TRƯỜNG ĐẠI HỌC CÔNG NGHỆ KỸ THUẬT TP. HỒ CHÍ MINH

KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO MÔN HỌC

AN NINH MẠNG

HỆ THỐNG XÁC THỰC TẬP TRUNG

GVHD: Nguyễn Thị Thanh Vân
SVTH:

Huỳnh Thiên Hạo- 23162021
Võ Gia Huân - 23162027
Trương Nguyễn - Minh Hậu 23162022
Bùi Việt Hoàng - 23162024

TP. HỒ CHÍ MINH - NĂM 2026

MỤC LỤC

PHẦN 1: MỞ ĐẦU 3
1. Mục tiêu nghiên cứu 3
2. Đối tượng nghiên cứu 3
3. Phương pháp nghiên cứu 4
4. Phạm vi nghiên cứu 5
PHẦN 2: NỘI DUNG 6
CHƯƠNG 1: TỔNG QUAN VỀ CƠ CHẾ HOẠT ĐỘNG 6
CỦA HỆ THỐNGXÁC THỰC TẬP TRUNG 6
1.1. Khái niệm về AAA (Authentication - Authorization - Accounting) 6
1.2. Các giao thức xác thực phổ biến 7
1.2.1. LDAP (Lightweight Directory Access Protocol) 7
1.2.2. RADIUS (Remote Authentication Dial-In User Service) 8
1.2.3. TACACS+ (Terminal Access Controller Access-Control System Plus) 8
1.2.4. Xác thực hai yếu tố (2FA – Two-Factor Authentication) 9
1.3. Xu hướng Zero Trust Network Access (ZTNA) 9
CHƯƠNG 2: GIỚI THIỆU THIẾT BỊ FORTIAUTHENTICATOR 200E 11
2.1. Thông số kĩ thuật của Fortiauthenticator 200E 11
2.2. Các tính năng của Fortiauthenticator 200E 12
2.2.1. Quản lý định danh tập trung (Centralized Identity Management) 12
2.2.2. Xác thực đa nhân tố (Multi-Factor Authentication - MFA) 13
2.2.3. Giải pháp Đăng nhập một lần (Fortinet Single Sign-On - FSSO) 13
2.2.4. Dịch vụ chứng thư số (Certificate Management/PKI) 13
2.2.5. Quản lý truy cập khách và Captive Portal 14
2.2.6. Khả năng tích hợp và Quản trị hệ thống 14
CHƯƠNG 3: TRIỂN KHAI CẤU HÌNH VÀ THỬ NGHIỆM 15
3.1. Lab 1: Tìm hiểu các thành phần trên thiết bị, giao diện quản trị. 15
3.2. Lab 2: Thực hành các tính năng LDAP 24
3.3. Lab 3: Thực hành các tính năng xác thực 2 bước 31
3.4. Lab 4: Thực hành khả năng giám sát xác thực 42

3.5. Lab 5: Thực hành xác thực SSO 45
PHẦN 3: KẾT LUẬN 53
3.1. Ưu nhược điểm của FortiAuthenticator 200E 53
3.2. Tổng kết 54
TÀI LIỆU THAM KHẢO 56

PHẦN 1: MỞ ĐẦU

1. Mục tiêu nghiên cứu

Nghiên cứu này được thực hiện nhằm đặt được các mục tiêu sau đây:

Hiểu rõ các nguyên tắc cơ bản: Nắm vững cấu trúc, nguyên lý hoạt động và các mô hình triển khai phổ biến của hệ thống xác thực tập trung (Centralized Authentication).

Khám phá các kỹ thuật bảo mật định danh: Tìm hiểu và phân tích các phương thức xác thực đa nhân tố (MFA), cơ chế đăng nhập một lần (SSO) và quản lý chứng thư số (CA) mà giải pháp FortiAuthenticator tích hợp.

Tích lũy kinh nghiệm thực tế: Có được kinh nghiệm thực hành trong việc cấu hình, triển khai và quản trị thiết bị xác thực cụ thể là FortiAuthenticator 200E để kiểm soát truy cập trong môi trường Lab.

Đánh giá hiệu quả bảo mật: Kiểm nghiệm và đánh giá một cách khách quan khả năng của thiết bị FortiAuthenticator 200E trong việc nhận diện người dùng và thực thi chính sách bảo mật định danh (User-based policy) thông qua các kịch bản mô phỏng.

Nhận định về giải pháp: Đưa ra những đánh giá về ưu điểm, nhược điểm và sự phù hợp của giải pháp FortiAuthenticator 200E dựa trên kết quả nghiên cứu và thực hành thực tế.

2. Đối tượng nghiên cứu

Đối tượng nghiên cứu trọng tâm và bao quát của báo cáo này là hệ thống xác thực tập trung (Centralized Authentication). Việc lựa chọn xác thực tập trung làm đối tượng chính xuất phát từ vai trò ngày càng quan trọng của quản trị định danh (IAM) trong việc đảm bảo an ninh cho hạ tầng mạng doanh nghiệp - một thành phần cốt lõi giúp thay thế mô hình quản lý theo địa chỉ IP truyền thống vốn nhiều sơ hở. Trong bối cảnh các cuộc tấn công đánh cắp danh tính và truy cập trái phép ngày càng gia tăng về số lượng và mức độ tinh vi, việc hiểu rõ và triển khai hiệu quả các giải pháp xác thực tập trung là một yêu cầu cấp thiết.

Để nghiên cứu hệ thống một cách cụ thể và thực tiễn, báo cáo tập trung vào một sản phẩm đại diện là thiết bị phần cứng FortiAuthenticator 200E của hãng bảo mật Fortinet. Lý do lựa chọn FortiAuthenticator 200E làm đối tượng nghiên cứu chính bao gồm:

Tính sẵn có trong môi trường thực hành: Đây là thiết bị hiện đại được trang bị tại phòng Lab, cho phép sinh viên có cơ hội được thực nghiệm trực tiếp và trải nghiệm thực tế.

Tính đại diện: FortiAuthenticator là một dòng sản phẩm quản lý định danh phổ biến trên thị trường, tích hợp đầy đủ các công nghệ bảo mật tiên tiến (như xác thực đa nhân tố MFA, quản lý chứng thư số CA, FSSO,...) đại diện cho các xu hướng bảo mật hiện đại. Model 200E cung cấp đầy đủ các tính năng cốt lõi phù hợp cho quy mô doanh nghiệp vừa và lớn.

Đối tượng thứ ba và không kém phần quan trọng là các thiết bị thực thi chính sách (Policy Enforcement Points) bao gồm FortiGate 100E (External Firewall), FortiWeb và FortiMail. Các thiết bị này được chọn làm đối tượng mục tiêu để FortiAuthenticator bảo vệ và xác thực người dùng. Sự lựa chọn này dựa trên các đặc điểm phù hợp:

Môi trường tích hợp đa dạng: Việc sử dụng tổ hợp các thiết bị này cho phép thực hiện các kịch bản xác thực thực tế từ truy cập Internet, bảo vệ ứng dụng Web đến bảo mật mail, tạo ra một môi trường lý tưởng để kiểm tra tính đồng bộ của hệ thống.

Phản ánh nhu cầu thực tế: Các thiết bị này mô phỏng sát với nhu cầu bảo mật đa lớp trong các doanh nghiệp ngoài đời thực, nơi mà một danh tính duy nhất cần được xác thực xuyên suốt qua nhiều tầng bảo vệ khác nhau.

Như vậy, việc nghiên cứu kết hợp ba đối tượng này (hệ thống xác thực tập trung nói chung, thiết bị FortiAuthenticator 200E và hệ thống thiết bị thực thi chính sách) cho phép báo cáo vừa có cái nhìn tổng quan về lý thuyết, vừa đi sâu vào thực hành và đánh giá thực tiễn một cách toàn diện và hiệu quả.

3. Phương pháp nghiên cứu

Để đạt được các mục tiêu đã đề ra và đảm bảo tính khoa học, khách quan cho báo cáo, các phương pháp nghiên cứu sau đây đã được áp dụng một cách kết hợp:

Nghiên cứu tài liệu: Là việc thu thập, tổng hợp và phân tích thông tin từ các nguồn tài liệu đa dạng và đáng tin cậy. Các nguồn này bao gồm tài liệu kỹ thuật chính thức của nhà sản xuất Fortinet, tài liệu hướng dẫn thực hành cụ thể tại phòng Lab, các bài báo khoa học và các giao thức xác thực tiêu chuẩn như RADIUS, LDAP, SAML.

Thực nghiệm trong phòng lab: Đây là phương pháp cốt lõi, bao gồm việc trực tiếp thao tác, cấu hình và triển khai thiết bị FortiAuthenticator 200E trong một môi trường mạng được kiểm soát.

Kiểm thử và mô phỏng: Sau khi cấu hình, báo cáo tiến hành kiểm thử hiệu quả của hệ thống bằng cách thiết kế và thực hiện các kịch bản truy cập có kiểm soát. Các kịch bản bao gồm việc người dùng truy cập mạng qua External Firewall (FortiGate), truy cập ứng dụng web qua FortiWeb hoặc sử dụng hệ thống mail qua FortiMail. Các thử nghiệm về xác thực hai lớp (2FA) qua FortiToken/Email và cơ chế đăng nhập một lần (SSO) được thực hiện để mô phỏng chính xác các nhu cầu bảo mật thực tế của doanh nghiệp.

Phân tích và đánh giá định tính: Cuối cùng, các kết quả thu được từ quá trình thực nghiệm và kiểm thử được phân tích một cách cẩn thận. Bao gồm việc xem các bản ghi nhật ký của hệ thống, quan sát hành vi thực tế của luồng dữ liệu xác thực khi đối mặt với các yêu cầu truy cập lạ hoặc cố gắng xâm nhập.

4. Phạm vi nghiên cứu

Phạm vi của báo cáo được giới hạn trong các khía cạnh sau:

Về lý thuyết: Báo cáo tập trung vào các khái niệm cơ bản và nâng cao của hệ thống xác thực tập trung (Centralized Authentication), bao gồm nguyên tắc hoạt động của mô hình AAA(Authentication, Authorization, Accounting), các giao thức xác thực tiêu chuẩn (RADIUS, LDAP, TACACS+), và đặc biệt là các phương pháp bảo mật định danh hiện đại như xác thực đa nhân tố (MFA/2FA), đăng nhập một lần (Single Sign-On - FSSO), và quản lý chứng thư số (PKI/CA). Chi tiết thiết bị FortiAuthenticator 200E.

Về thực hành: Phạm vi thực hành giới hạn trong việc cấu hình thiết bị FortiAuthenticator 200E trong môi trường Lab mô phỏng. Các cấu hình chính bao gồm thiết lập hệ thống quản trị, khởi tạo cơ sở dữ liệu người dùng và nhóm người dùng, triển khai dịch vụ RADIUS/LDAP, thiết lập xác thực hai lớp qua Email/FortiToken, và cấu hình cơ chế FSSO.

PHẦN 2: NỘI DUNG

CHƯƠNG 1: TỔNG QUAN VỀ CƠ CHẾ HOẠT ĐỘNG CỦA HỆ THỐNGXÁC THỰC TẬP TRUNG

Trong các hệ thống mạng truyền thống, việc kiểm soát truy cập thường được thực hiện dựa trên địa chỉ IP hoặc subnet. Cách tiếp cận này cho phép các thiết bị nằm trong dải địa chỉ hợp lệ được quyền truy cập vào tài nguyên mạng. Tuy nhiên, phương pháp này bộc lộ nhiều hạn chế, đặc biệt trong các hệ thống hiện đại có quy mô lớn và nhiều người dùng. Việc chỉ dựa vào IP khiến hệ thống không thể xác định chính xác danh tính của người sử dụng, dẫn đến khó khăn trong việc quản lý và kiểm soát truy cập. Ngoài ra, cơ chế này cũng dễ bị tấn công giả mạo địa chỉ IP (IP Spoofing), từ đó làm giảm mức độ an toàn của hệ thống.

Trong bối cảnh công nghệ phát triển mạnh mẽ, mô hình làm việc linh hoạt (remote working), điện toán đám mây (cloud computing) và sự phổ biến của thiết bị cá nhân (BYOD) đã đặt ra yêu cầu cao hơn về bảo mật. Do đó, xu hướng hiện nay là chuyển sang mô hình kiểm soát truy cập dựa trên danh tính (Identity-Based Access Control). Trong mô hình này, quyền truy cập không còn phụ thuộc vào địa chỉ mạng mà được gắn trực tiếp với từng người dùng cụ thể. Điều này giúp hệ thống dễ dàng quản lý, theo dõi và kiểm soát hoạt động truy cập một cách hiệu quả hơn.

1.1. Khái niệm về AAA (Authentication - Authorization - Accounting)

AAA là một khung kiến trúc bảo mật tiêu chuẩn được sử dụng để kiểm soát truy cập tài nguyên máy tính, thực thi các chính sách an ninh và giám sát quá trình sử dụng. Hệ thống AAA đóng vai trò trọng yếu trong quản trị mạng và an ninh mạng bằng cách sàng lọc người dùng và theo dõi hoạt động của họ, đảm bảo tuân thủ các nguyên tắc của mô hình CIA (Tính bảo mật - Tính toàn vẹn - Tính sẵn sàng).

Khung kiến trúc này được cấu thành từ ba thành phần cốt lõi:

- Authentication (Xác thực): Quá trình này yêu cầu người dùng cung cấp các bằng chứng định danh (Credentials) để đối chiếu với cơ sở dữ liệu lưu trữ. Các yếu tố xác thực như: mật khẩu, mã PIN, thẻ USB, Token vật lý, dấu vân tay, nhận diện khuôn mặt hoặc các đặc điểm sinh trắc học khác.

- Authorization (Cấp quyền): Quá trình này xảy ra sau khi xác thực thành công, hệ thống sẽ cấp các đặc quyền truy cập dựa trên danh tính người dùng. Việc cấp quyền quy định rõ các

vùng mạng hoặc tài nguyên mà người dùng có thể thao tác, đồng thời có thể được quản trị viên thay đổi linh hoạt tùy theo vai trò.

- Accounting (Ghi nhật ký/quản lý): Quá trình này sẽ theo dõi toàn bộ hoạt động của người dùng trong suốt phiên làm việc, bao gồm: thời gian login/logout, lượng dữ liệu ra vào, địa chỉ IP và các dịch vụ đã truy cập.

Vai trò: Khung AAA giúp hạn chế tối đa các đối tượng xâm nhập vào hệ thống với ý đồ xấu, đồng thời cung cấp khả năng truy vết trong trường hợp người dùng nội bộ lạm dụng đặc quyền. Có hai loại hình quản trị AAA chính:

- Network Access (Truy cập mạng): Kiểm soát chặt chẽ các thiết bị tham gia vào hệ thống mạng dựa trên thông tin định danh.

- Device Administration (Quản trị thiết bị): Kiểm soát quyền truy cập vào các phiên làm việc quản trị thiết bị (Console, SSH), quy định cụ thể ai được phép cấu hình hoặc thay đổi thông số trên các thiết bị mạng.

1.2. Các giao thức xác thực phổ biến

1.2.1. LDAP (Lightweight Directory Access Protocol)

LDAP là giao thức được sử dụng rộng rãi nhất trong việc quản lý và xác thực thông tin người dùng trong các hệ thống xác thực tập trung. Giao thức này hoạt động dựa trên mô hình cây thư mục (Directory Tree), trong đó dữ liệu được tổ chức theo cấu trúc phân cấp tương tự như hệ thống thư mục trong máy tính.

Trong LDAP, mỗi đối tượng (object) như người dùng, nhóm hoặc thiết bị đều được định danh bằng một Distinguished Name (DN) duy nhất. DN giúp hệ thống xác định chính xác vị trí của đối tượng trong cây thư mục, từ đó hỗ trợ việc tìm kiếm, truy vấn và quản lý dữ liệu một cách hiệu quả.

LDAP thường được sử dụng để lưu trữ các thông tin như tài khoản người dùng, mật khẩu (đã được mã hóa), nhóm người dùng (group), quyền truy cập và các thuộc tính liên quan khác. Điều này giúp hệ thống có thể quản lý tập trung toàn bộ danh tính người dùng trong doanh nghiệp.

Ngoài ra, LDAP còn hỗ trợ cơ chế bảo mật thông qua LDAPS (LDAP Secure), sử dụng giao thức mã hóa SSL/TLS để đảm bảo dữ liệu truyền giữa client và server không bị nghe lén hoặc giả mạo.

1.2.2. RADIUS (Remote Authentication Dial-In User Service)

RADIUS là một giao thức quan trọng trong việc xác thực người dùng truy cập mạng, đặc biệt trong các hệ thống như VPN, WiFi doanh nghiệp hoặc truy cập từ xa. Giao thức này hoạt động theo mô hình client-server.

Trong đó:

- Các thiết bị mạng như router, firewall, access point hoặc VPN gateway đóng vai trò client.

- Máy chủ RADIUS đóng vai trò server, chịu trách nhiệm xử lý yêu cầu xác thực

Khi người dùng thực hiện đăng nhập, thiết bị client sẽ gửi thông tin xác thực (username/password) đến máy chủ RADIUS. Sau đó, server sẽ kiểm tra thông tin và trả về kết quả cho phép hoặc từ chối truy cập.

RADIUS hỗ trợ đầy đủ ba chức năng chính (AAA):

- Authentication (Xác thực): Kiểm tra danh tính người dùng

- Authorization (Phân quyền): Xác định quyền truy cập tài nguyên

- Accounting (Ghi log): Ghi lại lịch sử truy cập và hoạt động của người dùng

Nhờ các chức năng này, RADIUS giúp hệ thống kiểm soát truy cập chặt chẽ và dễ dàng theo dõi, audit các hoạt động trong mạng.

1.2.3. TACACS+ (Terminal Access Controller Access-Control System Plus)

TACACS+ là một giao thức xác thực thường được sử dụng trong quản trị thiết bị mạng như router và switch. Giao thức này có nhiều điểm tương đồng với RADIUS nhưng được đánh giá cao hơn về mặt bảo mật và khả năng kiểm soát.

Một trong những ưu điểm nổi bật của TACACS+ là mã hóa toàn bộ nội dung giao tiếp giữa client và server, trong khi RADIUS chỉ mã hóa phần mật khẩu. Điều này giúp tăng cường khả năng bảo vệ dữ liệu khỏi các cuộc tấn công nghe lén.

Ngoài ra, TACACS+ cho phép phân tách rõ ràng ba chức năng AAA (Authentication, Authorization, Accounting). Điều này mang lại khả năng kiểm soát chi tiết hơn, đặc biệt trong việc phân quyền cho các quản trị viên hệ thống (ví dụ: cho phép xem cấu hình nhưng không cho phép chỉnh sửa).

Nhờ những ưu điểm trên, TACACS+ thường được sử dụng trong các môi trường yêu cầu mức độ bảo mật cao và kiểm soát truy cập chặt chẽ.

1.2.4. Xác thực hai yếu tố (2FA – Two-Factor Authentication)

Để tăng cường mức độ bảo mật cho hệ thống xác thực tập trung, các doanh nghiệp hiện nay thường triển khai thêm cơ chế xác thực hai yếu tố (2FA) hoặc đa nhân tố (MFA). Đây là các phương pháp yêu cầu người dùng cung cấp hai hoặc nhiều yếu tố xác thực độc lập khi đăng nhập.

Thông thường, các yếu tố này bao gồm:

- Yếu tố thứ nhất: Mật khẩu (Something you know)

- Yếu tố thứ hai: Mã OTP hoặc thiết bị xác thực (Something you have)

- Yếu tố thứ ba (chỉ có ở MFA): các đặc điểm sinh học (vân tay, khuôn mặt,...)

Việc triển khai MFA/2FA trên hệ thống xác thực tập trung giúp biến các điểm truy cập nhạy cảm (thiết bị máy tính, mạng nội bộ, cơ sở dữ liệu) thành những mục tiêu khó xâm phạm, đảm bảo an toàn tối đa cho tài sản số của doanh nghiệp ngay cả trong kịch bản mật khẩu hệ thống bị chiếm đoạt.

1.3. Xu hướng Zero Trust Network Access (ZTNA)

Trong bối cảnh hạ tầng mạng doanh nghiệp không còn giới hạn trong phạm vi văn phòng vật lý, mô hình bảo mật truyền thống dựa trên "hàng rào biên" (Perimeter-based Security) đã bộc lộ nhiều lỗ hổng. Zero Trust Network Access (ZTNA) ra đời như một sự chuyển dịch tất yếu, thay đổi hoàn toàn cách thức kiểm soát truy cập tài nguyên.

Khác với mô hình mạng truyền thống thường mặc định tin tưởng các kết nối bên trong nội bộ, ZTNA vận hành trên nguyên tắc mọi yêu cầu truy cập dù từ bên trong hay bên ngoài mạng đều bị coi là không đáng tin cậy cho đến khi được xác minh đầy đủ. ZTNA loại bỏ khái niệm "vùng tin cậy" và tập trung bảo vệ từng ứng dụng, tài nguyên cụ thể thay vì bảo vệ toàn bộ dải mạng.

Hệ thống ZTNA dựa trên sự kết hợp chặt chẽ của ba yếu tố kiểm chứng:

- Xác thực định danh người dùng (User Identity): Sử dụng hệ thống xác thực tập trung và MFA để định danh người dùng.

- Kiểm tra trạng thái thiết bị (Device Posture): Xác minh thiết bị kết nối có tuân thủ các quy định bảo mật hay không.

- Chính sách đặc quyền tối thiểu (Least Privilege Access): Người dùng chỉ được cấp quyền truy cập vừa đủ vào các ứng dụng cần thiết cho công việc, thay vì có toàn quyền truy cập vào phân vùng mạng.

CHƯƠNG 2: GIỚI THIỆU THIẾT BỊ FORTIAUTHENTICATOR 200E

Sau khi tìm hiểu về cấu trúc, nguyên lý hoạt động chung của hệ thống xác thực tập trung và các giao thức bảo mật định danh mà giải pháp này tích hợp, chương này sẽ đi sâu vào giới thiệu cụ thể về thiết bị FortiAuthenticator 200E. Đây là một trong những model thuộc dòng sản phẩm quản lý định danh và quyền truy cập (IAM) của Fortinet, được thiết kế để cung cấp giải pháp bảo mật danh tính mạnh mẽ và linh hoạt cho các doanh nghiệp quy mô vừa và lớn. Việc hiểu rõ về thông số kỹ thuật và các tính năng của FortiAuthenticator 200E sẽ giúp chúng ta có cái nhìn thực tế hơn về khả năng và phạm vi ứng dụng của thiết bị này trong việc xây dựng một hạ tầng an ninh mạng hiện đại, đồng bộ.

2.1. Thông số kĩ thuật của Fortiauthenticator 200E

FortiAuthenticator 200E là một thiết bị phần cứng chuyên dụng (appliance) được Fortinet tối ưu hóa cho nhiệm vụ quản trị và xác thực tập trung, cung cấp một sự cân bằng giữa hiệu suất xử lý, mật độ người dùng và các tính năng bảo mật danh tính. Để đánh giá đầy đủ khả năng của thiết bị này trong hệ thống xác thực tập trung, việc xem xét các thông số kỹ thuật chi tiết là điều cần thiết.

Về hiệu suất xử lý, FortiAuthenticator 200E được thiết kế để đáp ứng nhu cầu của các doanh nghiệp có số lượng người dùng và lưu lượng yêu cầu xác thực ở mức trung bình đến lớn. Thiết bị có khả năng xử lý thông lượng RADIUS lên đến 500 - 600 yêu cầu mỗi giây (Requests Per Second - RPS), đảm bảo thời gian phản hồi cực thấp ngay cả trong các khung giờ cao điểm khi có lượng lớn nhân viên đăng nhập hệ thống đồng thời. Về khả năng quản lý định danh, thiết bị hỗ trợ mặc định lên đến 500 người dùng cục bộ (Local Users) và có thể mở rộng thông qua các gói bản quyền, đáp ứng linh hoạt quy trình tăng trưởng nhân sự của doanh nghiệp.

Về giao diện phần cứng và kết nối mạng, FortiAuthenticator 200E được trang bị hệ thống cổng kết nối đa dạng để tối ưu hóa việc tích hợp vào hạ tầng mạng sẵn có. Thiết bị sở hữu 4 cổng mạng Gigabit Ethernet (GE RJ45), cho phép thiết lập các kết nối riêng biệt cho các vùng mạng quản trị, mạng xác thực và mạng dự phòng. Ngoài ra, mặt trước thiết bị tích hợp các cổng USB để hỗ trợ việc cấu hình nhanh hoặc sao lưu dữ liệu, cùng cổng Console (RJ45) phục vụ cho việc quản trị trực tiếp thông qua giao diện dòng lệnh (CLI) trong các trường hợp khẩn cấp.

Về khả năng lưu trữ và quản lý dữ liệu, thiết bị được trang bị ổ cứng HDD dung lượng 1 TB. Đây là một yếu tố quan trọng giúp FortiAuthenticator không chỉ lưu trữ cơ sở dữ liệu người

dùng khổng lồ mà còn đảm bảo không gian cho việc lưu trữ nhật ký hệ thống (Logs) và các báo cáo xác thực trong thời gian dài. Hệ thống lưu trữ này cũng hỗ trợ việc quản lý các chứng thư số (Certificates) và lưu trữ cấu hình sao lưu tự động, giúp hệ thống có khả năng phục hồi nhanh chóng sau sự cố.

Về yếu tố hình thức và môi trường hoạt động, thiết bị được thiết kế theo dạng 1U Rackmount, phù hợp để lắp đặt vào các tủ tiêu chuẩn tại trung tâm dữ liệu (Data Center). Thiết bị hoạt động ổn định trong dải nhiệt độ từ 0°C đến 40°C với độ ẩm từ 5% đến 95%, đảm bảo tính bền bỉ trong môi trường phòng Server chuyên nghiệp.

Về nguồn điện cung cấp và quản lý, FortiAuthenticator 200E sử dụng bộ nguồn AC đơn với dải điện áp rộng từ 100V đến 240V, tiêu thụ điện năng thấp nhưng vẫn duy trì hiệu suất hoạt động liên tục 24/7. Việc quản lý thiết bị được thực hiện linh hoạt thông qua giao diện đồ họa Web (Web UI) hiện đại, trực quan hoặc qua CLI cho các tác vụ chuyên sâu, giúp quản trị viên dễ dàng theo dõi trạng thái hệ thống và cấu hình các chính sách xác thực phức tạp.

2.2. Các tính năng của Fortiauthenticator 200E

Thiết bị FortiAuthenticator 200E cung cấp một tập hợp các tính năng quản trị định danh và quyền truy cập (IAM) chuyên sâu, đóng vai trò là "nguồn sự thật" (Source of Truth) cho toàn bộ hệ sinh thái bảo mật của doanh nghiệp. Các tính năng này được thiết kế để chuẩn hóa quy trình xác thực, tăng cường bảo mật lớp định danh và tối ưu hóa trải nghiệm người dùng.

2.2.1. Quản lý định danh tập trung (Centralized Identity Management)

FortiAuthenticator 200E hoạt động như một kho lưu trữ định danh hợp nhất, cho phép quản trị viên kiểm soát toàn bộ vòng đời của người dùng từ một giao diện duy nhất.

- Hỗ trợ đa giao thức: Thiết bị đóng vai trò là máy chủ RADIUS và LDAP, đồng thời hỗ trợ giao thức TACACS+ để quản trị các thiết bị mạng.

- Đồng bộ hóa thư mục ngoại vi: Khả năng kết nối và đồng bộ hóa thời gian thực với Microsoft Active Directory (AD) và các máy chủ LDAP bên thứ ba. Tính năng LDAP Proxy cho phép thiết bị chuyển tiếp các yêu cầu xác thực tới các hệ thống thư mục sẵn có mà không cần thay đổi cấu trúc hạ tầng hiện tại.

- Quản trị dựa trên vai trò (RBAC): Phân quyền truy cập tài nguyên dựa trên nhóm người dùng, giúp áp dụng các chính sách bảo mật khác nhau cho từng phòng ban (Kế toán, Kỹ thuật, Khách).

2.2.2. Xác thực đa nhân tố (Multi-Factor Authentication - MFA)

Đây là tính năng cốt lõi giúp bảo vệ hệ thống khỏi các cuộc tấn công đánh cắp mật khẩu.

- Hệ sinh thái FortiToken: Quản lý và cấp phát mã OTP thông qua FortiToken Mobile (ứng dụng trên iOS/Android), FortiToken Cloud, hoặc các thiết bị phần cứng (Hard Tokens).

- Công nghệ xác thực Push: Hỗ trợ xác thực qua thông báo đẩy, cho phép người dùng phê duyệt yêu cầu truy cập chỉ với một chạm trên thiết bị di động, tăng tính tiện dụng so với việc nhập mã thủ công.

- Kênh truyền tin thay thế: Hỗ trợ gửi mã xác thực dùng một lần qua Email hoặc SMS (thông qua tích hợp với các Gateway SMS hoặc dịch vụ FortiGuard).

2.2.3. Giải pháp Đăng nhập một lần (Fortinet Single Sign-On - FSSO)

FSSO là tính năng đặc thù giúp tích hợp sâu FortiAuthenticator vào hệ sinh thái Security Fabric.

- Nhận diện người dùng không cần đăng nhập lại: Khi người dùng xác thực thành công vào mạng (qua AD hoặc Portal), FortiAuthenticator sẽ tự động thông báo danh tính và địa chỉ IP của người dùng đó cho thiết bị FortiGate.

- Kiểm soát truy cập ứng dụng: Cho phép FortiGate áp dụng các chính sách tường lửa dựa trên tên người dùng (User-based) thay vì địa chỉ IP, đảm bảo tính chính xác ngay cả trong môi trường cấp phát IP động (DHCP).

- Hỗ trợ SAML IdP: FortiAuthenticator đóng vai trò là Identity Provider (IdP), cho phép người dùng sử dụng một tài khoản duy nhất để đăng nhập vào các ứng dụng SaaS (như Office 365, Salesforce) thông qua giao thức SAML 2.0.

2.2.4. Dịch vụ chứng thư số (Certificate Management/PKI)

Thiết bị tích hợp hệ thống quản lý mã khóa công khai (PKI) hoàn chỉnh để xác thực thực thể.

- Certificate Authority (CA): Hoạt động như một Root CA hoặc Subordinate CA để cấp phát, ký duyệt và thu hồi chứng thư số X.509.

- Tự động hóa cấp phát (SCEP/EST): Hỗ trợ các giao thức Simple Certificate Enrollment Protocol (SCEP) và Enrollment over Secure Transport (EST) để tự động cấp phát chứng chỉ cho các thiết bị đầu cuối, camera IP, hoặc thiết bị IoT trong mạng.

- Xác thực thiết bị (Certificate-based Auth): Cung cấp khả năng xác thực không cần mật khẩu cho các kết nối VPN và xác thực thiết bị trong mạng nội bộ (802.1X).

2.2.5. Quản lý truy cập khách và Captive Portal

Cung cấp giải pháp kiểm soát truy cập cho các đối tượng không thuộc biên chế doanh nghiệp.

- Cổng chào tùy chỉnh (Captive Portal): Giao diện đăng nhập web có thể tùy biến thương hiệu, dùng để xác thực khách hàng truy cập Wi-Fi hoặc mạng nội bộ.

- Tự đăng ký (Self-Registration): Cho phép khách tự tạo tài khoản và nhận thông tin đăng nhập qua SMS/Email sau khi được quản trị viên (hoặc nhân viên bảo trợ) phê duyệt.

- Social Login: Hỗ trợ đăng nhập thông qua các tài khoản mạng xã hội (Facebook, Google, LinkedIn) thông qua giao thức OAuth.

2.2.6. Khả năng tích hợp và Quản trị hệ thống

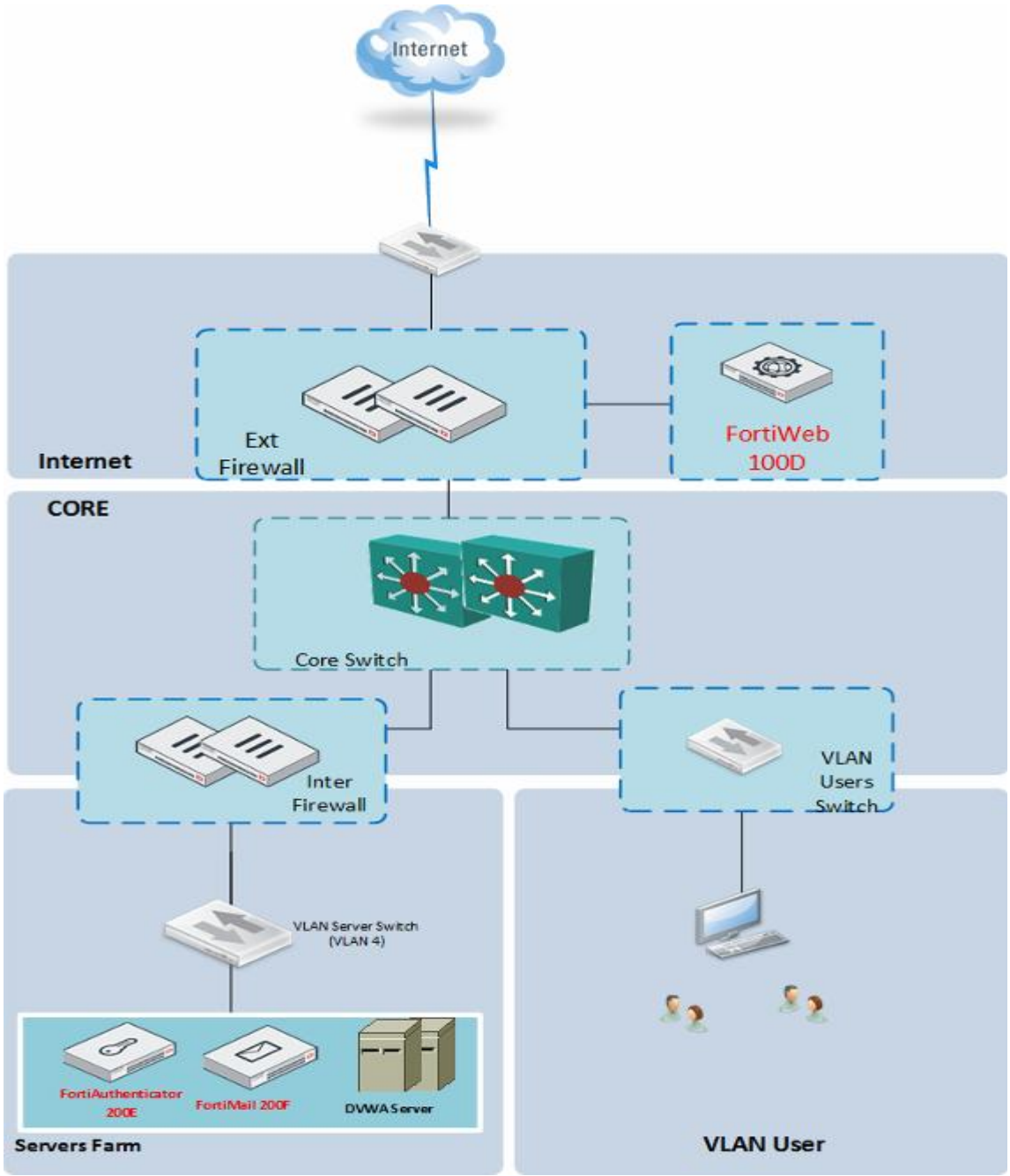
- REST API: Cung cấp giao diện lập trình ứng dụng (API) để tích hợp với các hệ thống quản trị bên thứ ba hoặc tự động hóa quy trình tạo/xóa tài khoản.

- Hệ thống báo cáo và Nhật ký (Logging & Reporting): Lưu trữ chi tiết lịch sử xác thực, các lần đăng nhập thất bại và hoạt động của quản trị viên để phục vụ công tác kiểm toán an ninh.

- Dự phòng hệ thống (High Availability): Hỗ trợ cấu hình Active-Passive hoặc Active-Active để đảm bảo dịch vụ xác thực luôn sẵn sàng ngay cả khi có sự cố phần cứng.

CHƯƠNG 3: TRIỂN KHAI CẤU HÌNH VÀ THỬ NGHIỆM

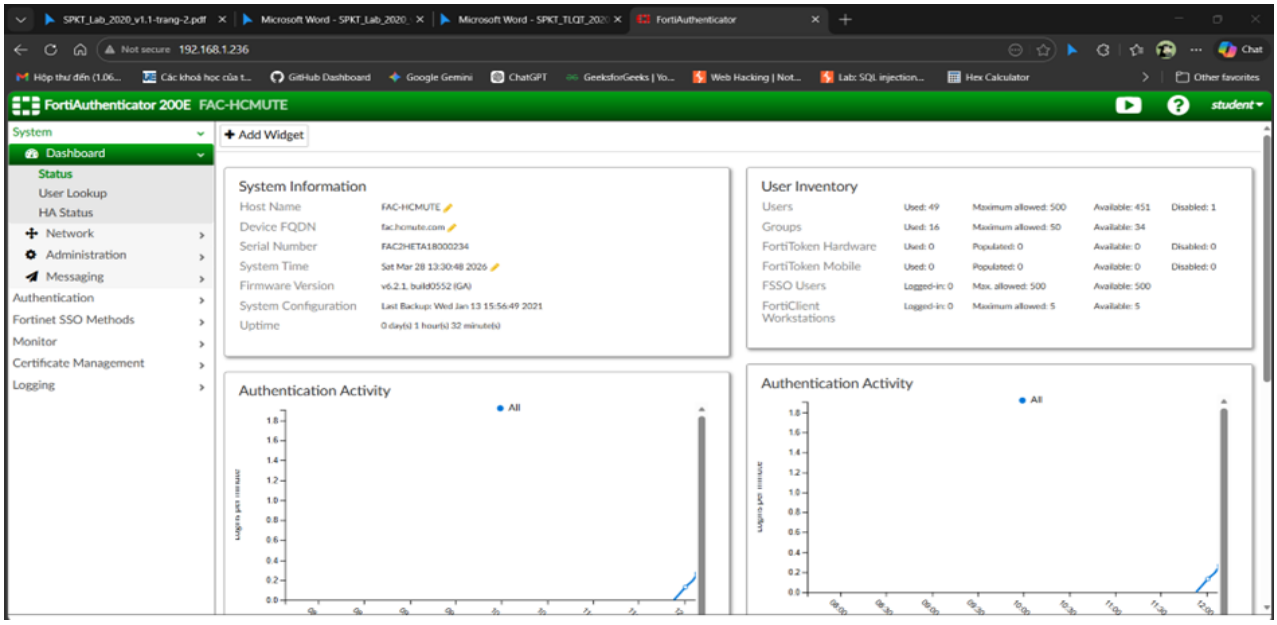
Sơ đồ mạng triển khai: chi tiết các thành phần



3.1. Lab 1: Tìm hiểu các thành phần trên thiết bị, giao diện quản trị.

Mục tiêu: tiếp cận giao diện quản trị web của FortiAuthenticator và nắm bắt các thông số vận hành cơ bản của thiết bị.

- Giao diện Dashboard và thông tin hệ thống

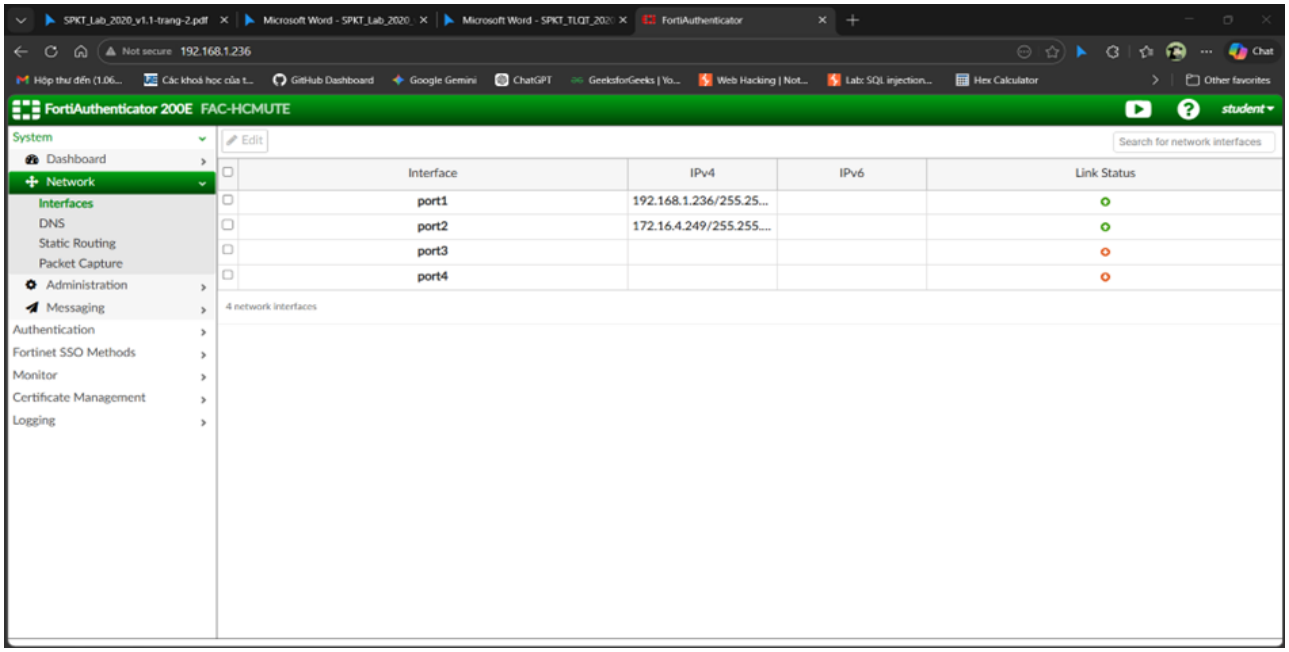


+ System Information: Hiển thị các thông tin định danh thiết bị bao gồm Host Name (FAC-HCMUTE), Device FQDN (fac.hcmute.com), số Serial Number (FAC2HETA18000234) và phiên bản Firmware hiện tại (v6.2.1, build0552).

+ User Inventory: Thống kê hiện trạng sử dụng tài nguyên. Hệ thống hiện có 49 người dùng (trên tổng số 500 cho phép) và 16 nhóm người dùng (trên tổng số 50 cho phép).

+ Authentication Activity: Biểu đồ quan trắc hoạt động xác thực theo thời gian thực, giúp quản trị viên theo dõi lưu lượng truy cập và các biến động bất thường trong hệ thống.

- Cấu hình giao tiếp mạng

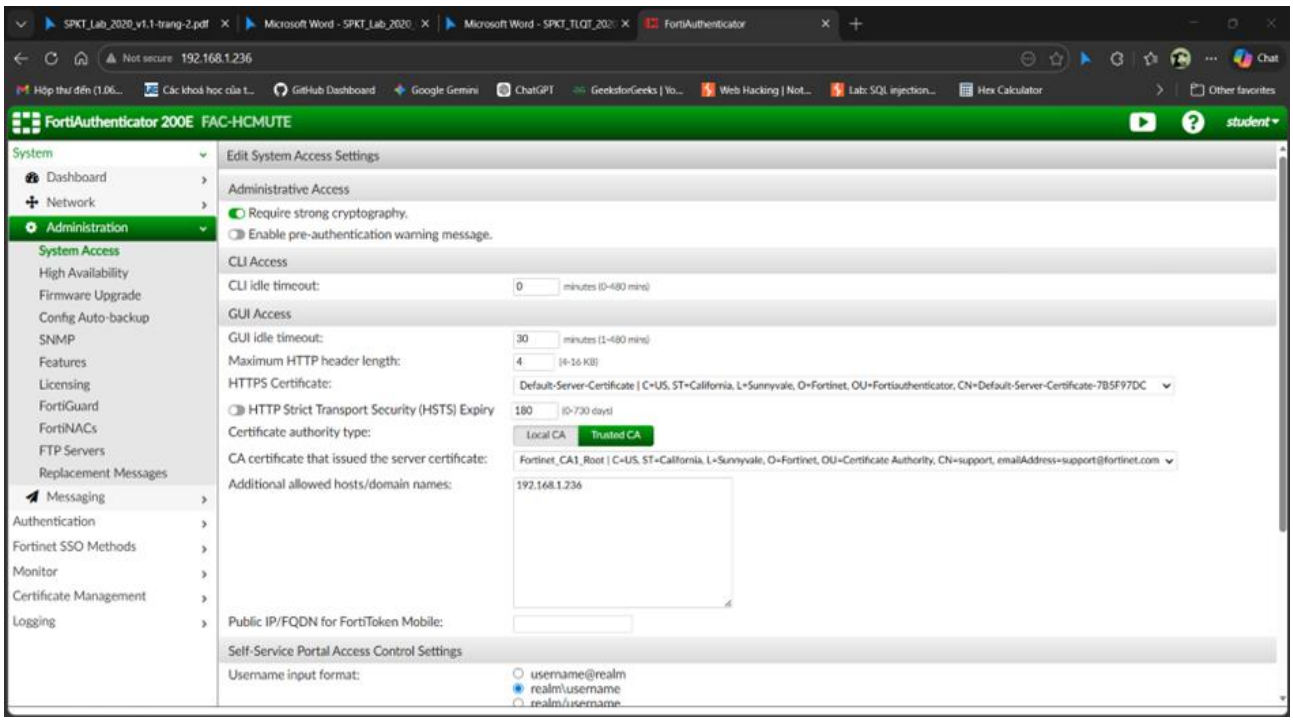


+ Port1 (Address IP: 192.168.1.236): Là cổng quản trị chính dùng để truy cập vào FortiAuthenticatior và thực hiện các cấu hình hệ thống.

+ Cổng port2: Được cấu hình địa chỉ IP 172.16.4.249. Cổng này đóng vai trò giao tiếp trong mạng nội bộ hoặc kết nối tới các thiết bị thực thi như FortiGate để truyền tải dữ liệu xác thực.

+ Chức năng: Giao diện này cho phép quản trị viên tùy chỉnh các tham số mạng như IPv4/IPv6, MTU, và các dịch vụ truy cập được phép trên từng cổng (HTTPS, SSH, PING, RADIUS...).

- Cấu hình truy cập hệ thống (System Access)

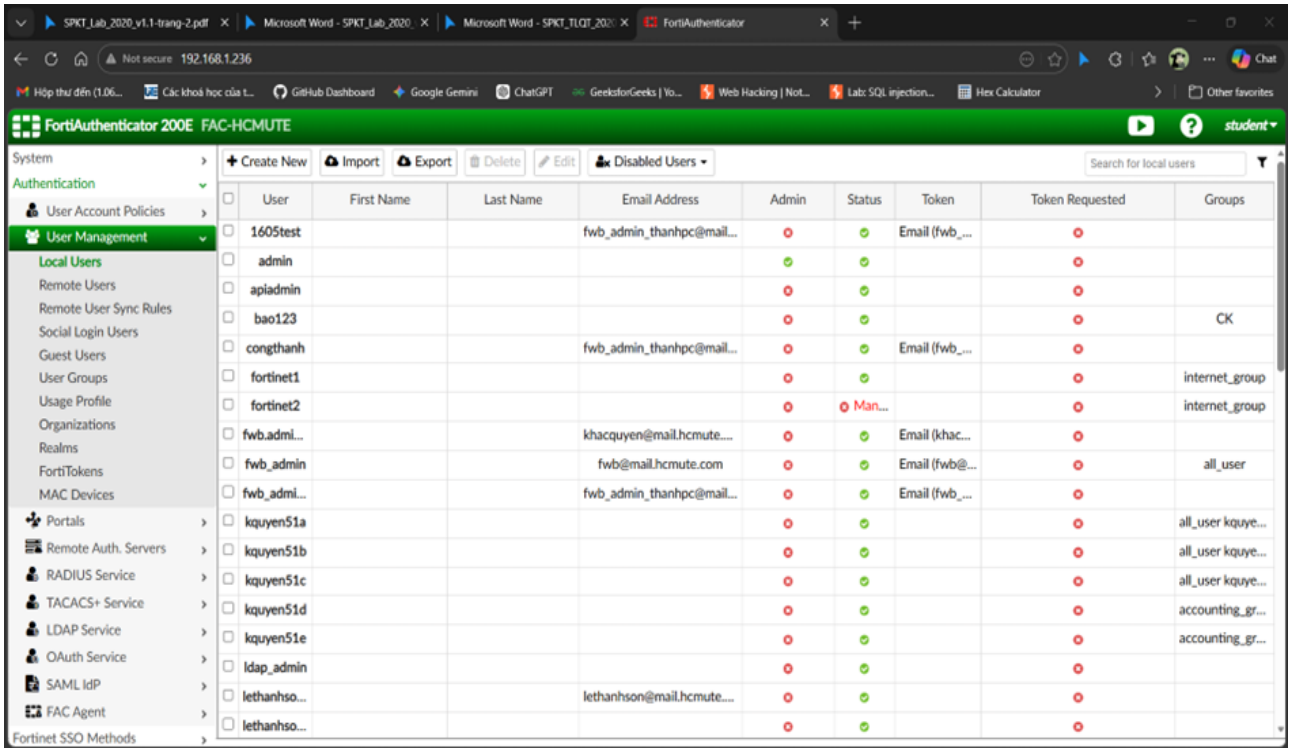


+ Administrative Access: dữ liệu được truyền tải giữa trình duyệt và thiết bị khi kích hoạt được mã hóa mạnh.

+ GUI Access: Thiết lập thời gian tự động ngắt kết nối khi không thao tác (GUI idle timeout) là 30 phút. Sử dụng chứng thư số hệ thống (HTTPS Certificate) để mã hóa kết nối truy cập web.

+ Allowed Hosts: Giới hạn dải địa chỉ IP hoặc host cụ thể (192.168.1.236) được phép truy cập quản trị, nhằm ngăn chặn các nỗ lực xâm nhập từ các vùng mạng không xác định.

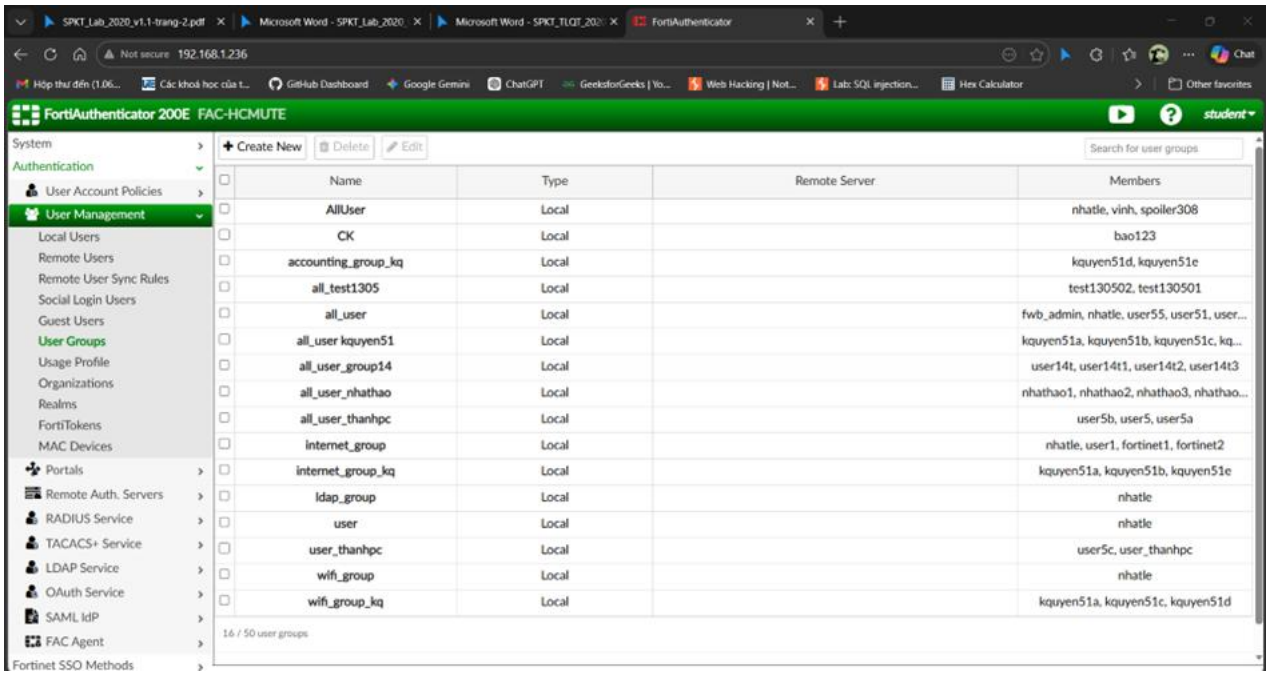
- Quản lý người dùng và nhóm người dùng (User & Group Management)



+ Local Users: Danh sách hiển thị các tài khoản người dùng nội bộ như 1605test, bao123, …

+ Thông tin định danh: Mỗi tài khoản đi kèm với địa chỉ Email để phục vụ tính năng gửi mã xác thực cùng với Status cho biết tài khoản đang hoạt động hay bị khóa.

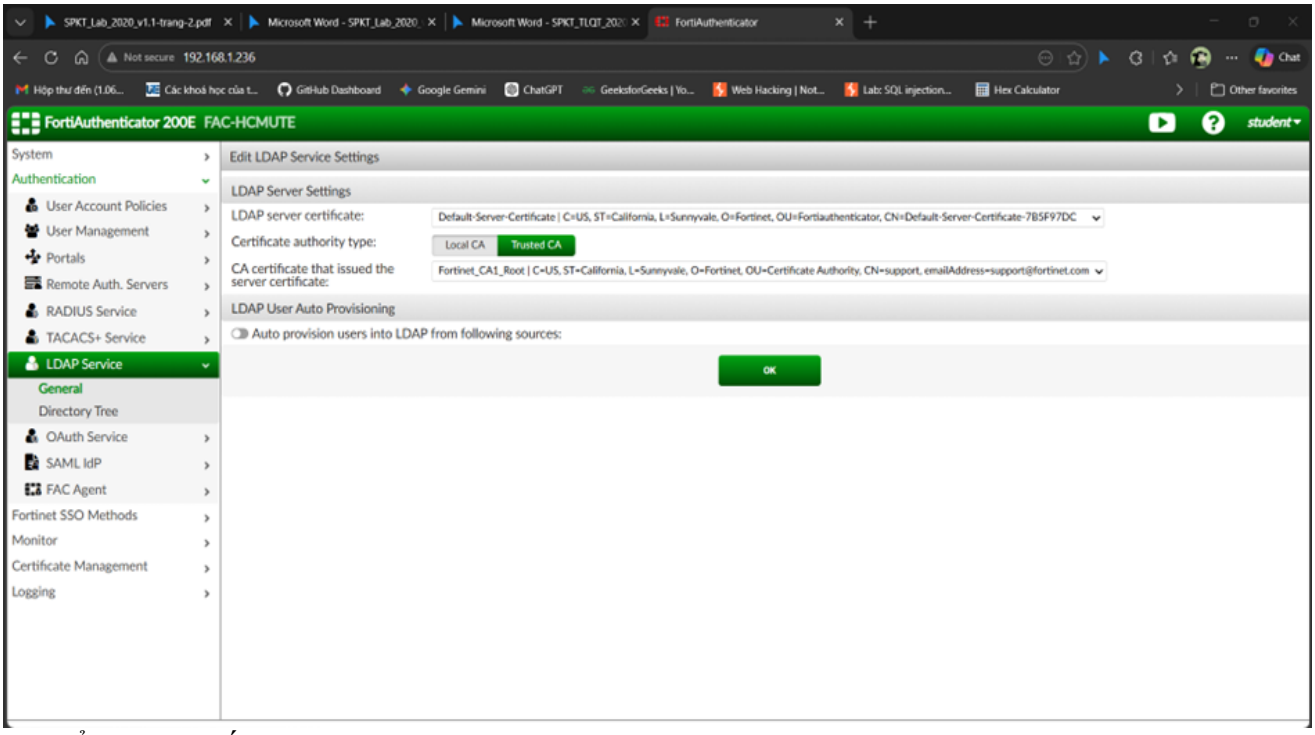
+ Xác thực đa nhân tố: Cột Token hiển thị phương thức 2FA đang áp dụng (ví dụ: Email Token) cho từng người dùng cụ thể.



+ User Groups: Các tài khoản cá nhân được gom nhóm theo chức năng hoặc phòng ban như accounting_group_kq, internet_group, wifi_group...

+ Mục đích: Việc phân nhóm giúp đơn giản hóa quá trình áp đặt chính sách bảo mật (Policy) trên các thiết bị thực thi như FortiGate hoặc FortiWeb.

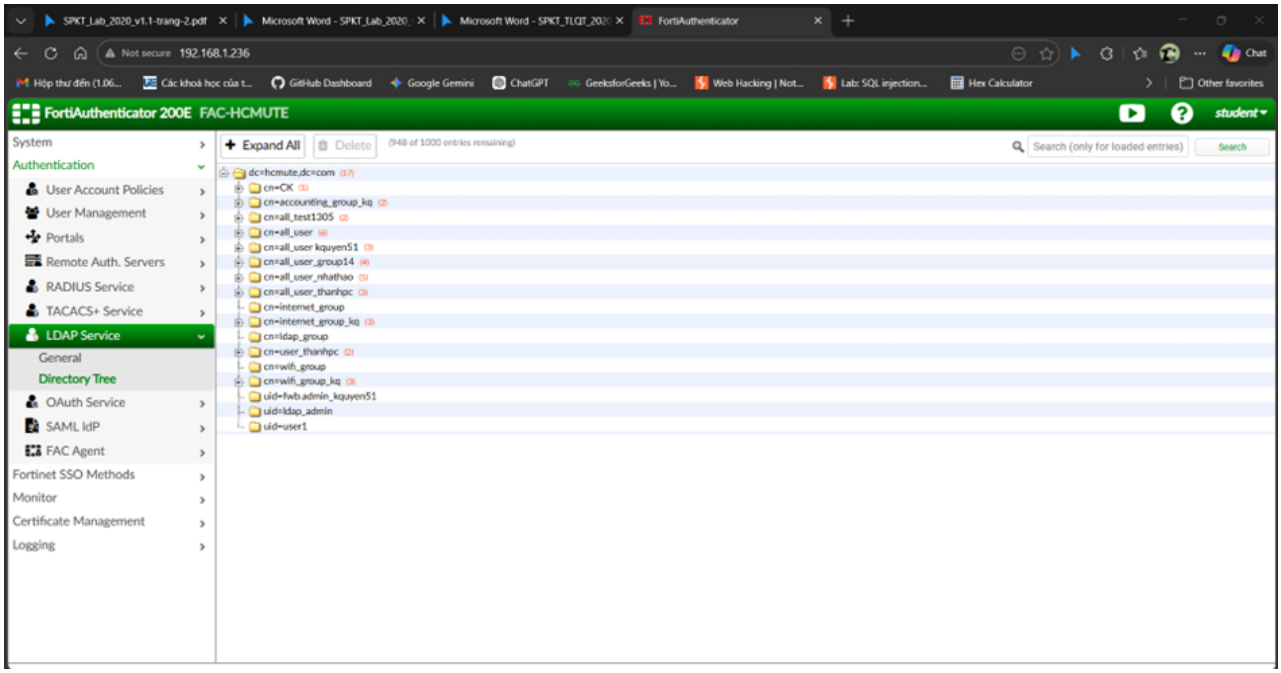
+ Cấu hình dịch vụ thư mục LDAP (LDAP Service): Dịch vụ LDAP cho phép FortiAuthenticator đóng vai trò như một máy chủ thư mục, kết nối tới các hệ thống thư mục hiện



có để quản lý cấu trúc cây định danh.

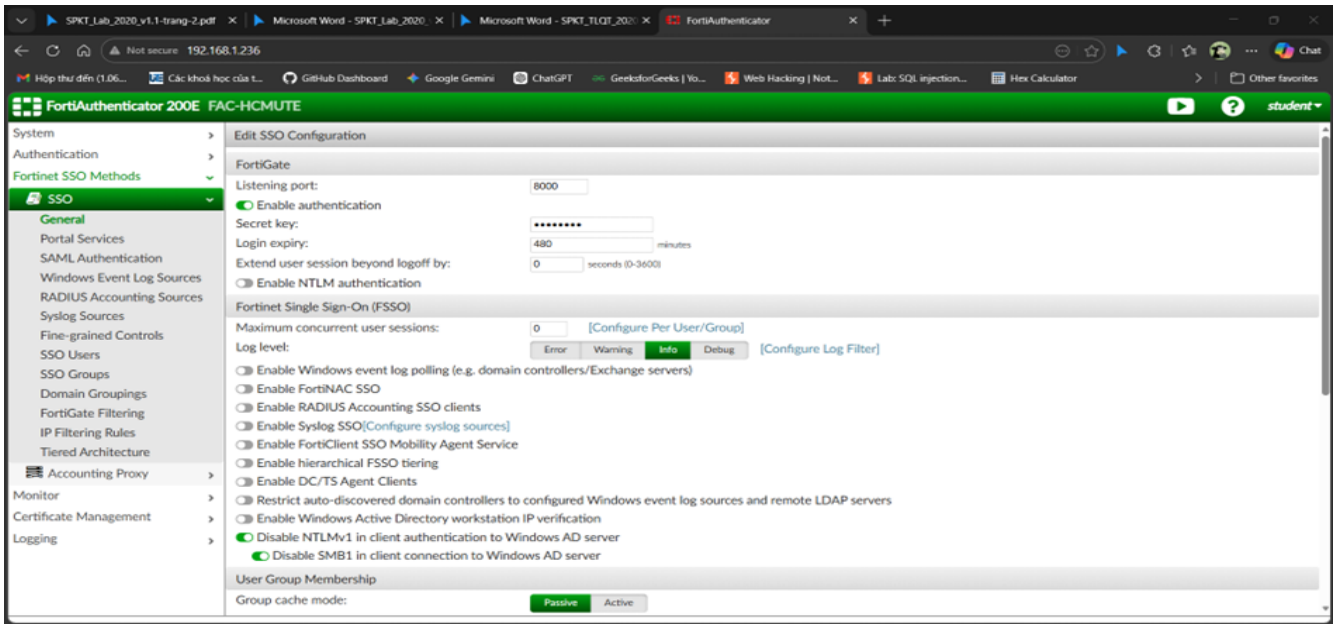
Cấu hình chung cho dịch vụ LDAP

+ Thiết lập các thông số về chứng thư số cho LDAP Server và tính năng tự động cấp phát người dùng (Auto Provisioning) từ các nguồn dữ liệu bên ngoài.



Cấu trúc cây thư mục LDAP (Directory Tree)

+ Hiển thị cấu trúc phân cấp dữ liệu định danh với gốc là dc=hcmute, dc=com. Các nút con bao gồm các nhóm người dùng và tài khoản định danh cá nhân, phản ánh tổ chức nhân sự của đơn vị trên hệ thống số

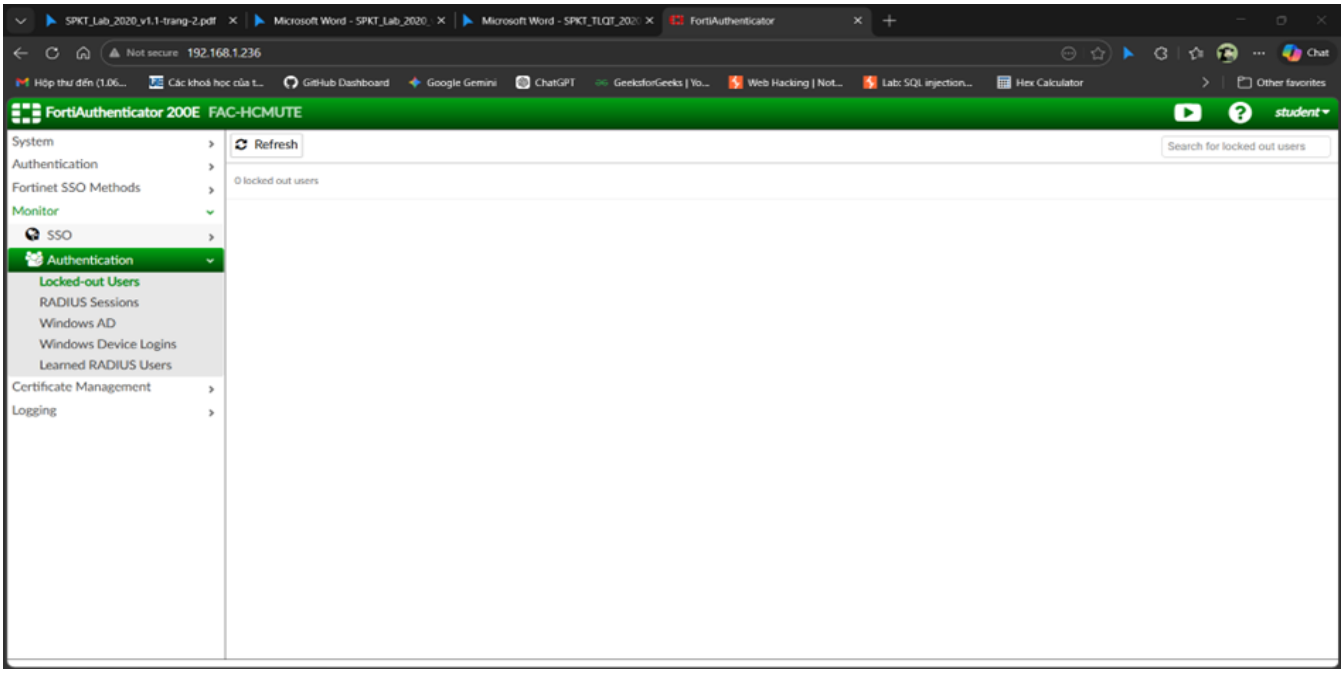


Cấu hình Fortinet Single Sign-On (FSSO)

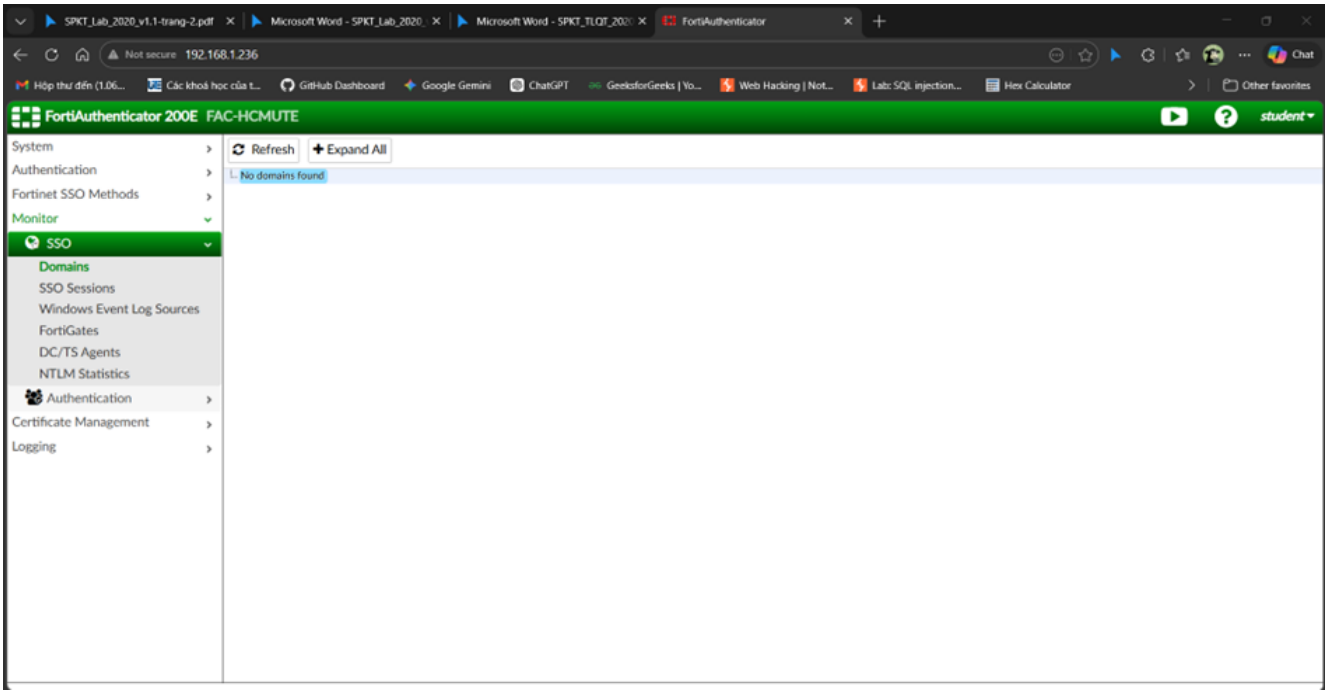
+ FortiGate Integration: Cấu hình cổng lắng nghe (Listening port) mặc định là 8000 và thiết lập khóa bí mật (Secret key) để thiết lập kênh truyền tin an toàn với thiết bị FortiGate.

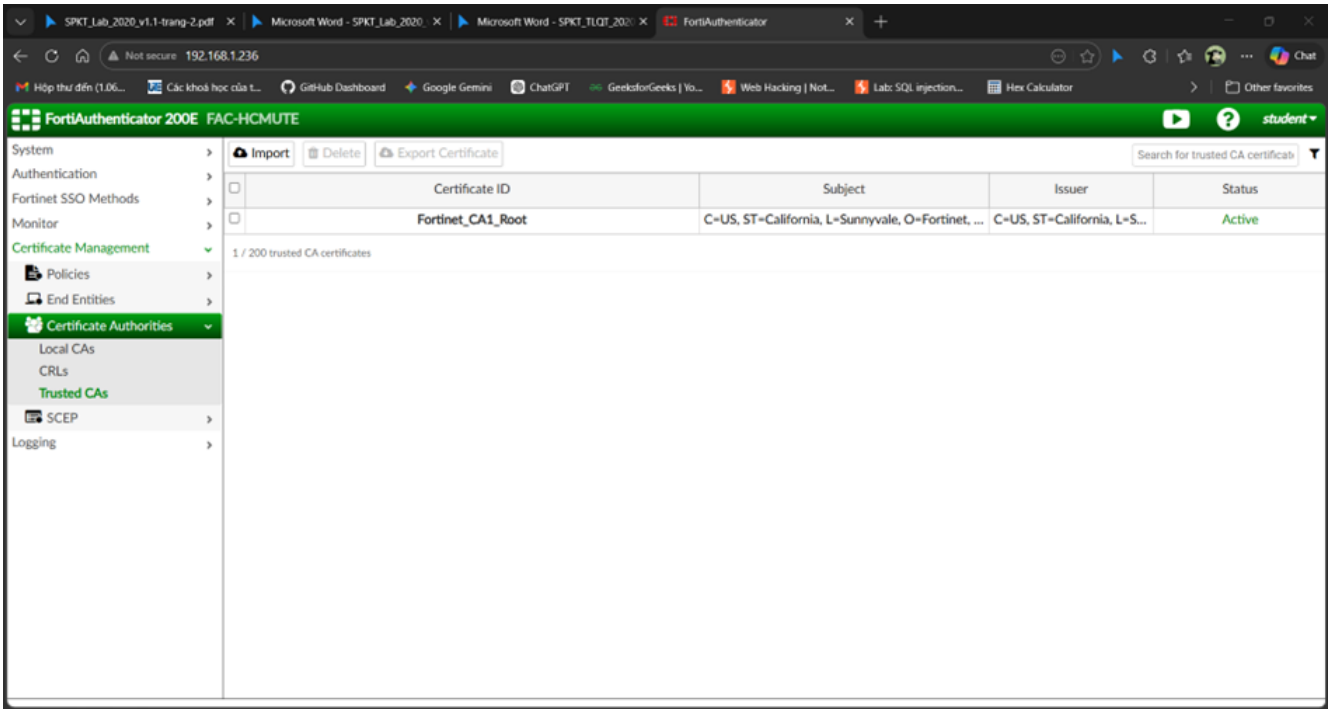
+ Cơ chế thu thập dữ liệu: Hỗ trợ nhiều phương thức như Windows Event Log polling, RADIUS Accounting, hoặc Syslog SSO để nhận diện trạng thái đăng nhập của người dùng trong mạng.

+ Security: Tùy chọn vô hiệu hóa các giao thức cũ, kém an toàn như NTLMv1 hoặc SMB1 khi thực hiện xác thực với Windows AD Server.



+ SSO Domains: Giao diện hiển thị các danh mục tên miền đang tham gia vào cơ chế Đăng nhập một lần



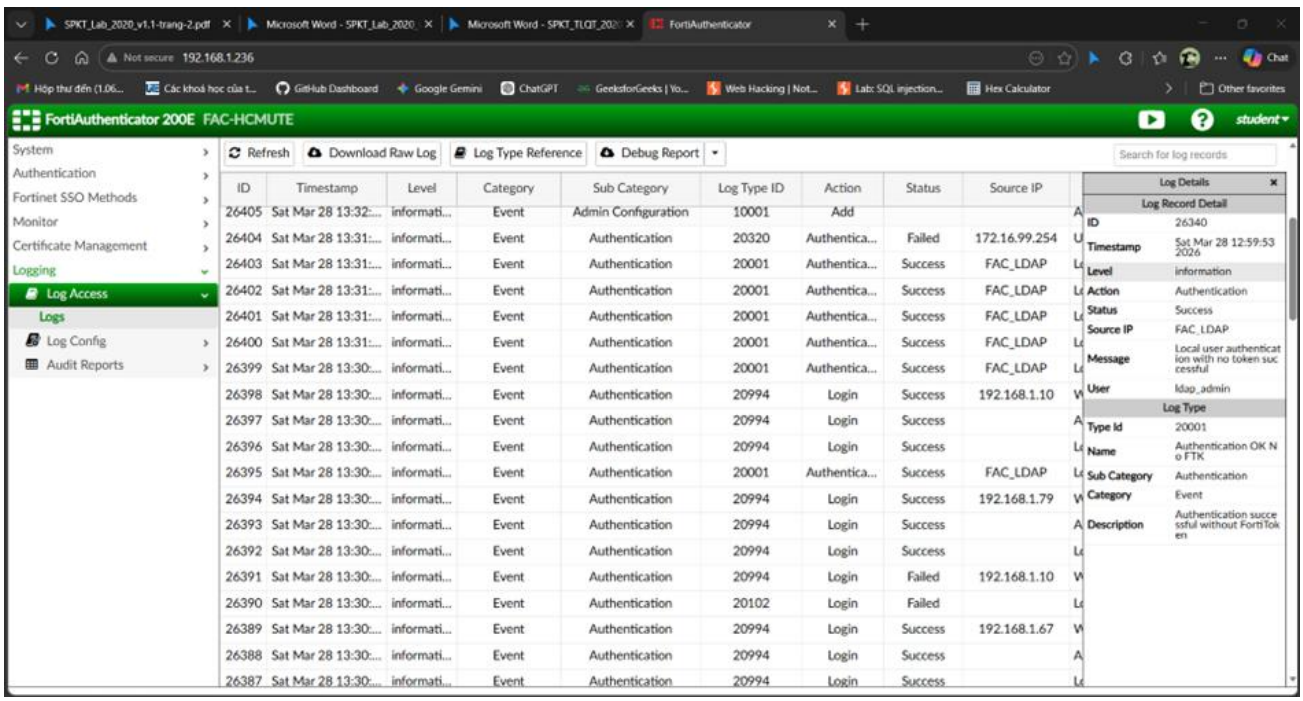


+ Authentication Monitor: Cung cấp danh sách các tài khoản bị tạm khóa do vi phạm chính sách bảo mật.

+ Quản lý các tổ chức cấp phát chứng chỉ tin cậy (Trusted CAs).

+ Trusted CAs: Hiển thị danh sách các chứng chỉ Root CA được hệ thống tin cậy.

+ Fortinet_CA1_Root: Chứng chỉ gốc của Fortinet hiện đang ở trạng thái Active, đóng vai trò làm nền tảng để xác thực tính hợp lệ của các thiết bị thực thi chính sách và các chứng chỉ người dùng cuối trong hệ sinh thái.



Giao diện quản lý nhật ký truy cập (Log Access)

Thiết bị FortiAuthenticator không hoàn toàn giống một hệ thống Windows Server thông thường mà là một giải pháp thiết bị phần cứng/ảo hóa chuyên dụng, được xây dựng chuyên biệt để vận hành cơ sở dữ liệu tài khoản và chạy các dịch vụ xác thực tập trung như RADIUS, LDAP, TACACS+.

Lợi thế của thiết bị này bao gồm:

Tích hợp các tính năng bảo mật nâng cao: Ngoài các dịch vụ xác thực cơ bản, FortiAuthenticator còn hỗ trợ thêm các tính năng tiên tiến như xác thực 2 bước (Two-Factor Authentication - 2FA), quản lý các chính sách mật khẩu (Password), hệ thống cảnh báo, và hỗ trợ cho phép người dùng tự thay đổi mật khẩu

Quản lý đăng nhập minh bạch: Thiết bị cung cấp tính năng Fortinet SSO Methods, là tập hợp các phương pháp giúp xác thực người dùng một cách minh bạch (Single Sign-On) với các thiết bị FortiGate

Khả năng liên kết hệ thống linh hoạt: Là một giải pháp hỗ trợ xác thực tập trung, FortiAuthenticator cho phép kết nối dễ dàng tới các thiết bị bảo mật, thiết bị mạng khác trong hệ thống (như VPN, Tường lửa, hệ thống Portal truy cập Wireless) để kiểm soát quyền truy cập của toàn bộ người dùng

Số lượng User (Người dùng): Hỗ trợ tối đa 500 người dùng (bao gồm tổng cả tài khoản Local và Remote).

Số lượng User Group (Nhóm người dùng): Hỗ trợ tối đa 50 nhóm.

Kết quả:

Lab 1 đã hoàn thành thành công việc tiếp cận và khám phá toàn diện giao diện quản trị web của FortiAuthenticator 200E. Dashboard hiển thị chính xác thông tin định danh thiết bị (Hostname: FAC-HCMUTE, Firmware: v6.2.1) và trạng thái tài nguyên (49/500 người dùng, 16/50 nhóm). Các cổng mạng Port1 (192.168.1.236) và Port2 (172.16.4.249) hoạt động đúng chức năng phân công. Cấu trúc cây thư mục LDAP với gốc dc=hcmute,dc=com và các dịch vụ FSSO đã được xác nhận chạy ổn định.

Đánh giá:

Giao diện quản trị của FortiAuthenticator 200E được thiết kế trực quan, cho phép quản trị viên nắm bắt nhanh trạng thái tổng thể qua Dashboard tập trung. Việc hiển thị đồng thời User Inventory, Authentication Activity và System Information trên một màn hình là điểm mạnh vận hành, giúp rút ngắn thời gian xử lý sự cố. Tuy nhiên, số lượng tùy chọn cấu hình lớn đòi hỏi người quản trị cần có nền tảng vững về AAA, LDAP, RADIUS để khai thác hiệu quả. Lab 1 cung cấp nền tảng quan trọng giúp nhóm định hướng cho các bài thực hành tiếp theo.

3.2. Lab 2: Thực hành các tính năng LDAP

Mục tiêu: LDAP là một trong những dịch vụ phổ biến nhất hỗ trợ các cơ chế xác thực tập trung trong hệ thống, giúp hiểu rõ hơn về LDAP cũng như các cấu hình trên FortiAuthenticator cho tính năng này.

Truy cập Authentication > User Management > Local User. Nhấn Create New để tạo các người dùng trên FortiAuthenticator. Cấu hình các thông số sau:

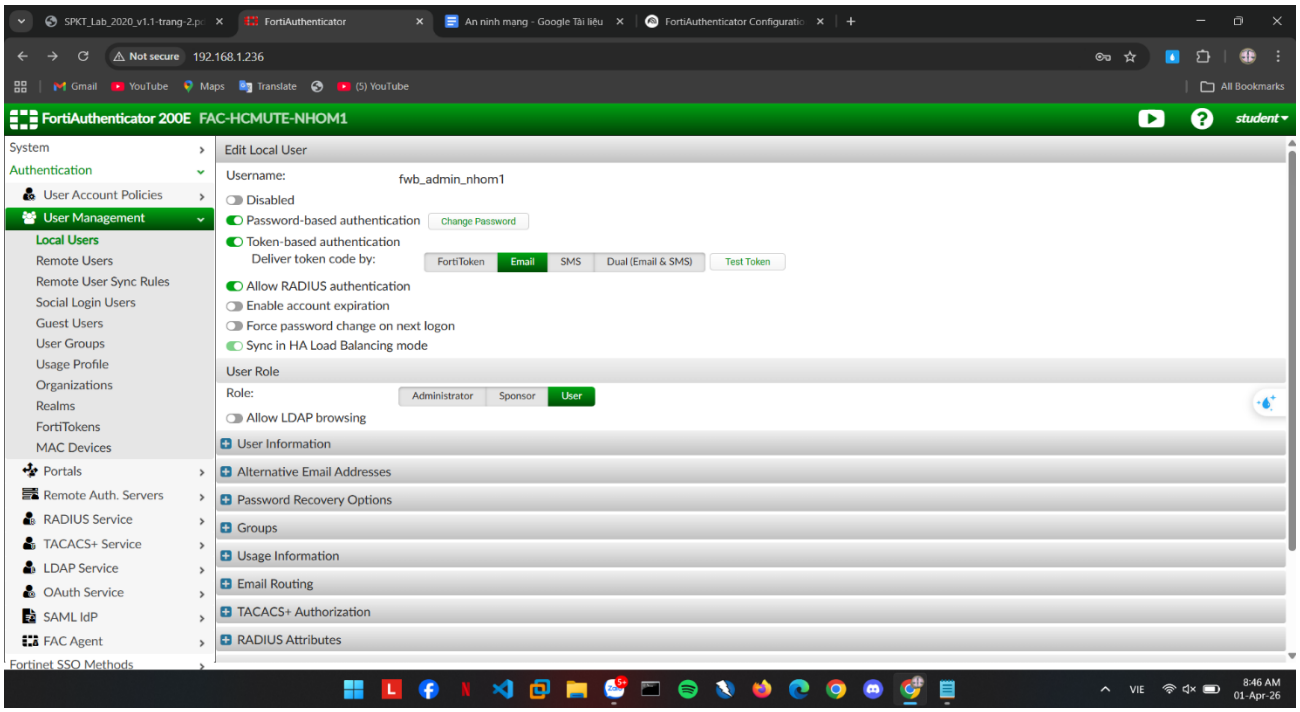
Username: fwb_admin_nhom1

Password: nhom1@123

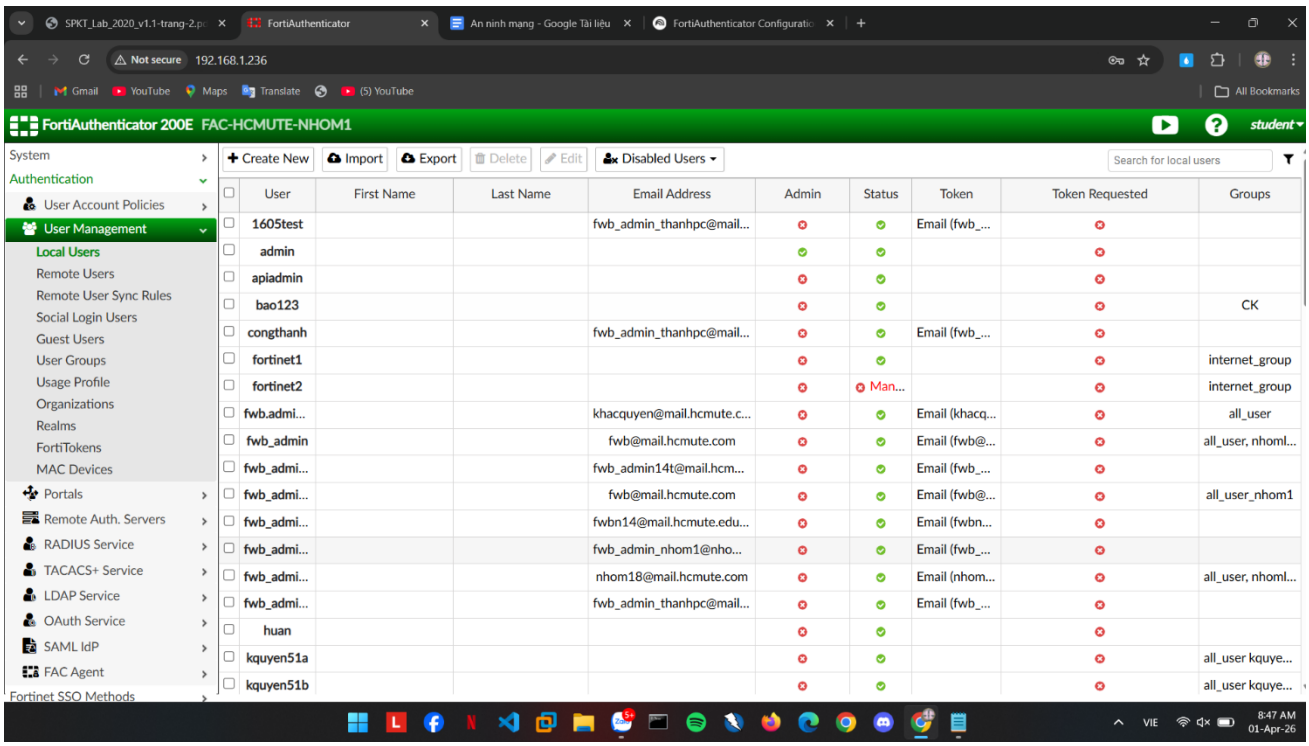
Pasword confirmation: nhom1@123

Role: User

Sau đó, Nhấn OK để hiển thị các cấu hình nâng cao cho người dùng.



Chúng ta sẽ được bảng thông tin người dùng như sau:

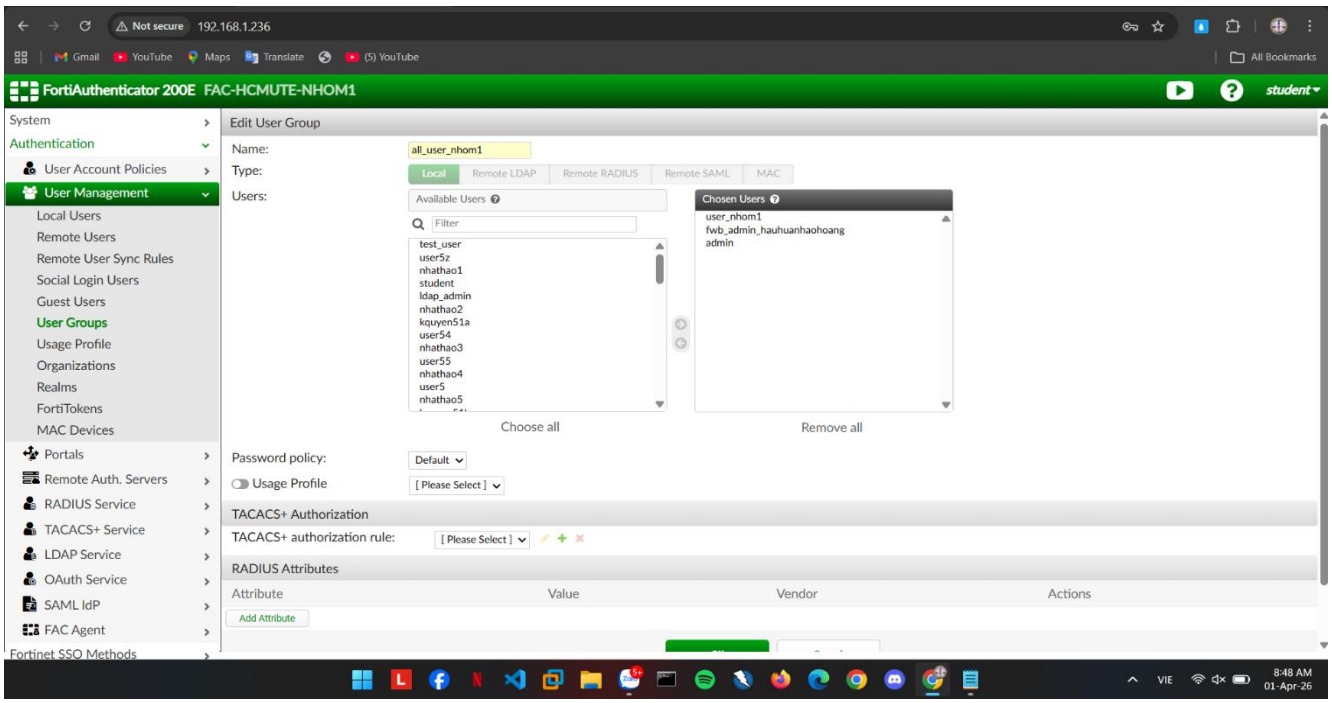


Truy cập Authentication > User Management > User Groups.

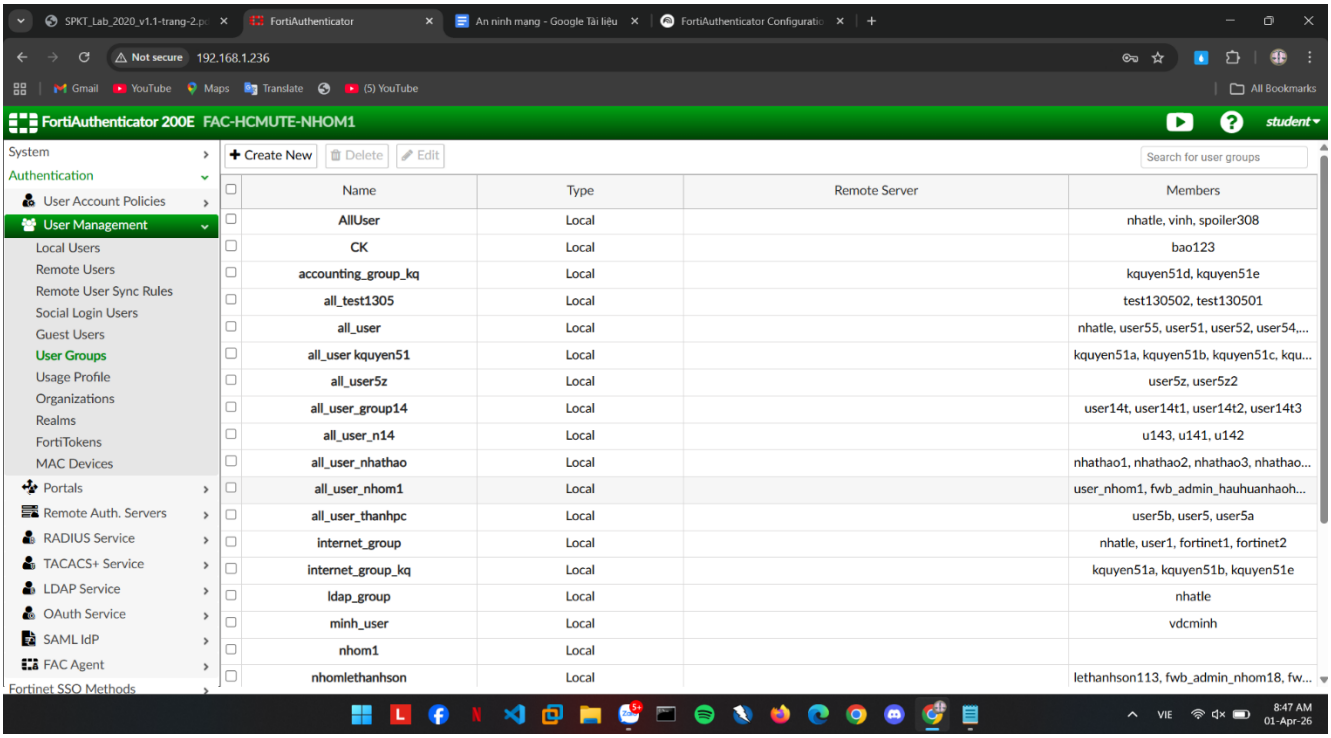
Nhấn Create New để tạo nhóm người dùng. Cấu hình các thông số sau:

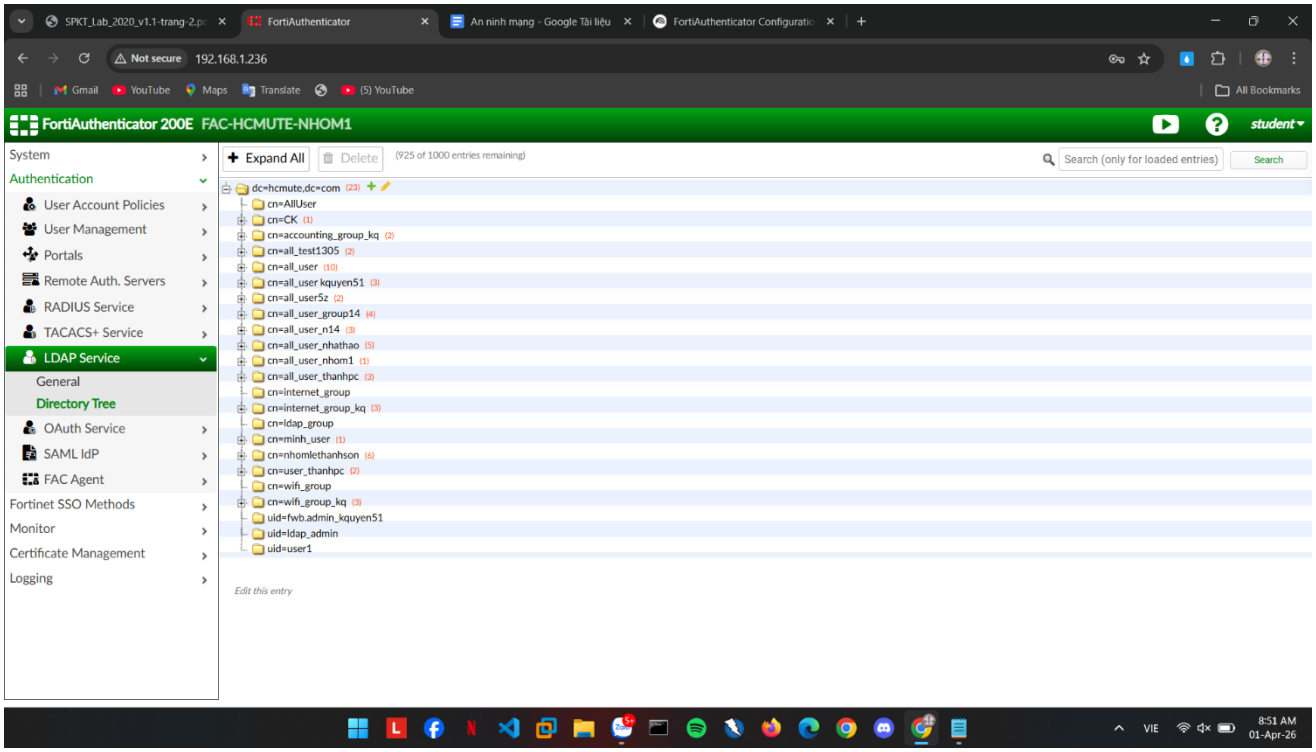
Name: all_user_nhom1

Type: Local Chọn các người dùng qua mục Seleted Users.



Nhấn OK.


FortiAuthenticator
192.168.1.236
FortiAuthenticator 200E FAC-HCMUTE-NHOM1
student
System
Authentication
User Account Policies
User Management
Local Users
Remote Users
Remote User Sync Rules
Social Login Users
Guest Users
User Groups
Usage Profile
Organizations
Realms
FortiTokens
MAC Devices
Portals
Remote Auth. Servers
RADIUS Service
TACACS+ Service
LDAP Service
OAuth Service
SAML IdP
FAC Agent
Fortinet SSO Methods
+ Create New
Delete
Edit
Search for user groups
Name
Type
Remote Server
Members
AllUser Local nhatle, vinh, spoiler308
CK Local bao123
accounting_group_kq Local kquyen51d, kquyen51e
all_test1305 Local test130502, test130501
all_user Local nhatle, user55, user51, user52, user54,...
all_user kquyen51 Local kquyen51a, kquyen51b, kquyen51c, kqu...
all_user5z Local user5z, user5z2
all_user_group14 Local user14t, user14t1, user14t2, user14t3
all_user_n14 Local u143, u141, u142
all_user_nhathao Local nhathao1, nhathao2, nhathao3, nhathao...
all_user_nhom1 Local user_nhom1, fwb_admin_hauhuanhaoh...
all_user_thanhpc Local user5b, user5, user5a
internet_group Local nhatle, user1, fortinet1, fortinet2
internet_group_kq Local kquyen51a, kquyen51b, kquyen51e
ldap_group Local nhatle
minh_user Local vdcminh
nhom1 Local
nhomlethanhson Local lethanhson113, fwb_admin_nhom18, fw...
8:47 AM
01-Apr-26



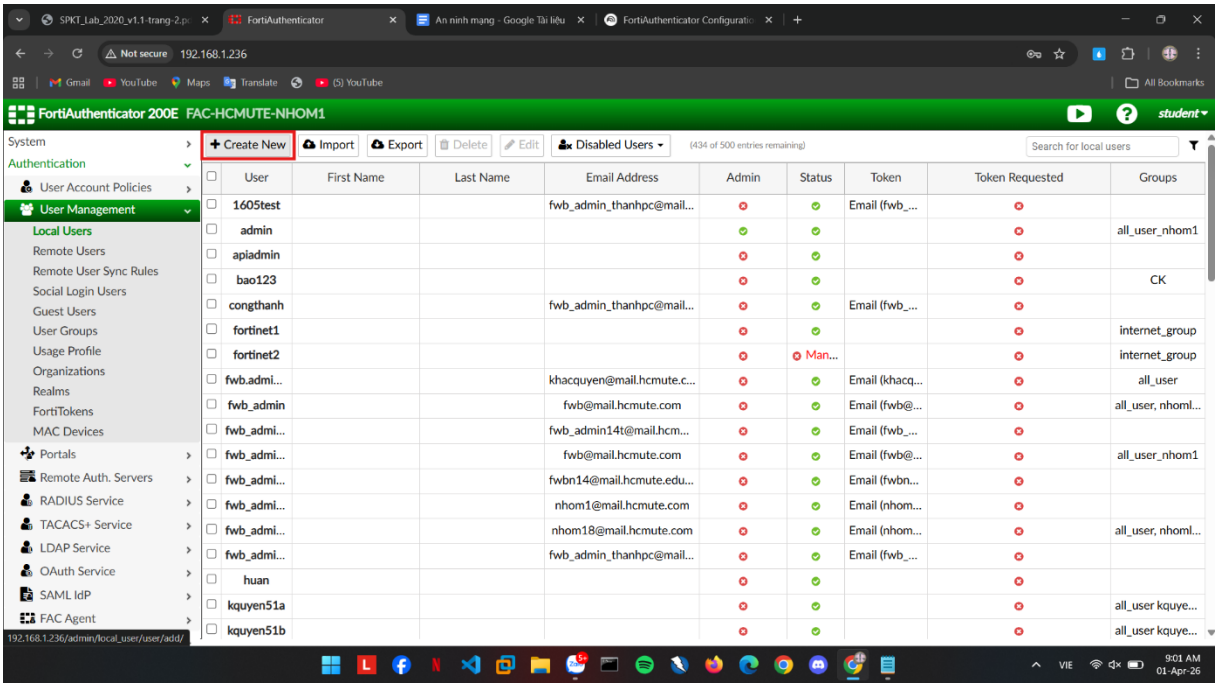
Nếu muốn tạo một Directory Tree mới ta có thể tạo thêm các nhánh mới để mở rộng cấu trúc Directory Tree trên thiết bị FortiAuthenticator.

Cụ thể, thông qua dịch vụ LDAP Service, từ thư mục gốc ban đầu (ví dụ: dc=hcmute,dc=com), quản trị viên có thể click vào biểu tượng dấu + để liên tục thêm mới các cấu trúc phân cấp (Class) như Nhóm người dùng (User Group) hay Người dùng cục bộ (Local User) vào trong cây thư mục này.

Để có thể mở rộng Directory Tree với các user mới ta thực hiện 3 bước sau:

Bước 1: Tạo tài khoản người dùng mới (Local User)

Truy cập vào mục Authentication > User Management > Local Users và Nhấn Create



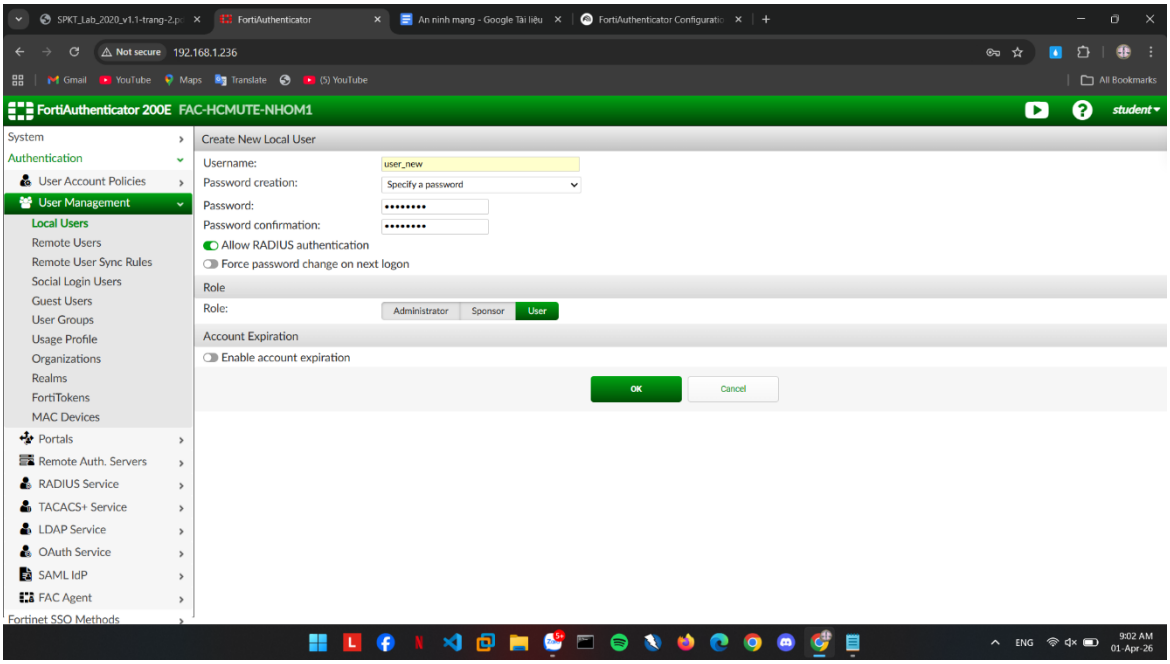
New

Cấu hình các thông số tài khoản:

Username: user_new

Password & Password confirmation: user@123

Role: Chọn User. Nhấn OK để mở ra các tùy chọn nâng cao (nếu cần cấu hình thêm) và hoàn tất lưu thông tin.



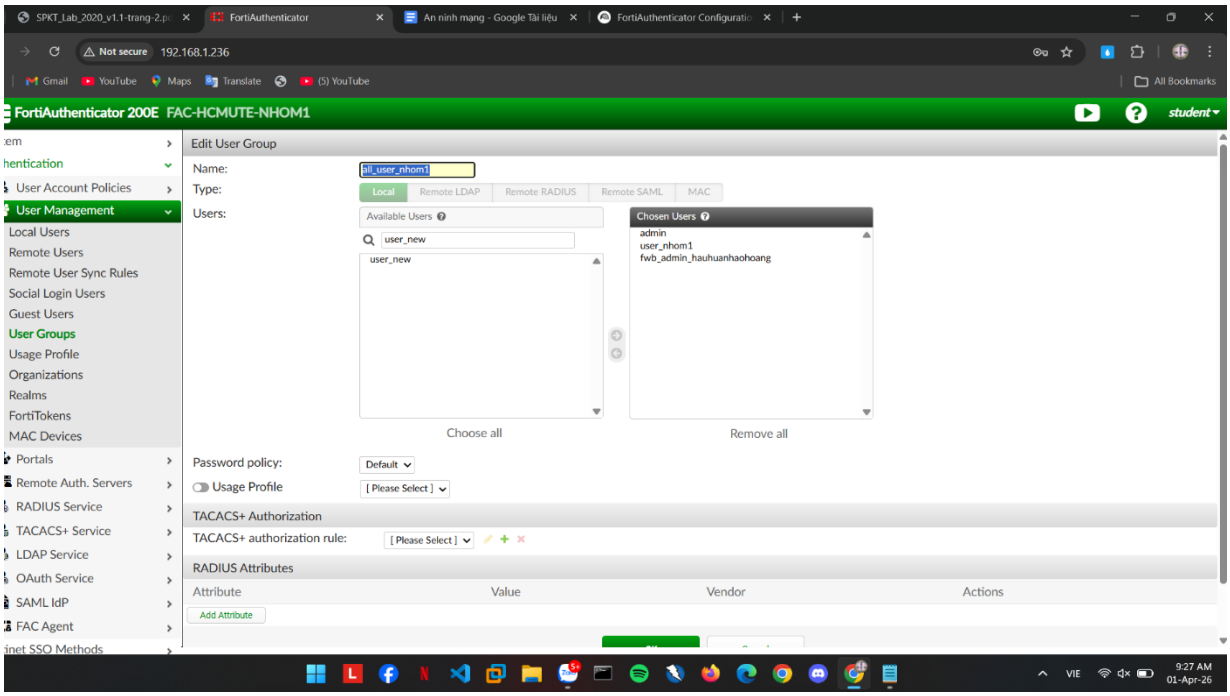
Bước 2: Tạo Nhóm người dùng và đưa user mới vào nhóm

Truy cập vào mục Authentication > User Management > User Groups

Cấu hình thông số nhóm:

Name: all_user_nhom1

Thêm user_new vào Chosen User



Bước 3: Mở rộng Directory Tree với tài khoản user mới

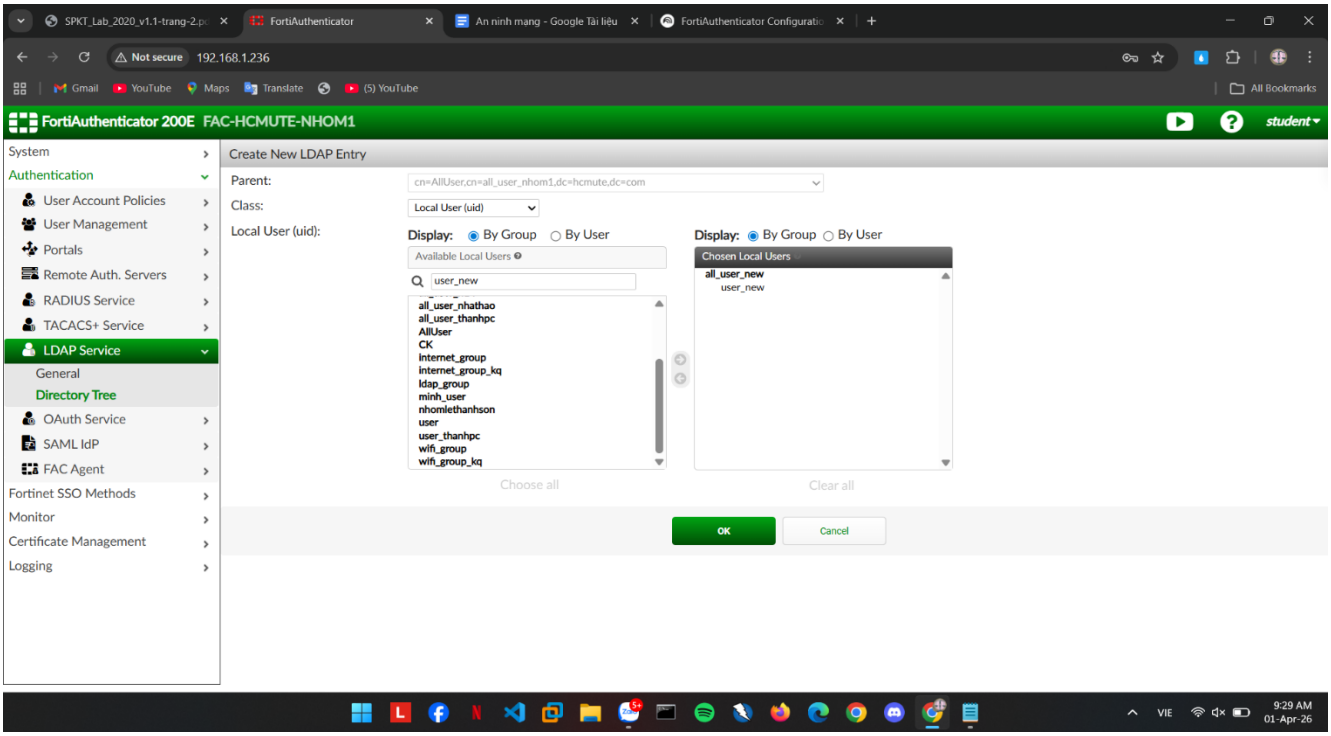
Lúc này trên cây thư mục đã xuất hiện nhánh mới là cn=all_user. Tiếp tục Nhấn vào dấu + ngay tại mục cn=all_user_nhom1 này.

Trong hộp thoại cấu hình, thiết lập:

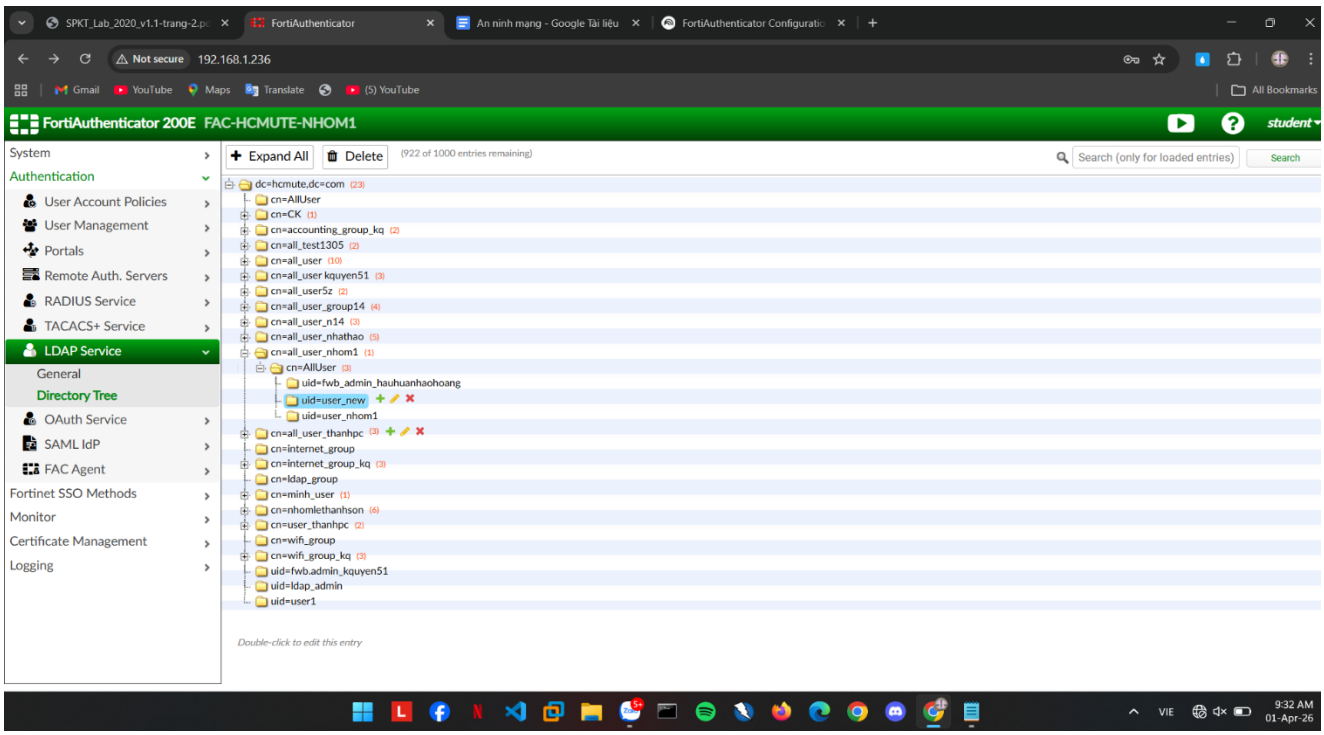
Class: Chọn Local User (uid)

Tại mục Display: By User, hãy tick chọn người dùng user_ (và các user cùng nhóm) để đưa vào danh sách Chosen Local Users.

Nhấn OK



Sau khi hoàn tất, cấu trúc Directory Tree của ta đã được mở rộng thành công, hiển thị rõ nhánh cn=all_user chứa các tài khoản con như uid=user_new bên trong, và hệ thống đã sẵn sàng để sử dụng dịch vụ xác thực LDAP.



Kết quả:

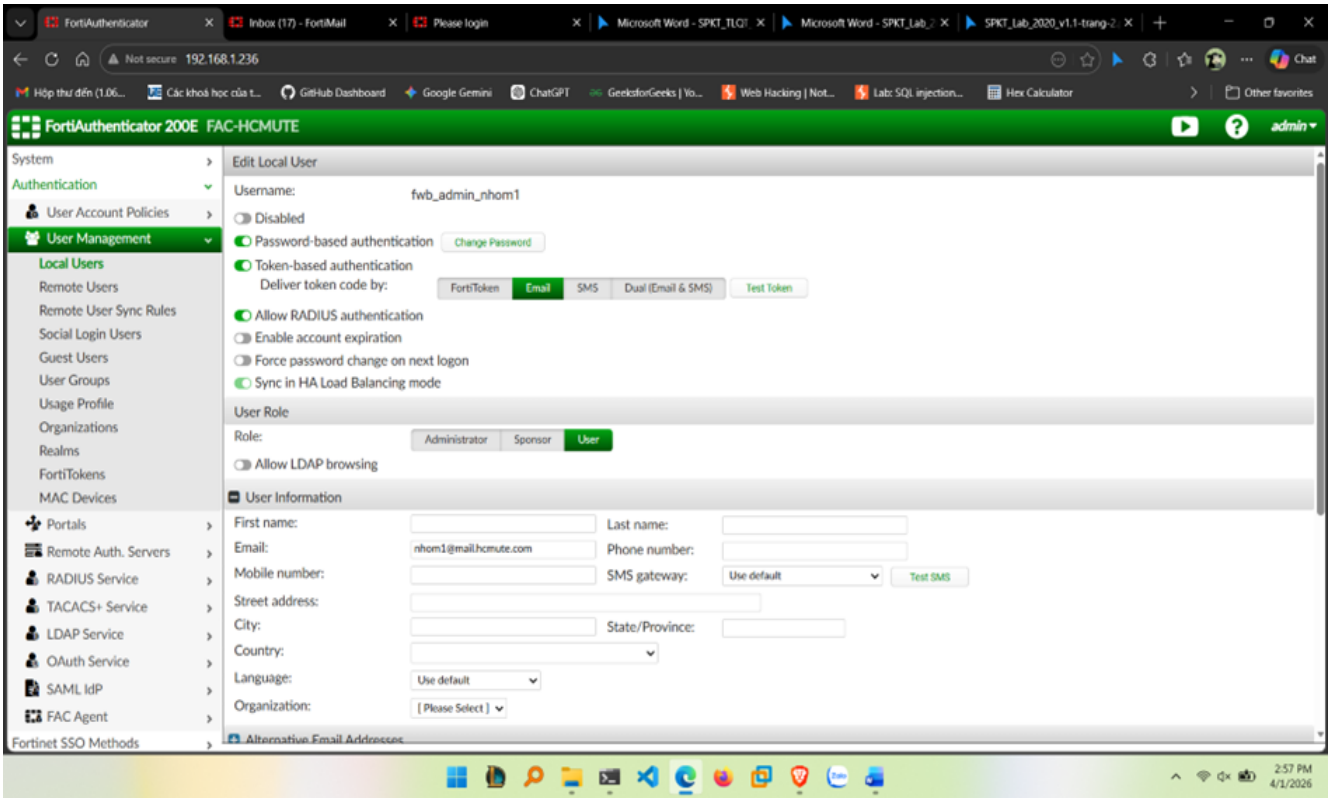
Lab 2 đã triển khai thành công các chức năng cốt lõi của dịch vụ LDAP. Tài khoản fwb_admin_nhom1 được tạo và gán vào nhóm all_user_nhom1 đúng yêu cầu. Cấu trúc Directory Tree được mở rộng từ gốc dc=hcmute,dc=com, bổ sung nhánh cn=all_user_nhom1 chứa tài khoản uid=user_new bên trong. Dịch vụ LDAP Service phản ánh chính xác cấu trúc phân cấp sau cấu hình, xác nhận đồng bộ hóa ngay lập tức. Hệ thống đã sẵn sàng để các ứng dụng bên ngoài thực hiện truy vấn LDAP đến FortiAuthenticator.

Đánh giá:

FortiAuthenticator 200E thể hiện khả năng hoạt động như một máy chủ thư mục LDAP độc lập hiệu quả. Việc tích hợp trực tiếp quản lý người dùng với LDAP Service tạo luồng cấu hình liền mạch: quản trị viên chỉ tạo đối tượng một lần rồi ánh xạ vào cây thư mục mà không cần cấu hình lại trên hệ thống thứ hai. Mô hình này phù hợp với tổ chức chưa có hạ tầng Active Directory. Giới hạn 500 người dùng và 50 nhóm cho thấy thiết bị được thiết kế cho doanh nghiệp vừa và nhỏ, không phù hợp với tổ chức lớn có hàng nghìn tài khoản.

3.3. Lab 3: Thực hành các tính năng xác thực 2 bước

Truy cập Authentication > User Management > Local Users. Nhấn Create New để tạo một người dùng mới. Username: fwb_admin_nhom1 Password: nhom1@123 sau đó Nhấn OK, để hiện thị các tùy chỉnh nâng cao cho người dùng. Bật Token-based authentication. Deliver token code by: Email Nhập thông tin email của người dùng: nhom1@mail.hcmute.com



Truy cập System > Messaging > SMTP Servers.

Nhấn Create New, cấu hình các thông tin sau:

Name: Mail-Server-Nhom1

Server name/IP: mail.hcmute.com

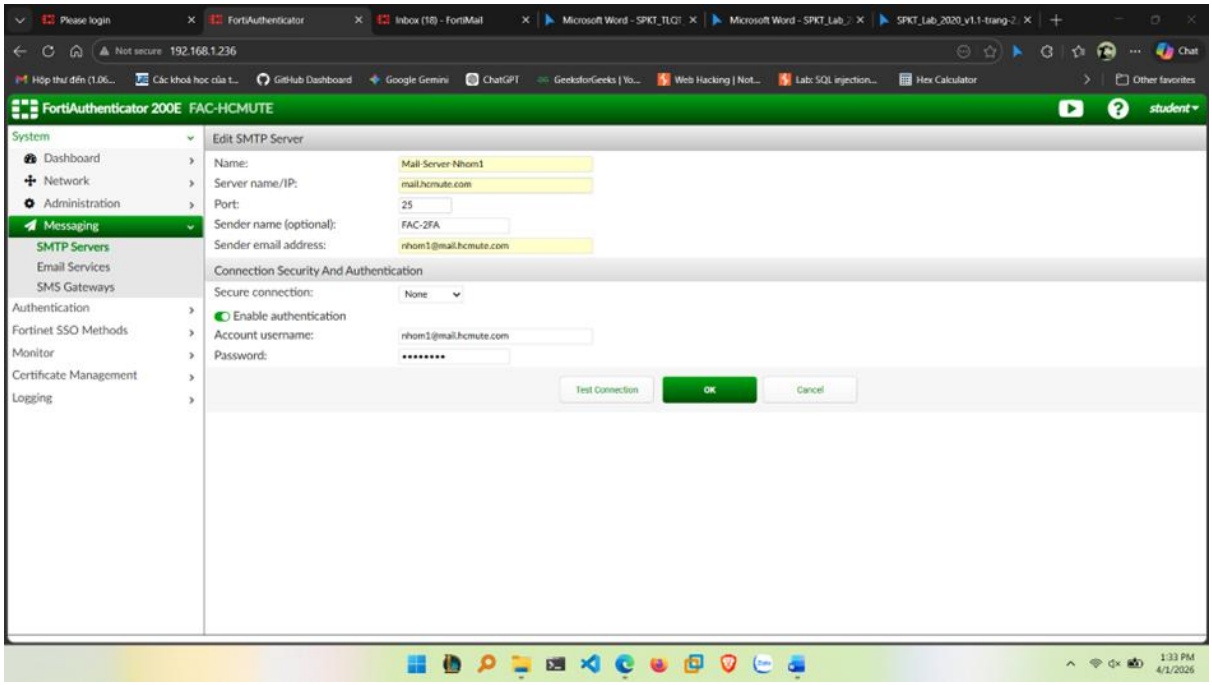
Port: 25 Sender name: FAC-2FA

Sender email address: nhom1@mail.hcmute.com

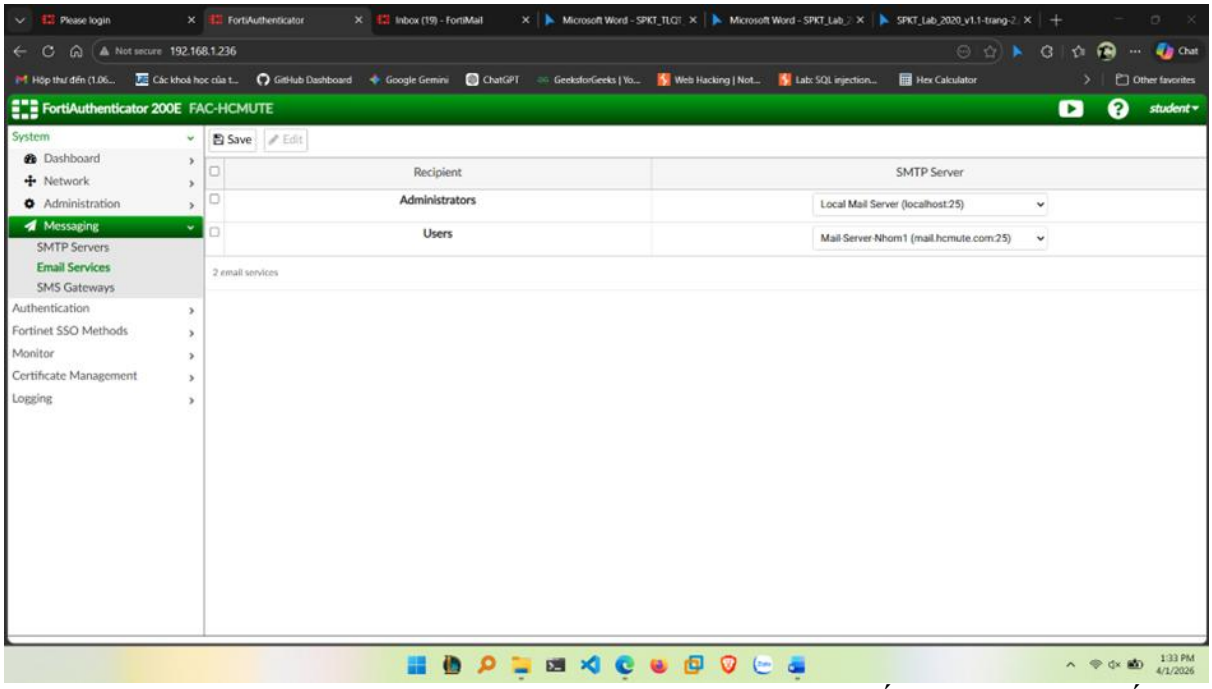
Kích hoạt Enable authentication

Account username: nhom1@mail.hcmute.com

Password: nhom1@123



Nhấn OK. Truy cập System > Messaging > Email Services. Chọn SMTP Server cho Users là Mail-Server-Nhom1 - (mail.hcmute.com:25)

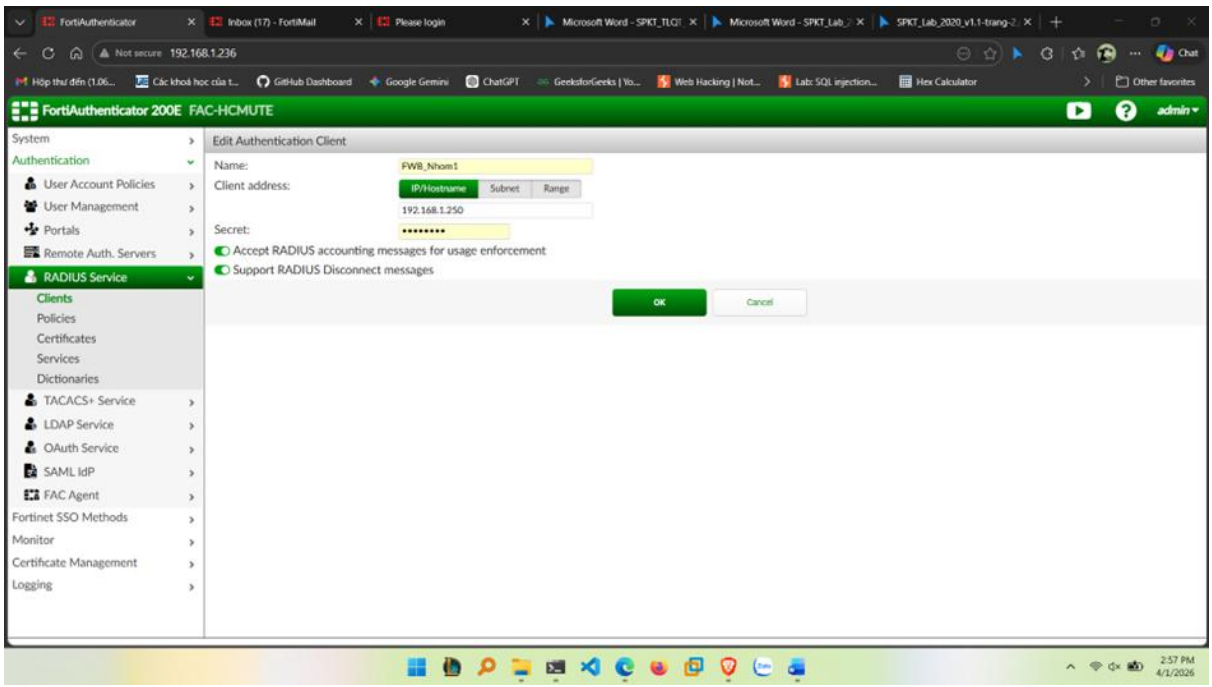


Truy cập Authentication > RADIUS Service > Clients, Nhấn Create New. Cấu hình các thông tin sau:

Name: FWB_Nhom1

Client address: IP/Hostname 192.168.1.250

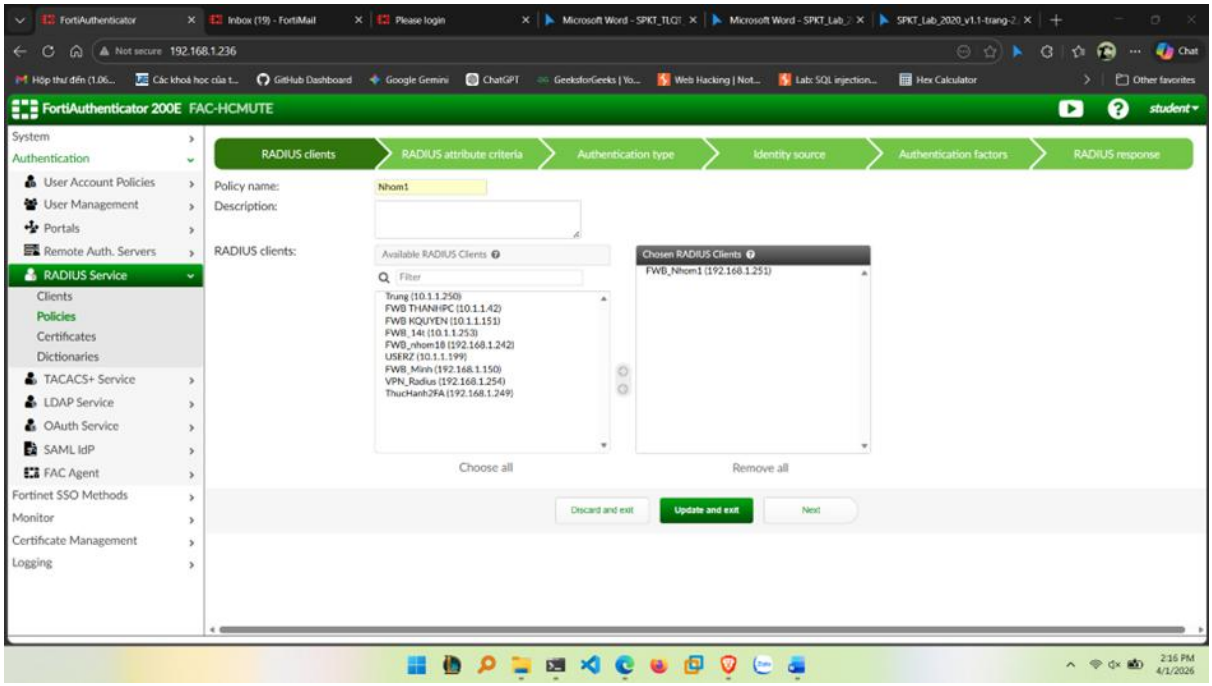
Secret: nhom1@123



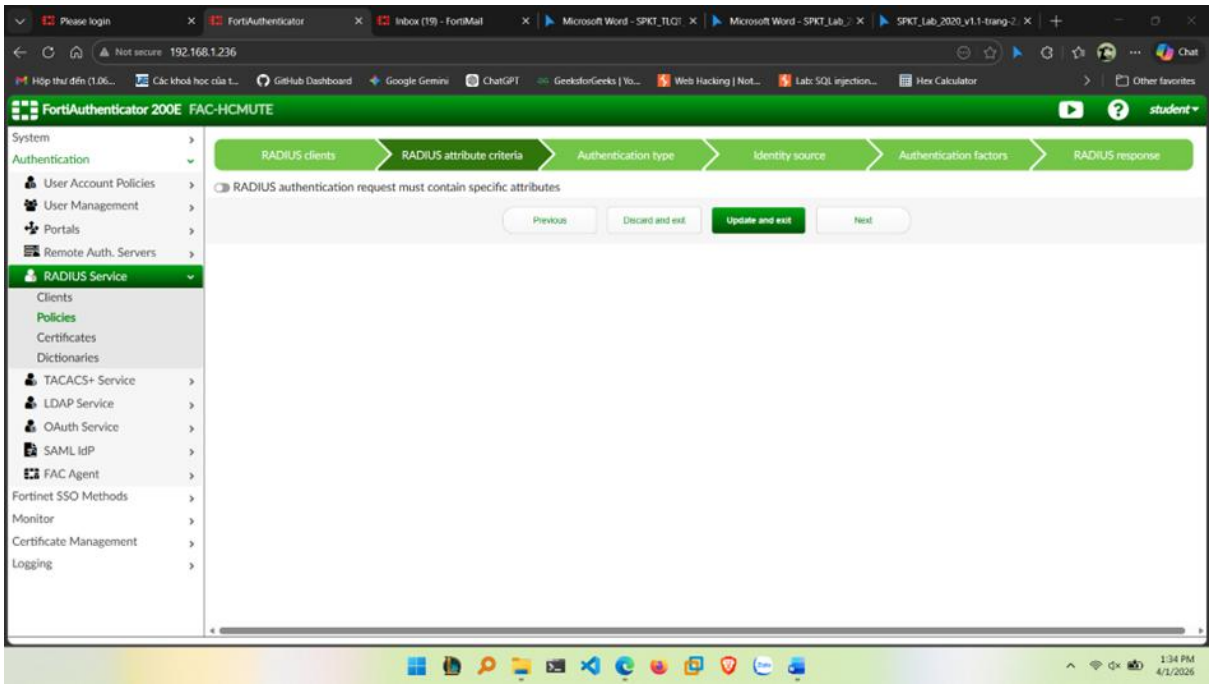
Nhấn OK. Truy cập Authentication > RADIUS Service > Policies, Nhấn Create New.

Policy name: Nhom1

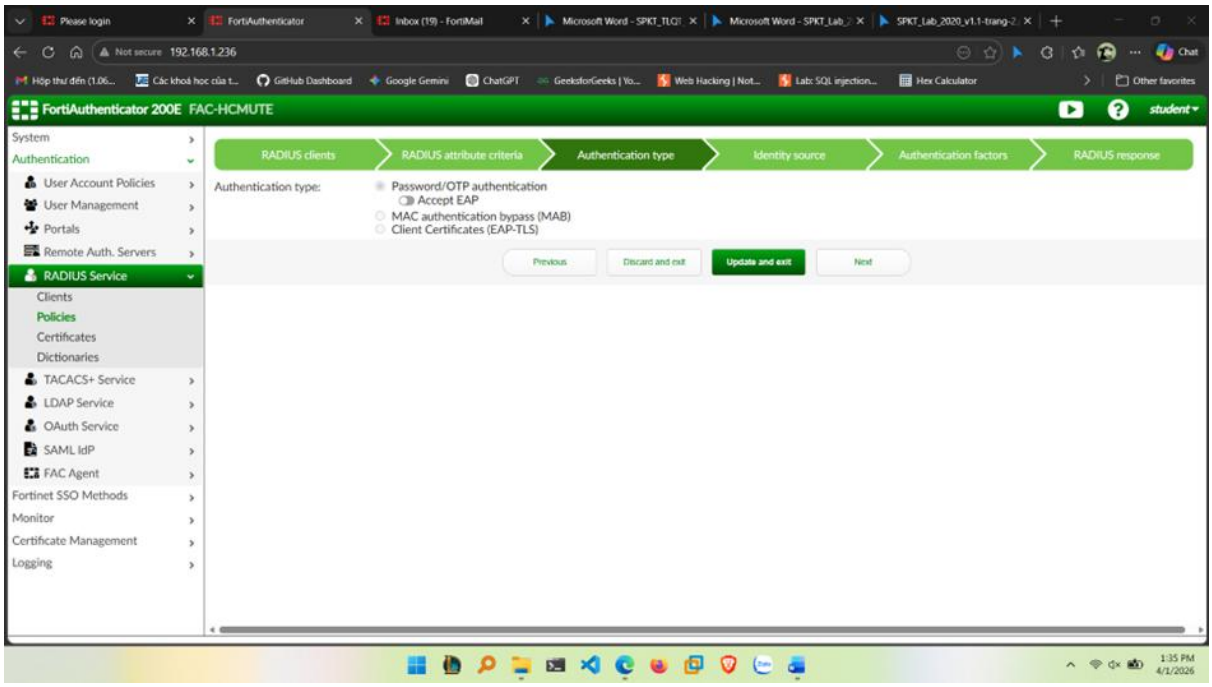
Chọn RADIUS Client vừa tạo: FWB _Nhom1



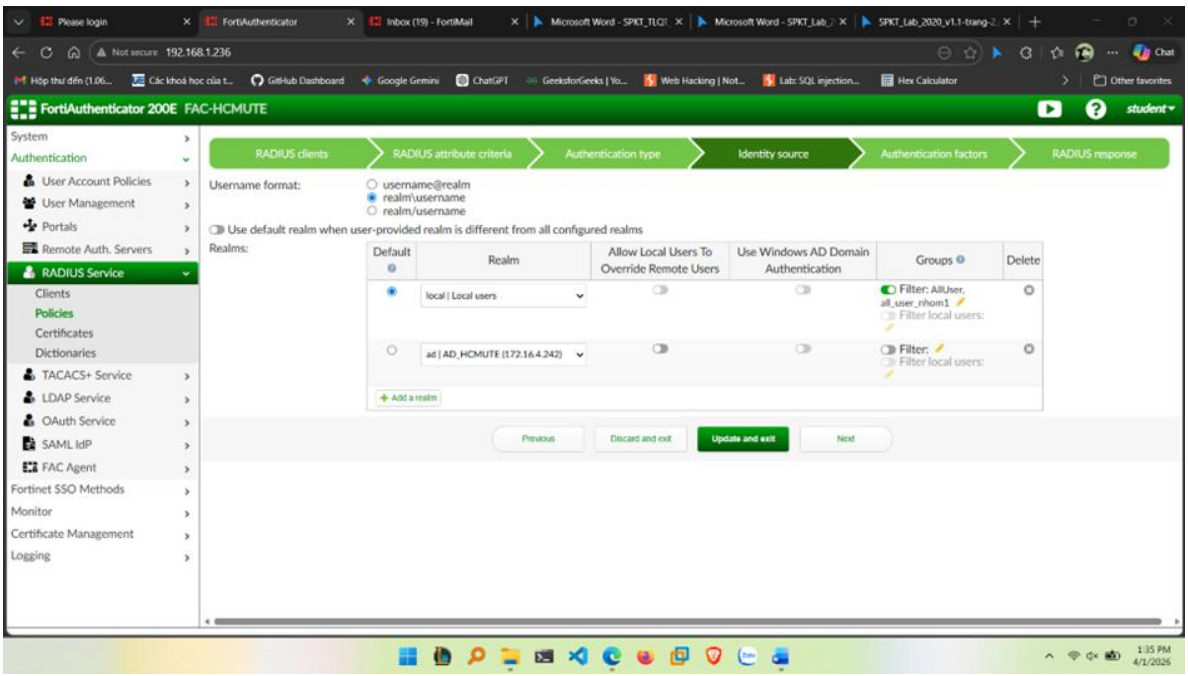
Nhấn Next. Để mặc định.



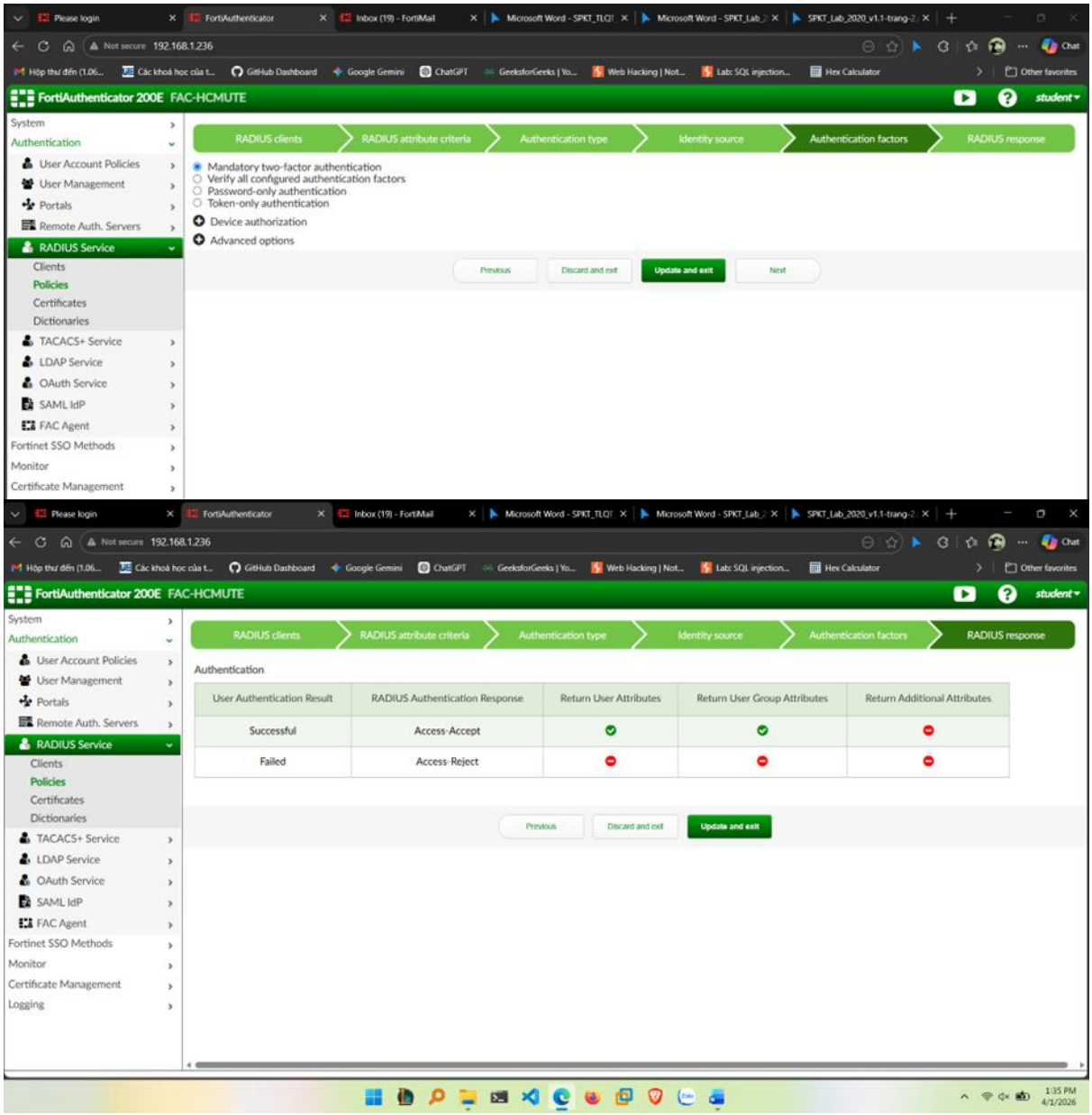
Nhấn Next. Chọn Password/OTP authentication.



Nhấn Next. Chọn Username format: realm\username Ở mục Realm, chọn local | Local users.



Nhấn Next. Chọn Mandatory two-factor authentication



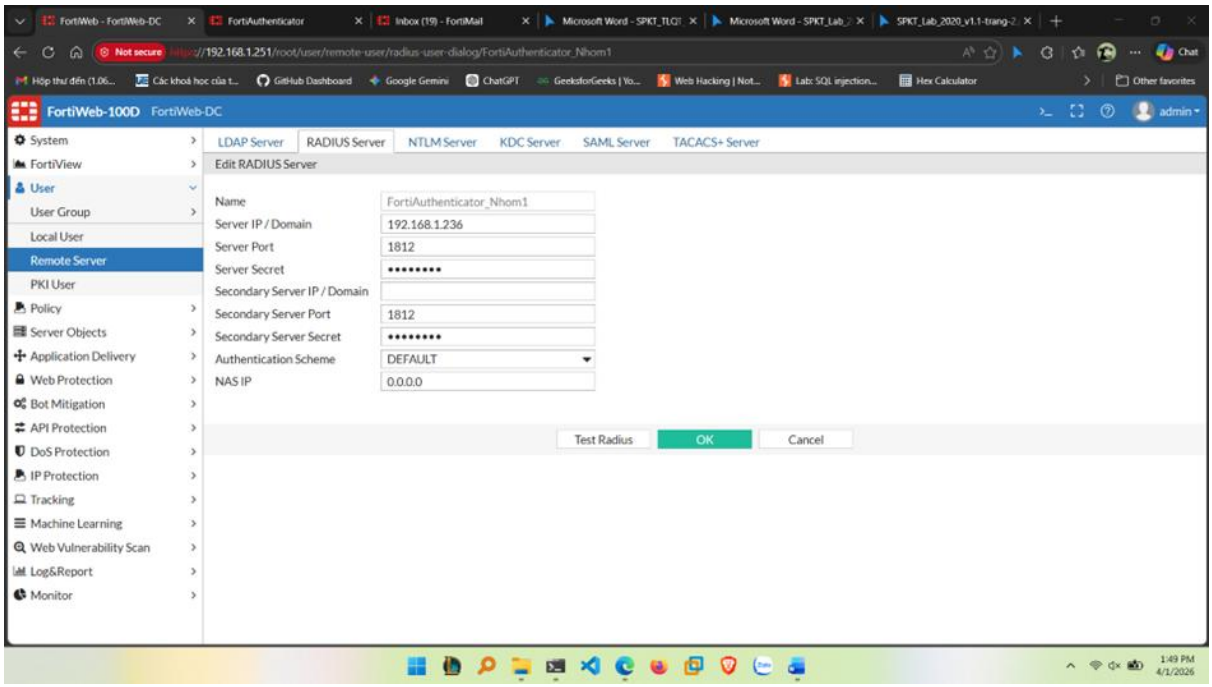
Nhấn Save and Exit.

Truy cập FortiWeb, User > Remote User > Radius Server. Nhấn Create New. Cấu hình các thông tin sau:

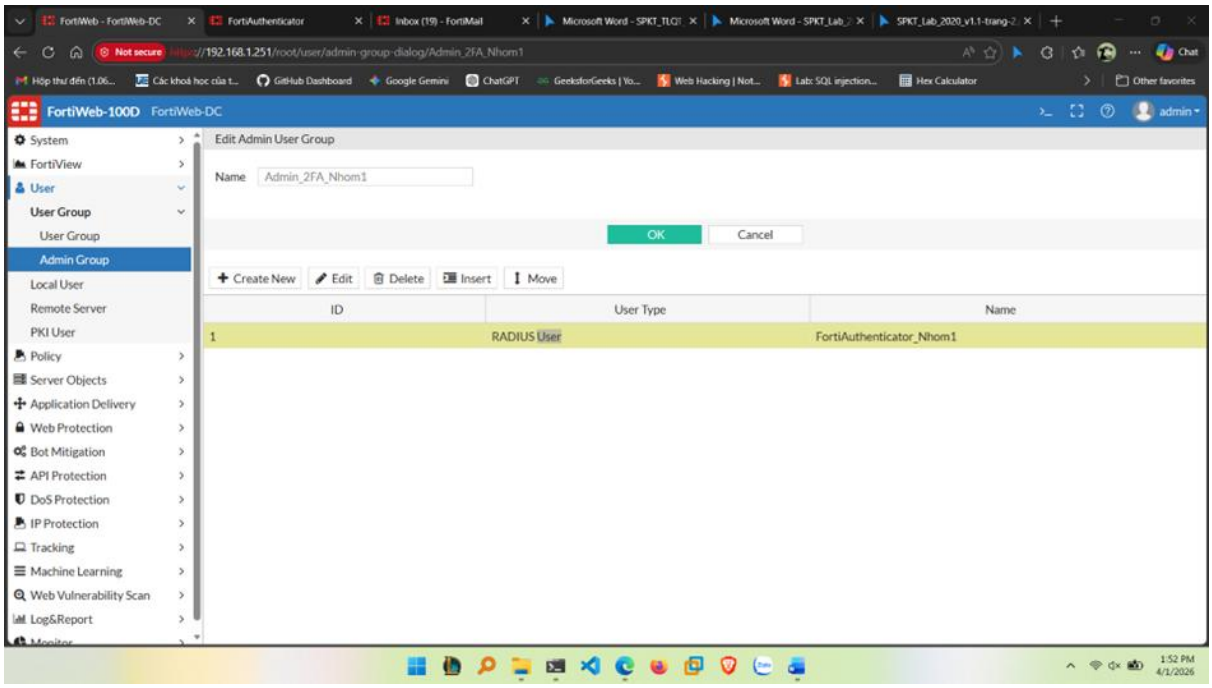
Name: FortiAuthenticator _Nhom1Server Ip / Domain: 192.168.1.236

Server Port: 1812

Server Secret: nhom1@123



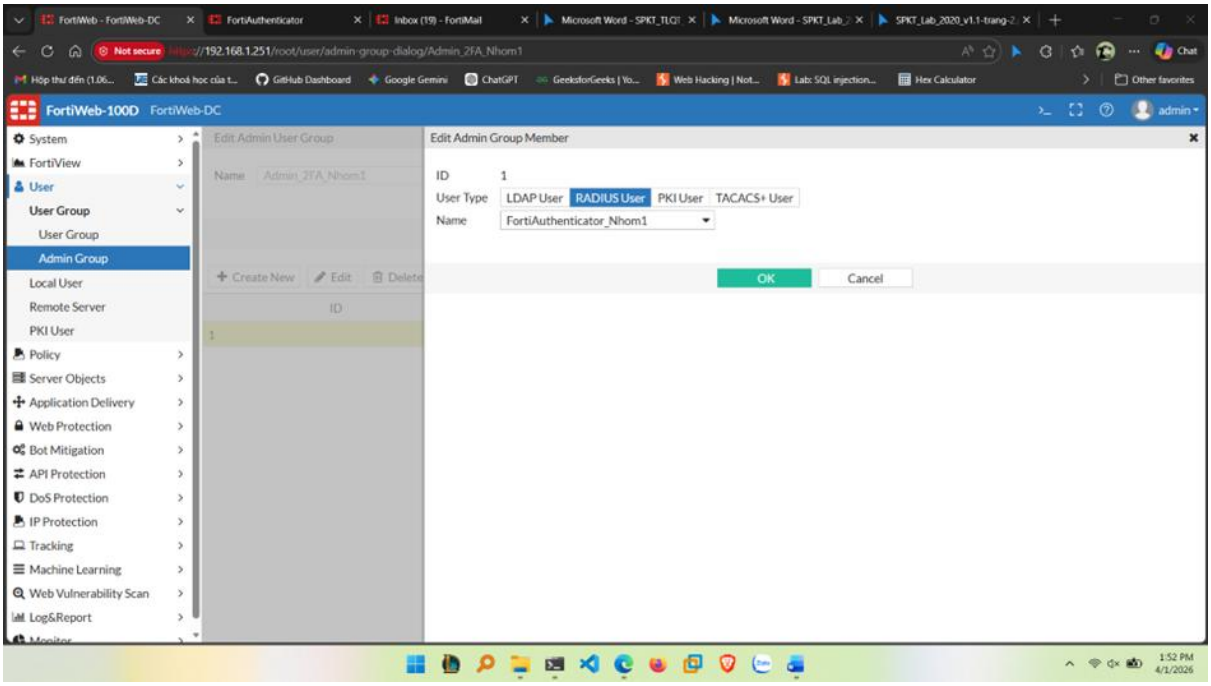
Nhấn OK. Truy cập User > User Group > Admin Group. Nhấn Create New. Đặt tên cho nhóm: Admin_2FA_Nhom1 Nhấn OK.



Nhấn Create New. Cấu hình các thông số sau:

User Type: RADIUS

User Name: FortiAuthenticator_Nhom1



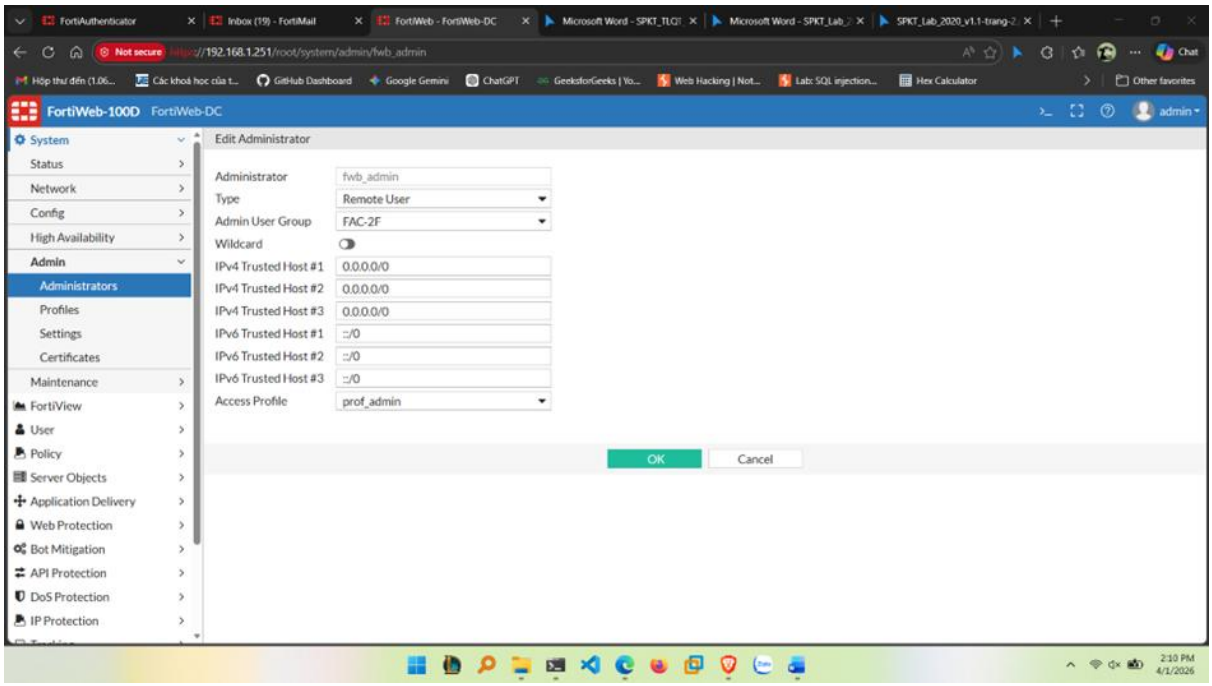
Nhấn OK. Truy cập System > Admin > Administrators. Nhấn Create New để tạo người quản trị mới.

Administrator: fwb_admin

Type: Remote User Admin User

Group: FAC-2F

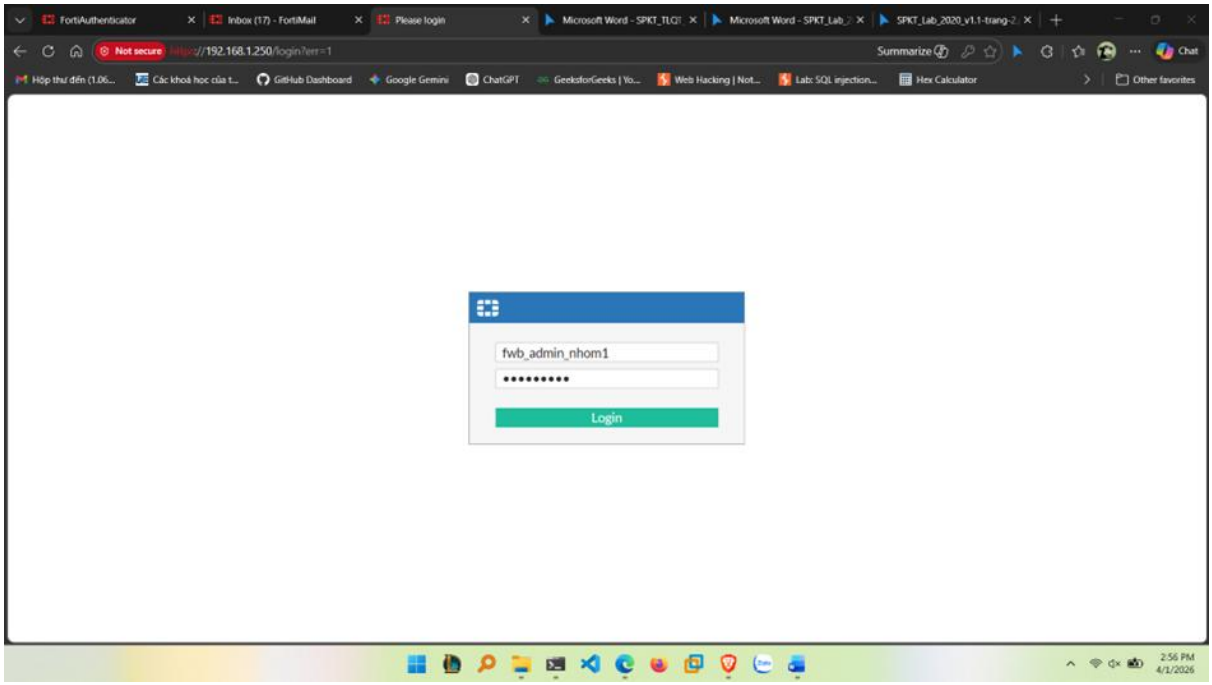
Access Profile: prof_admin

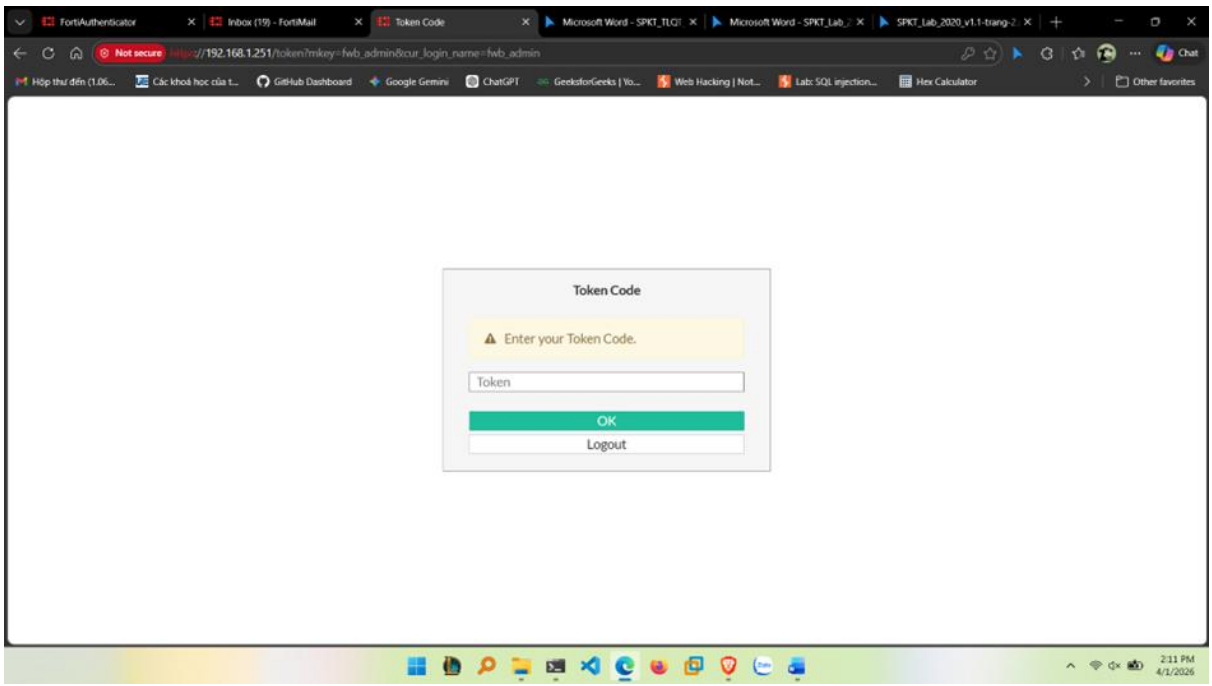


Nhấn OK.

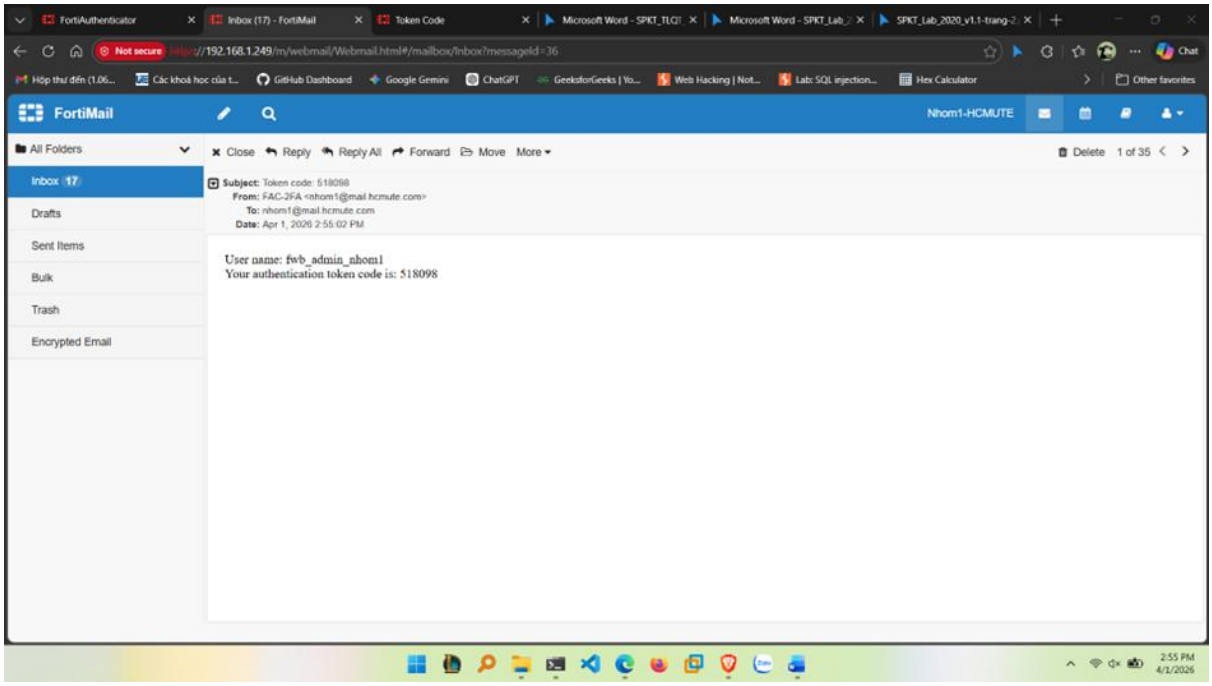
Bây giờ thử đăng nhập lại FortiWeb bằng tài khoản được tạo trên FortiAuthenticator: fwb_admin_nhom1/nhom1@123 Một mã code token sẽ được gửi về mail:

nhom1@mail.hcmute.com

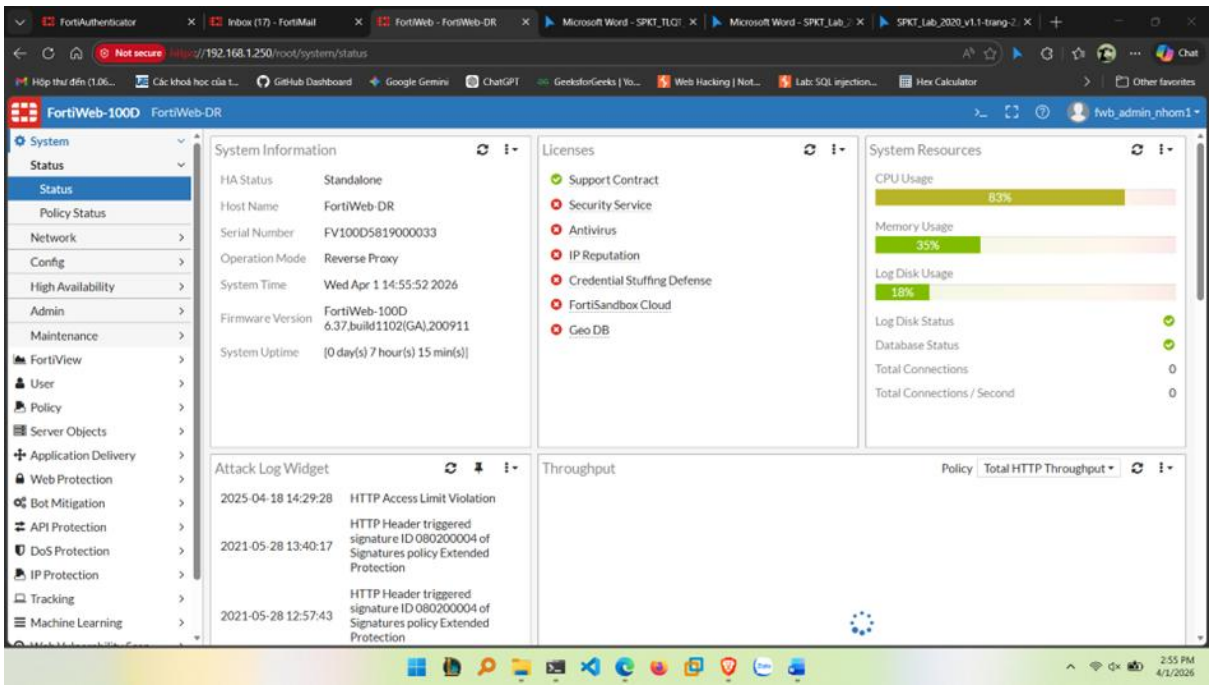




Kiểm tra FortiMail để lấy tokenCode:



Bạn sẽ đăng nhập được vào giao diện quản lý của FortiWeb với tài khoản fwb_admin_nhom1:



Ngoài khả năng gửi mã xác thực qua Email, FortiAuthenticator còn hỗ trợ cấu hình gửi mã 2FA thông qua các phương thức sau:

Qua tin nhắn SMS: Gửi trực tiếp chuỗi xác thực đến số điện thoại của người dùng.

Qua thiết bị FortiToken: Sử dụng ứng dụng sinh mã trên điện thoại di động (Apps Mobile - FortiToken Mobile) hoặc thiết bị vật lý nhỏ gọn (Token cứng - FortiToken Hardware).

Dual (Kết hợp cả Email & SMS): Tùy chọn này cho phép hệ thống gửi mã xác thực đồng thời qua cả hai kênh Email và SMS để đảm bảo người dùng chắc chắn nhận được.

Yêu cầu để có thể sử dụng các thành phần này:

Đối với gửi qua SMS hoặc Dual: Hệ thống bắt buộc phải được kết nối và khai báo với một hệ thống cổng dịch vụ tin nhắn (SMS Gateways) thông qua đường dẫn System > Messaging > SMS Gateways.

Ngoài ra, trong thông tin tài khoản người dùng cũng phải được cập nhật số điện thoại (Mobile number) hợp lệ.

Đối với sử dụng FortiToken: Doanh nghiệp bắt buộc phải trang bị các thiết bị FortiToken phần cứng hoặc phải mua các bản quyền (License) phân bổ cho ứng dụng FortiToken Mobile (Như trên giao diện Dashboard quản trị, FortiAuthenticator cần kiểm tra kho lưu trữ "User Inventory" để đảm bảo số lượng FortiToken đang còn khả dụng (Available) trước khi cấp phát cho người dùng).

Để tạo ra chuỗi xác thực 2 bước (Token Code): Tính năng 2FA hoạt động dựa trên cơ chế: Hệ thống FortiAuthenticator tự động sinh ra một "chuỗi kí tự 6 chữ số ngẫu nhiên", chuỗi này sẽ thay đổi liên tục và được đẩy về cho người dùng (qua mail, sms, app) để làm lớp mật khẩu thứ hai.

Tạo lớp bảo mật thứ 2 bằng mã OTP 6 số, thay đổi liên tục theo 3 cơ chế sinh mã chính:

- TOTP (theo thời gian):

+ Dùng cho app FortiToken Mobile
+ Dựa trên Secret Key + thời gian hiện tại
+ Mã đổi mỗi từ 30–60 giây

- HOTP (theo bộ đếm):

+ Dùng cho Token cứng
+ Dựa trên Secret Key + Counter
+ Mỗi lần Nhấn -> sinh mã mới

- Email/SMS OTP:

+ Sinh bằng RNG (số ngẫu nhiên an toàn)
+ Gắn với session đăng nhập
+ Có thời gian sống ngắn (TTL)

Kết luận: Tất cả đều dựa trên Secret Key và thuật toán HMAC/RNG để đảm bảo mã chỉ dùng 1 lần và khó đoán.

Kết quả:

Lab 3 đã triển khai và kiểm chứng thành công luồng xác thực hai bước (2FA) qua Email cho tài khoản fwb_admin_nhom1 trên FortiWeb. Chuỗi cấu hình bao gồm: SMTP Server (mail.hcmute.com:25), RADIUS Client (FWB_Nhom1 tại 192.168.1.250), Policy RADIUS với Mandatory Two-Factor Authentication, và khai báo FortiAuthenticator làm RADIUS Server trên FortiWeb. Kết quả kiểm thử xác nhận: hệ thống từ chối truy cập sau khi nhập mật khẩu, sinh mã OTP 6 chữ số gửi đến nhom1@mail.hcmute.com, và chỉ cấp quyền vào FortiWeb sau khi người dùng nhập đúng token nhận từ FortiMail.

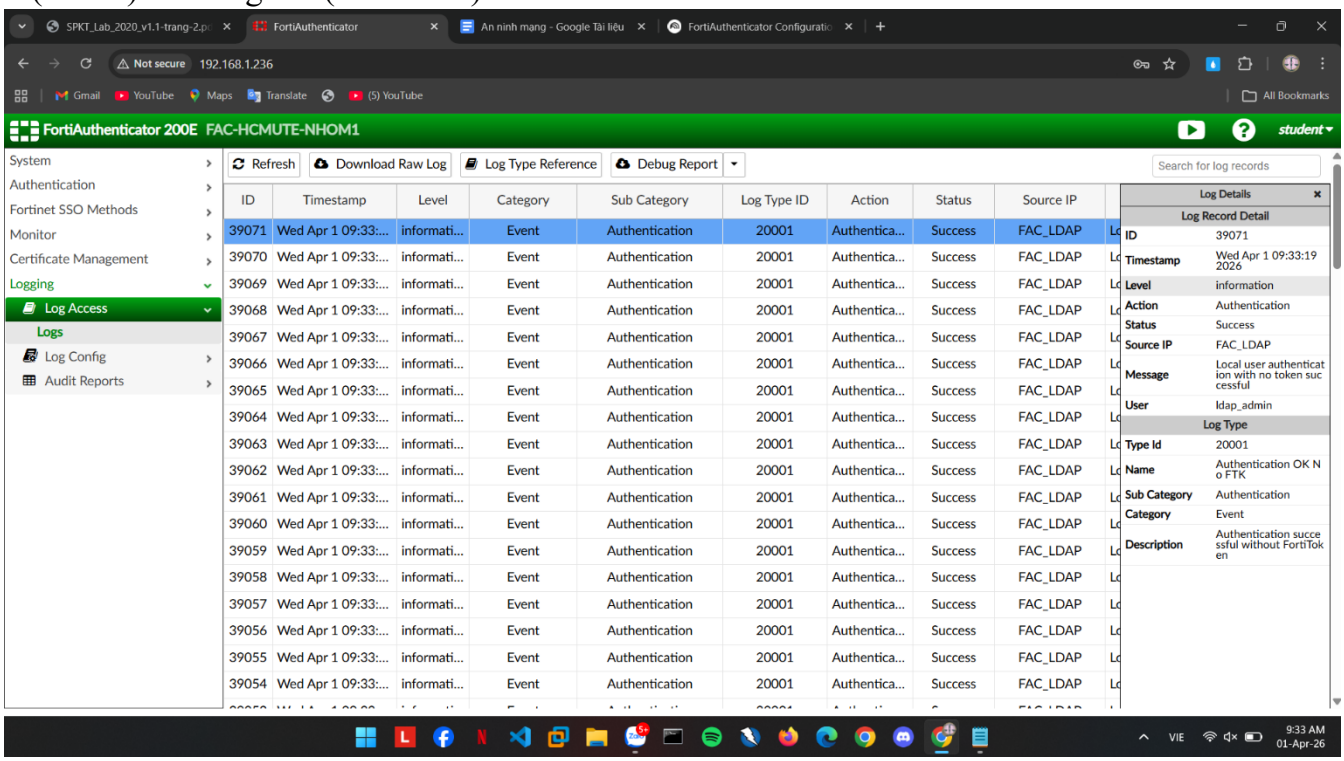
Đánh giá:

Lab 3 minh họa rõ ràng hiệu quả của mô hình bảo mật nhiều lớp (Defense-in-Depth). Ngay cả khi kẻ tấn công có mật khẩu chính xác, họ vẫn không thể đăng nhập nếu không kiểm soát được hộp thư của người dùng — biện pháp phòng thủ hiệu quả chống credential stuffing và password spray. Việc dùng RADIUS làm cầu nối giữa FortiWeb và FortiAuthenticator là thiết kế chuẩn mực, cho phép tái sử dụng chính sách xác thực cho nhiều thiết bị. Trong thực tế cần đảm bảo độ tin cậy kênh email nhận OTP vì đây trở thành yếu tố quyết định khả năng truy cập.

3.4. Lab 4: Thực hành khả năng giám sát xác thực

Truy cập Logging > Log Access > Logs:

Danh sách hiển thị hàng loạt các sự kiện xác thực với đầy đủ các trường thông tin: ID, Thời gian (Timestamp), Mức độ (Level), Danh mục (Category), Hành động (Action), Trạng thái (Status) và IP nguồn (Source IP).



Ví dụ phân tích bản ghi mẫu (ID: 39071):

+ Timestamp: Sự kiện diễn ra vào thứ Tư, ngày 01/04/2026 lúc 09:33:19.

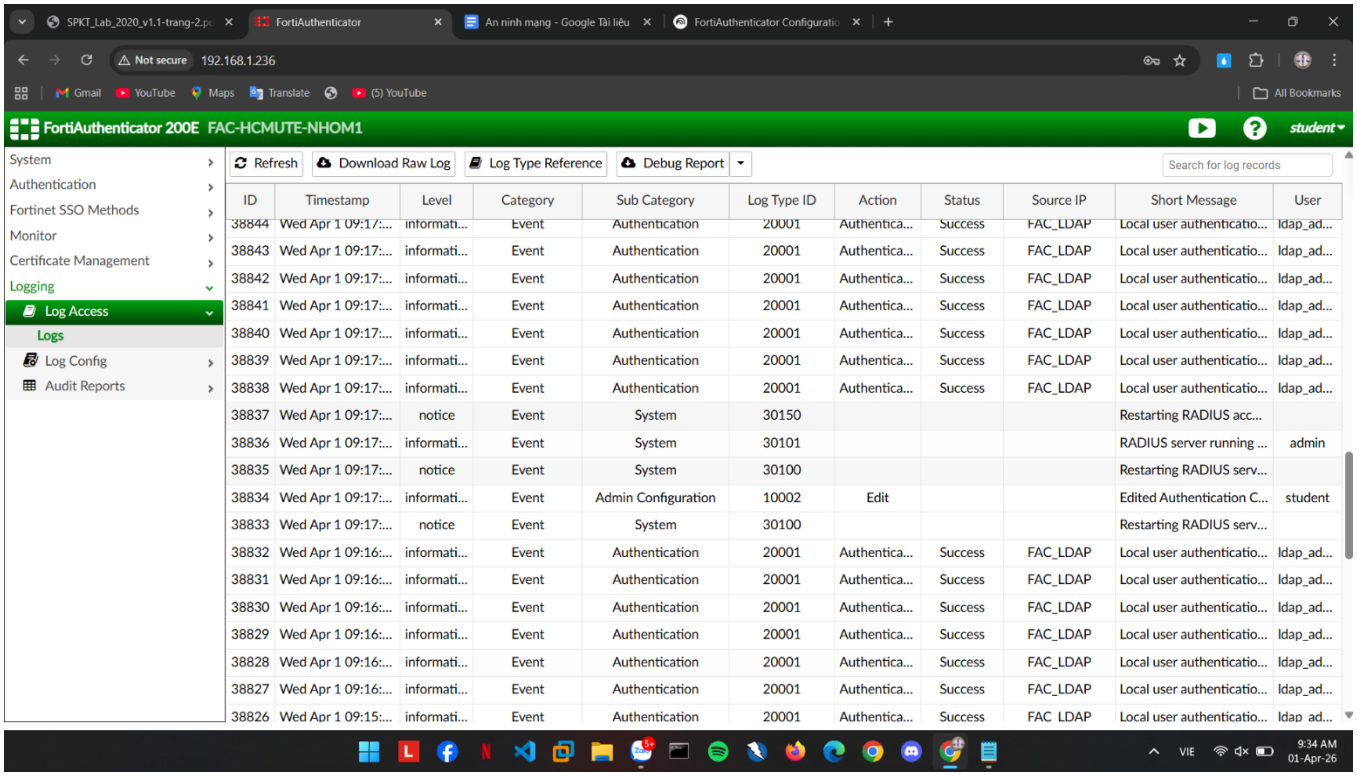
+ User: Tài khoản thực hiện là ldap_admin.

+ Action & Status: Loại sự kiện và trạng thái.

+ Source IP: Yêu cầu xuất phát từ FAC_LDAP, cho thấy đây là một phiên xác thực liên quan đến dịch vụ thư mục.

+ Message: "Local user authentication with no token successful". Bản ghi này xác nhận người dùng đã đăng nhập thành công bằng mật khẩu cục bộ mà không yêu cầu nhân tố thứ hai (FortiToken).

+ Log Type: Thuộc nhóm Event, danh mục con Authentication với ID loại là 20001.



Kết quả:

Lab 4 đã thực hành thành công việc truy cập và phân tích hệ thống nhật ký xác thực qua Logging > Log Access > Logs. Giao diện hiển thị đầy đủ sự kiện theo thời gian thực với các trường: ID, Timestamp, Level, Category, Action, Status, Source IP. Phân tích bản ghi mẫu (ID: 39071, ngày 01/04/2026 lúc 09:33:19): tài khoản ldap_admin xác thực thành công từ FAC_LDAP bằng mật khẩu cục bộ không cần nhân tố thứ hai (thông điệp: "Local user authentication with no token successful"), thuộc loại Event – Authentication (ID: 20001). Giao diện Authentication Monitor hiển thị danh sách tài khoản bị tạm khóa, hỗ trợ phản ứng nhanh với hành vi bất thường.

Đánh giá:

Hệ thống log của FortiAuthenticator đáp ứng tốt yêu cầu kiểm toán (Audit) và điều tra sự cố (Forensics). Mức độ chi tiết cho phép quản trị viên tái hiện chính xác chuỗi sự kiện khi xảy ra vi phạm, đặc biệt hữu ích trong xác định nguồn gốc và thời điểm xâm nhập. Khả năng phân biệt rõ các loại xác thực (Local, LDAP, RADIUS, 2FA) trong cùng giao diện là ưu điểm khi hệ thống tích hợp nhiều phương thức song song. Trong thực tế, cần kết hợp với hệ thống SIEM để tự động hóa phát hiện bất thường và cảnh báo theo thời gian thực.

3.5. Lab 5: Thực hành xác thực SSO

Cấu hình cơ chế Đăng nhập một lần (Single Sign-On) sử dụng giao thức SAML giữa FortiAuthenticator (đóng vai trò Identity Provider - IdP) và FortiGate (đóng vai trò Service Provider - SP). Mục tiêu là cho phép quản trị viên sử dụng một bộ định danh duy nhất để truy cập vào nhiều thiết bị trong hệ thống mà không cần đăng nhập lại nhiều lần.

Bước 1: Thiết lập FortiGate để chuyển hướng yêu cầu đăng nhập về phía máy chủ xác thực tập trung.

Vào Security Fabric > Fabric Connectors > Chọn mục SAML SSO và cấu hình:

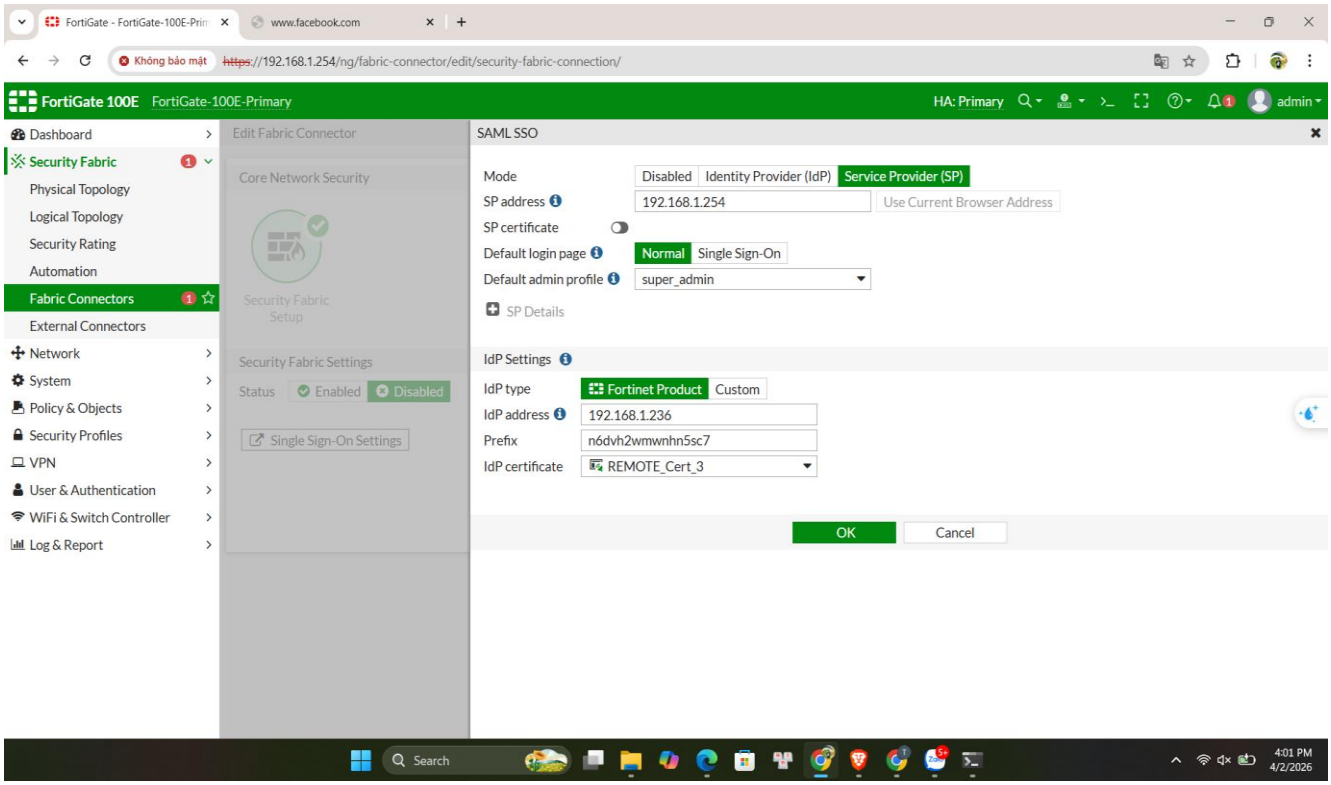
Mode: Service Provider (SP).

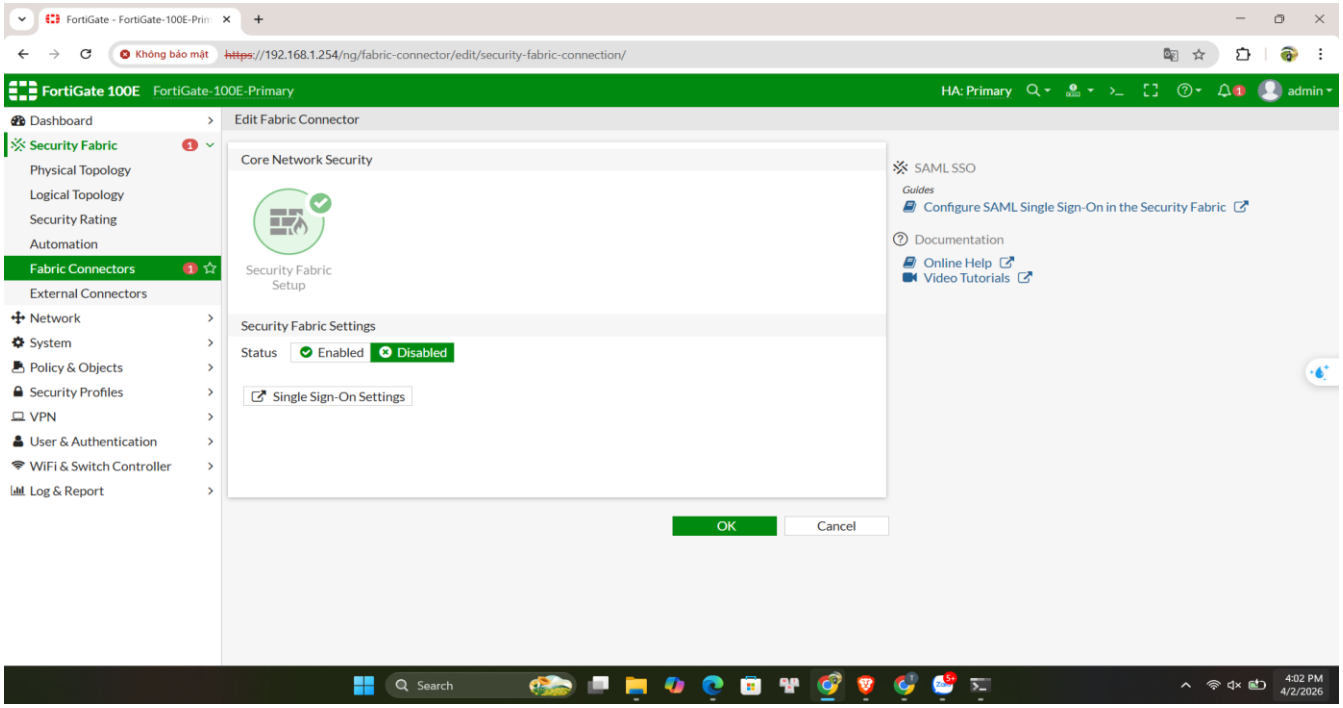
SP address: 192.168.1.254

IdP Type: Chọn Fortinet Product.

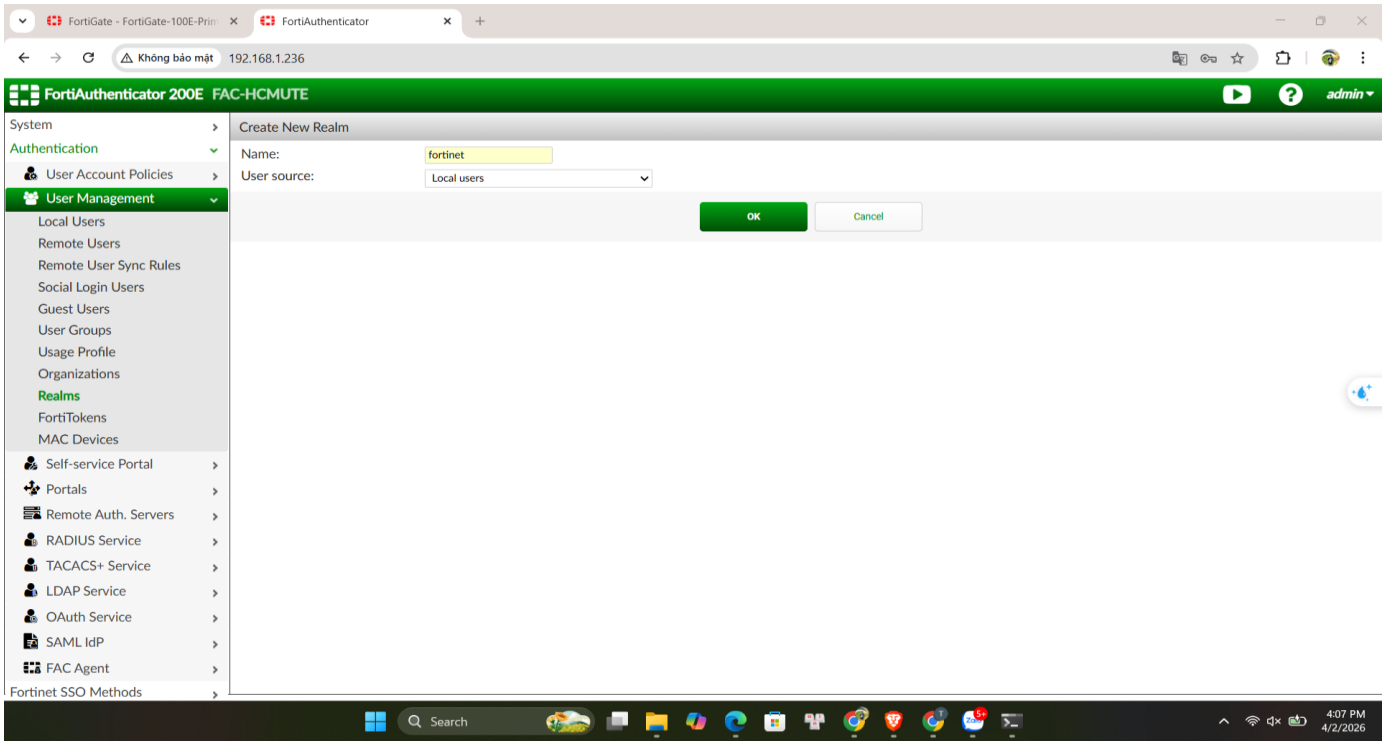
IdP Address: 192.168.1.236 (địa chỉ của FortiAuthenticator).

Default admin profile: Gán quyền super_admin cho các tài khoản đăng nhập qua SSO.





Bước 2: Khởi tạo Realm xác thực Truy cập Authentication > User Management > Realms. Tạo mới một Realm tên là fortinet với nguồn người dùng (User source) là Local users.



Bước 3: Kết nối máy chủ thư mục LDAP để cho phép FortiAuthenticator truy vấn và xác thực người dùng dựa trên cơ sở dữ liệu sẵn có.

- Edit LDAP Server:

Name: AD_HCMUTE_NHOM1

Primary server name/IP: 192.168.1.254

Port 389.

Base distinguished name: dc=hcmute, dc=com

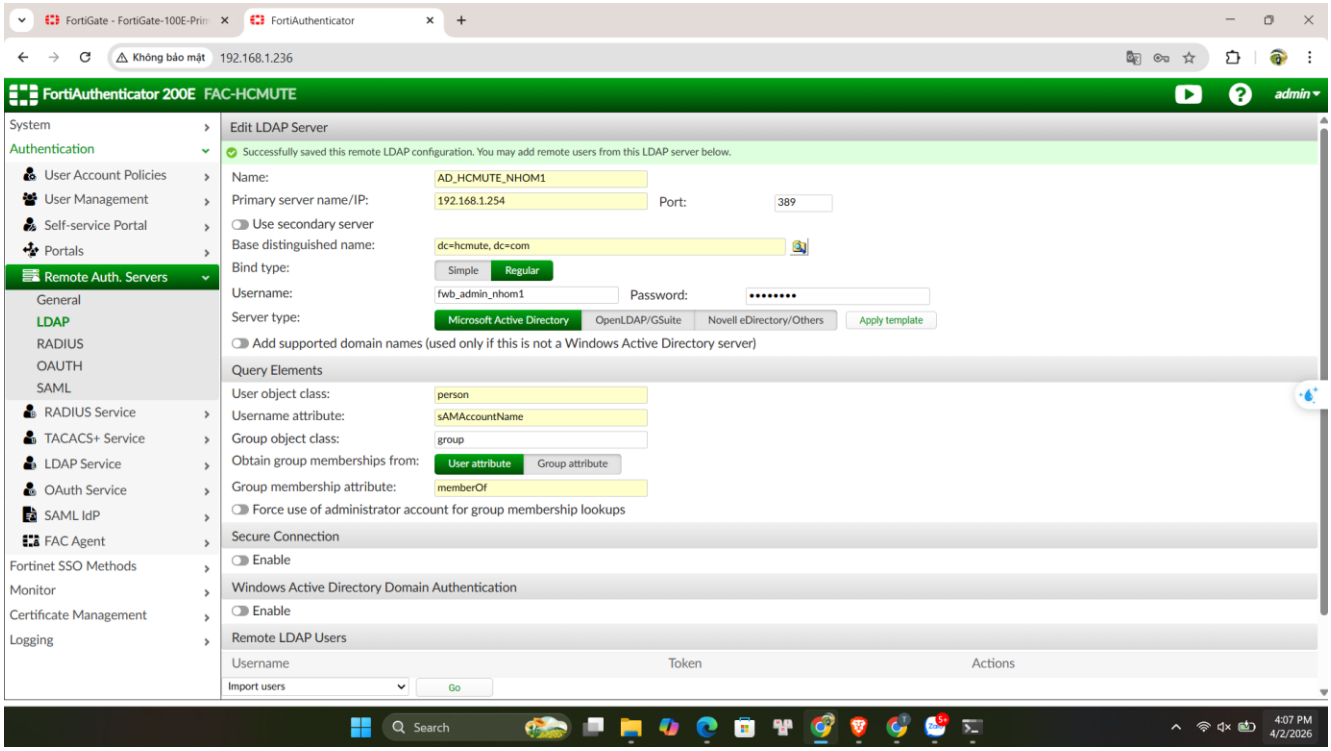
Bind type: Regular, dùng tài khoản quản trị fwb_admin_nhom1 để thực hiện quyền truy vấn vào Active Directory.

Server Type: Thiết bị được tối ưu hóa cho Microsoft Active Directory, giúp tự động hóa việc ánh xạ các thuộc tính người dùng.

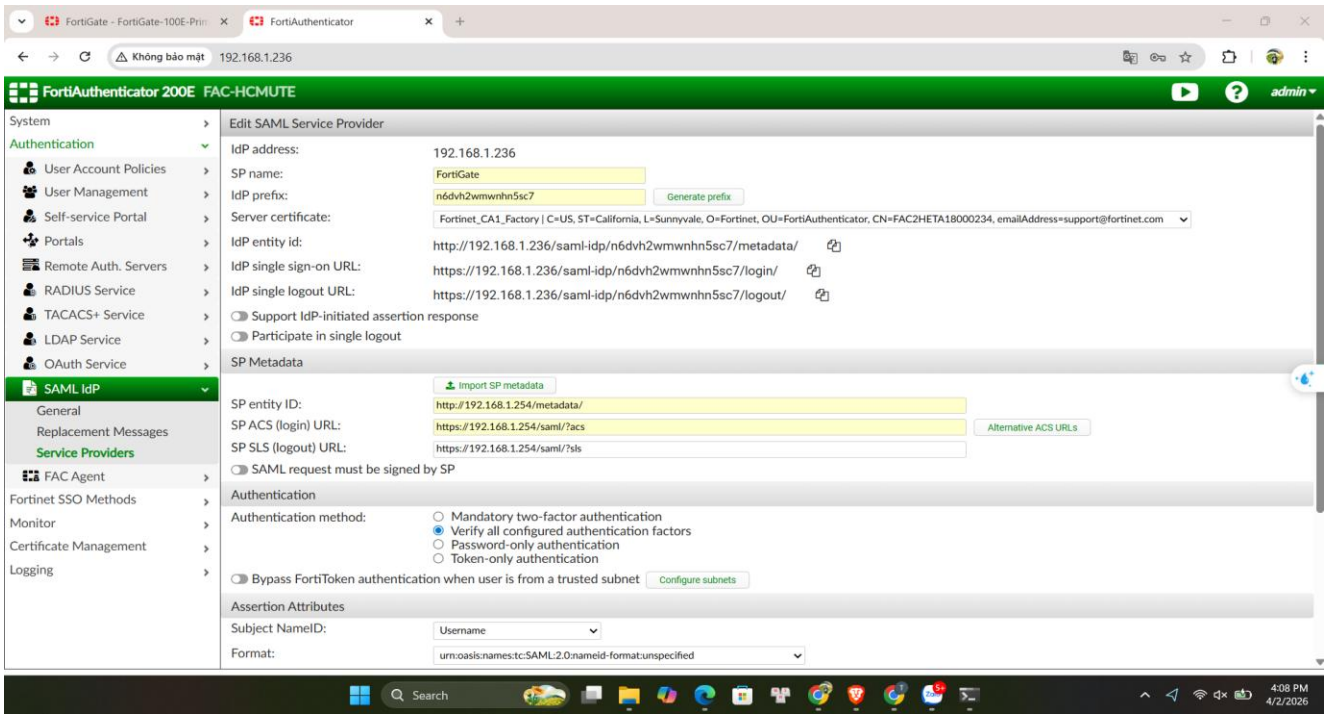
- Query Elements:

Username attribute: Sử dụng thuộc tính sAMAccountName (tên đăng nhập Windows chuẩn) để định danh người dùng.

Group membership attribute: Sử dụng thuộc tính memberOf để xác định quyền hạn của người dùng dựa trên các nhóm (Group) trong AD.



Bước 4: Khai báo Service Provider (FortiGate) trên FortiAuthenticator, thiết lập mối quan hệ tin cậy bằng cách khai báo FortiGate như một Service Provider (SP) bên trong máy chủ xác thực (IdP).



- Thông tin IdP (Identity Provider Info):

IdP address: 192.168.1.236.

IdP entity ID: Đường dẫn metadata dùng để FortiGate có thể tải về các thông số cấu hình tự động.

Server certificate: Sử dụng chứng chỉ mặc định của hệ thống để ký các gói tin xác thực SAML Assertion.

- Thông tin SP (Service Provider Metadata):

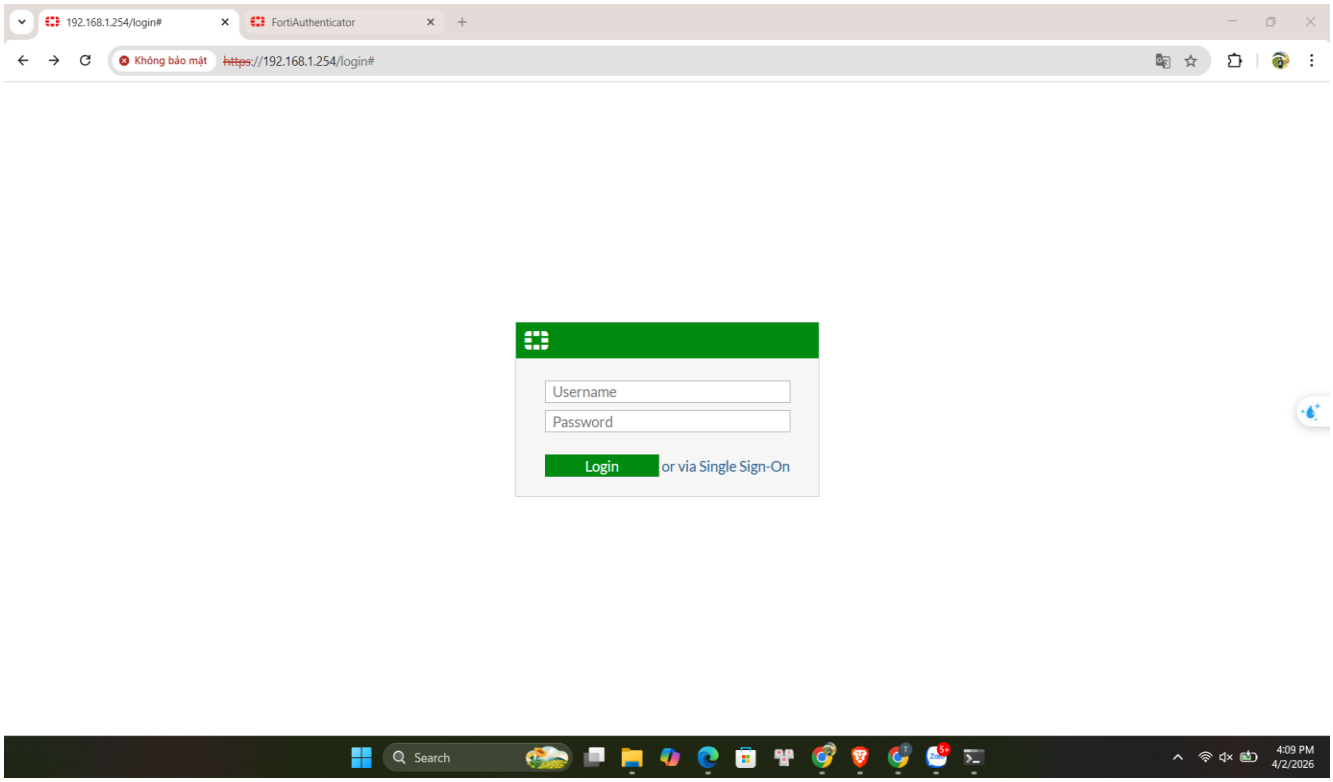
SP name: FortiGate.

SP entity ID: http://192.168.1.254/metadata/ (Trỏ về địa chỉ IP của FortiGate).

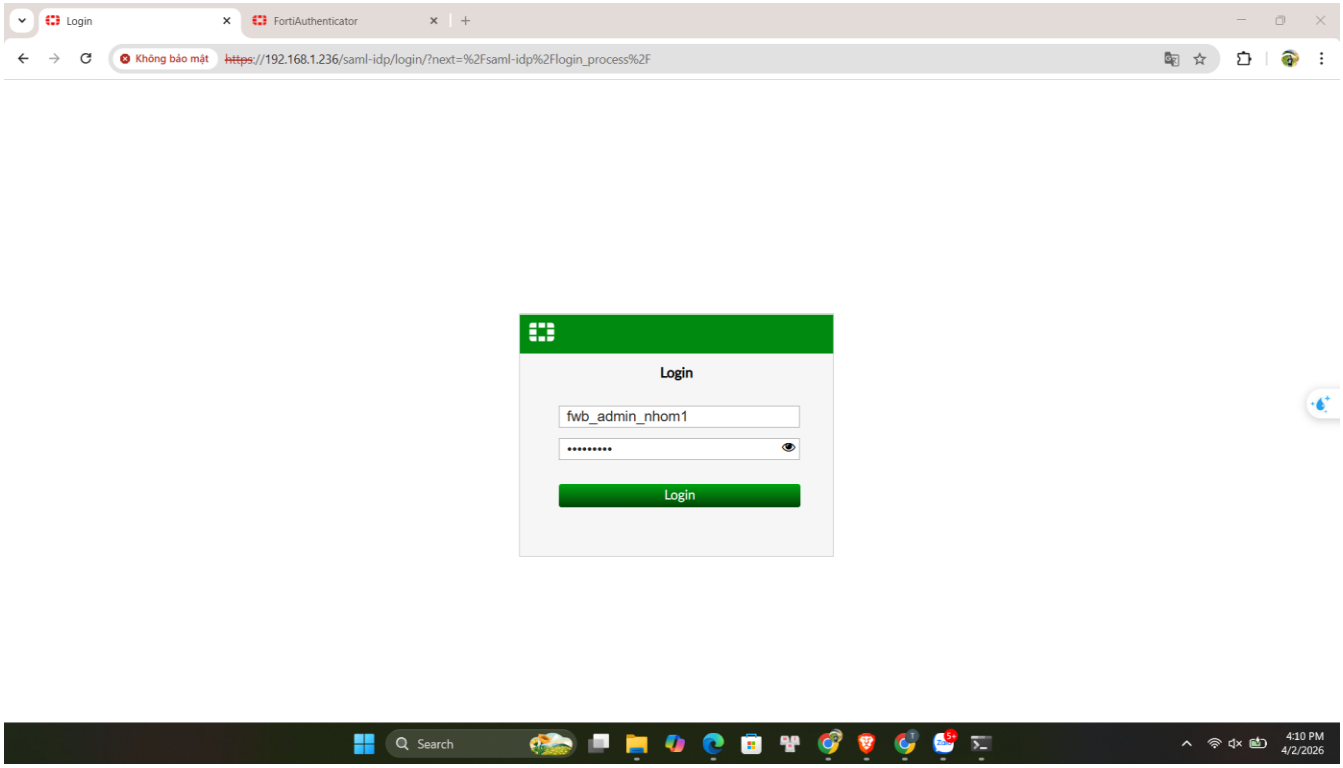
SP ACS (login) URL: https://192.168.1.254/saml/?acs (Địa chỉ mà IdP sẽ gửi phản hồi xác thực sau khi người dùng đăng nhập thành công).

Bước 5: Kiểm tra và xác thực

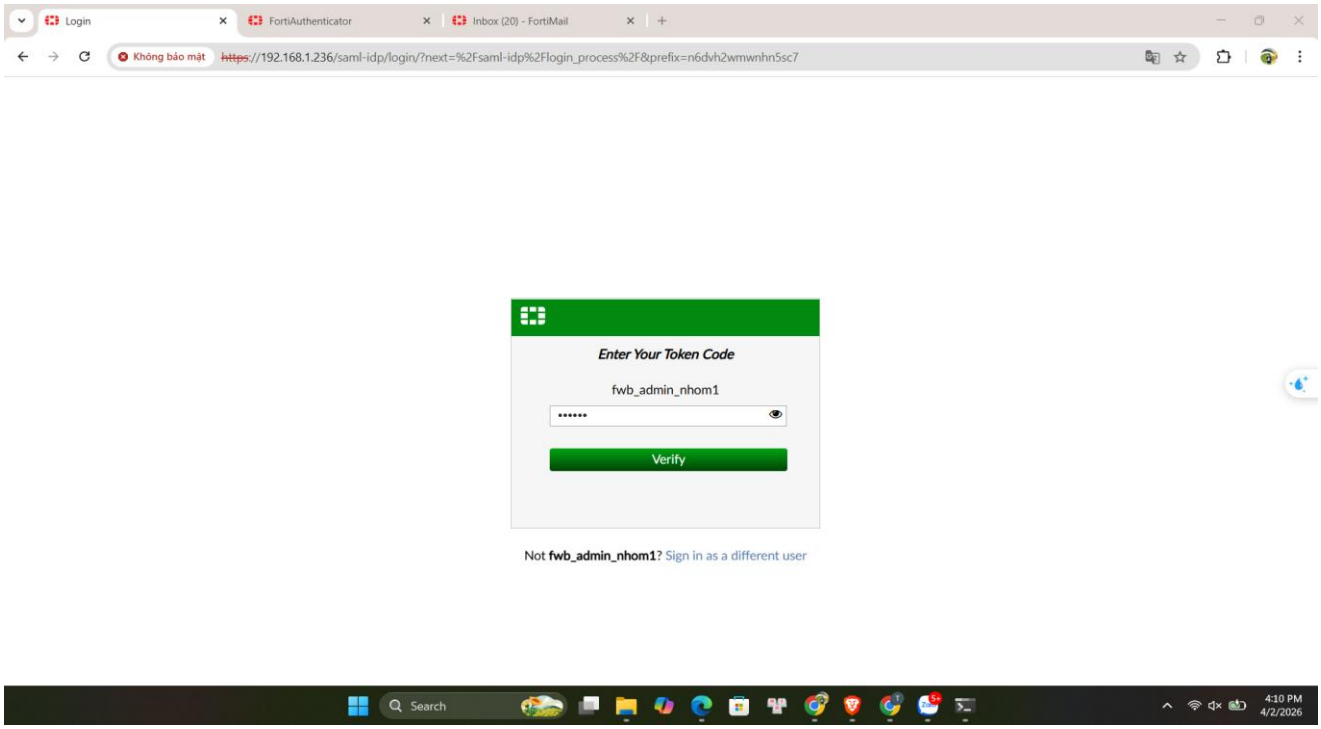
Truy cập giao diện đăng nhập và chọn phương thức SSO



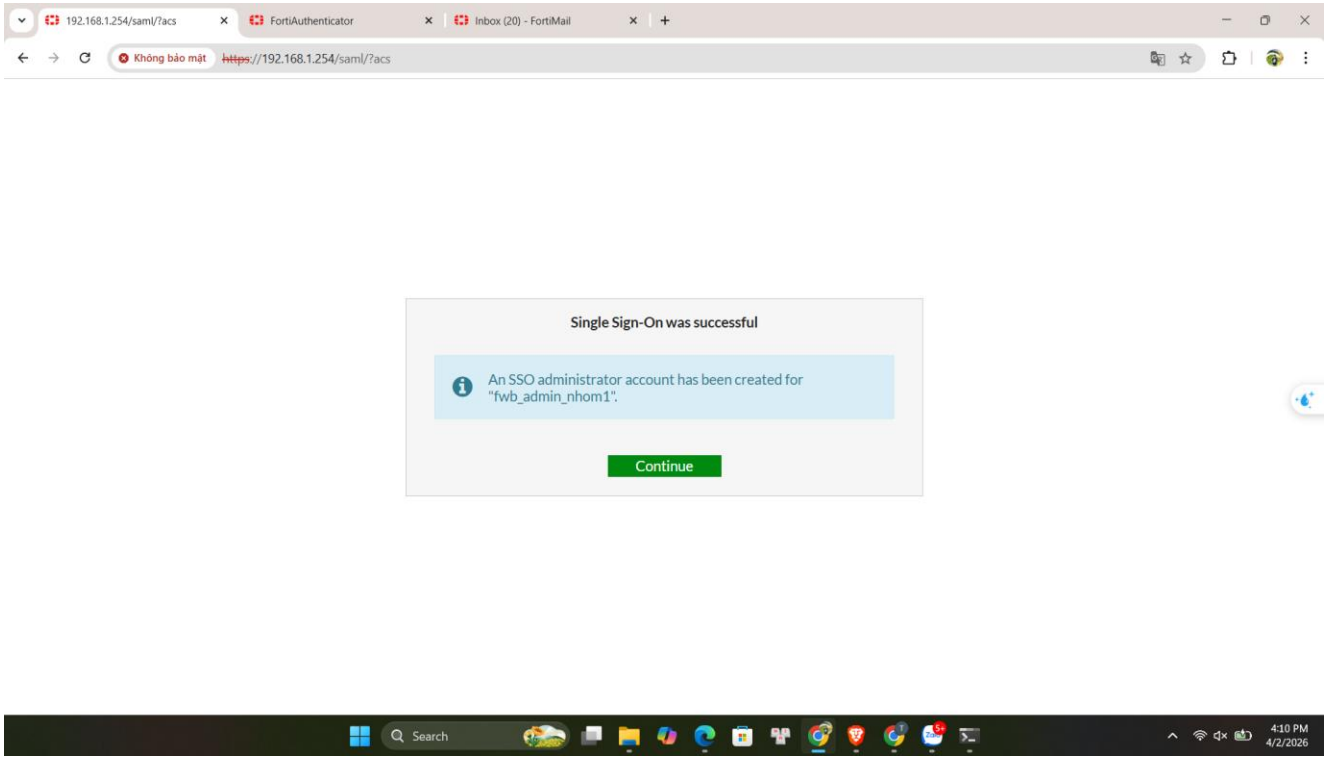
Ngay sau khi chọn SSO, trình duyệt sẽ tự động chuyển hướng sang trang đăng nhập của FortiAuthenticator (IdP) tại địa chỉ 192.168.1.236



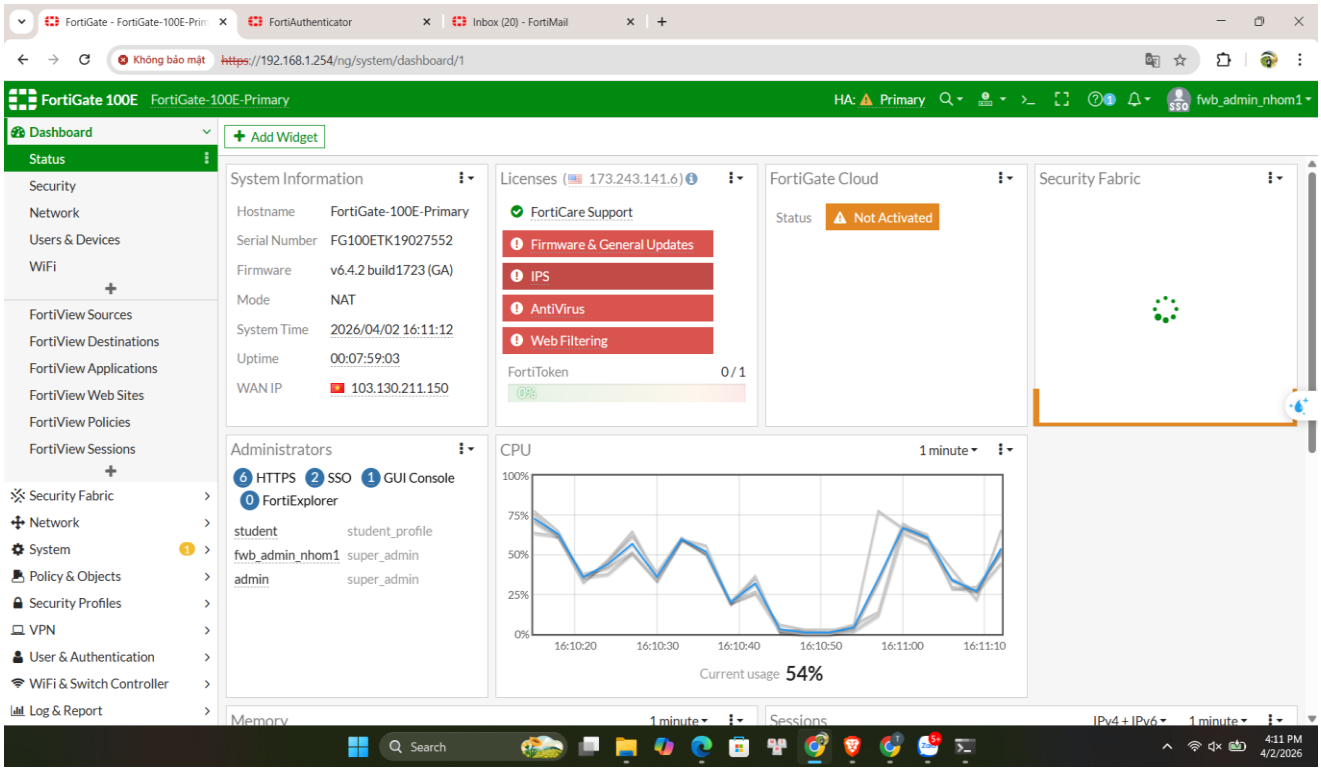
Nhập Token code



Sau khi xác thực thành công, FortiGate sẽ hiển thị thông báo "Single Sign-On was successful". Hệ thống sẽ tự động khởi tạo một tài khoản quản trị tạm thời cho fwb_admin_nhom1 dựa trên các thuộc tính đã nhận được từ IdP.



Nhấn continue sau đó sẽ được chuyển hướng vào Dashboard chính của FortiGate với đầy đủ quyền hạn đã được chỉ định.



Kết quả:

Lab 5 đã cấu hình và kiểm chứng thành công SSO theo chuẩn SAML 2.0 giữa FortiAuthenticator (IdP) và FortiGate (SP). Luồng xác thực hoạt động đúng thiết kế: FortiGate chuyển hướng yêu cầu đến FortiAuthenticator, người dùng xác thực tại IdP, IdP ký và gửi SAML Assertion, FortiGate xác nhận và cấp quyền. Sau khi nhập thông tin đăng nhập và mã Token tại

192.168.1.236, FortiGate hiển thị thông báo "Single Sign-On was successful" và tự động tạo tài khoản quản trị tạm thời cho fwb_admin_nhom1 với quyền super_admin. Người dùng được chuyển thẳng vào Dashboard FortiGate mà không cần đăng nhập lại.

Đánh giá:

Lab 5 minh họa thành công giá trị cốt lõi của SSO: người dùng xác thực một lần tại điểm trung tâm để truy cập nhiều hệ thống mà không lặp lại quy trình đăng nhập, đồng thời tập trung hóa điểm kiểm soát để thu hồi quyền trên toàn hệ thống khi cần. Việc sử dụng SAML 2.0 — chuẩn công nghiệp được chấp nhận rộng rãi — đảm bảo tính tương thích cao và khả năng mở rộng ra ngoài hệ sinh thái Fortinet. Tuy nhiên, cấu hình SAML đòi hỏi đồng bộ chính xác Entity ID và ACS URL; bất kỳ sai lệch nào đều khiến luồng xác thực thất bại hoàn toàn. Trong thực tế cần bổ sung High Availability cho FortiAuthenticator để tránh gián đoạn toàn bộ hệ thống SSO.

PHẦN 3: KẾT LUẬN

Qua quá trình tìm hiểu lý thuyết, triển khai cấu hình và thực hiện kiểm nghiệm thực tế trên thiết bị xác thực tập trung FortiAuthenticator 200E, báo cáo này đã cung cấp một cái nhìn tổng quan về vai trò, cơ chế hoạt động và hiệu quả của một giải pháp quản trị định danh (IAM) hiện đại trong việc bảo vệ hạ tầng mạng doanh nghiệp. Từ việc phân tích các giao thức AAA tiêu chuẩn, đến việc giới thiệu chi tiết về thiết bị FortiAuthenticator 200E và các bước cấu hình thực tế, cuối cùng là đánh giá kết quả thông qua các kịch bản xác thực tích hợp, chúng ta có thể rút ra những kết luận quan trọng.

3.1. Ưu nhược điểm của FortiAuthenticator 200E

Dựa trên các tìm hiểu và kết quả thực hành, thiết bị FortiAuthenticator 200E thể hiện nhiều ưu điểm đáng kể nhưng cũng có một số điểm cần cân nhắc.

Ưu điểm:

Khả năng quản trị định danh tập trung mạnh mẽ: FortiAuthenticator 200E cung cấp một kho lưu trữ danh tính hợp nhất, cho phép chuẩn hóa quy trình xác thực cho toàn bộ hệ thống. Việc tích hợp các dịch vụ RADIUS, LDAP và TACACS+ trên cùng một thiết bị giúp đơn giản hóa công tác quản trị và đảm bảo tính nhất quán của chính sách bảo mật.

Tăng cường bảo mật bằng xác thực đa nhân tố (MFA): Sự hỗ trợ đa dạng các loại Token (FortiToken Mobile, Physical, Email/SMS) tạo ra một lá chắn vững chắc chống lại các cuộc tấn công đánh cắp mật khẩu. Khả năng phê duyệt xác thực qua thông báo đẩy (Push Notification) là một điểm cộng lớn về trải nghiệm người dùng.

Tích hợp sâu rộng trong hệ sinh thái Fortinet Security Fabric: Thiết bị đóng vai trò là "nguồn sự thật" về định danh cho các sản phẩm khác như FortiGate, FortiWeb và FortiMail. Cơ chế FSSO giúp các thiết bị thực thi chính sách nhận diện người dùng ngay lập tức, hỗ trợ triển khai mô hình bảo mật dựa trên định danh (User-based) hiệu quả hơn địa chỉ IP truyền thống.

Dịch vụ chứng thư số (PKI) toàn diện: Khả năng hoạt động như một Root CA hỗ trợ đầy đủ các giao thức cấp phát chứng chỉ tự động (SCEP, EST) giúp tổ chức dễ dàng triển khai xác thực thiết bị và mã hóa kênh truyền mà không cần đầu tư thêm các giải pháp PKI phức tạp bên thứ ba.

Giao diện quản lý trực quan và khả năng giám sát tốt: Giao diện web (GUI) của FortiAuthenticator tương đối thân thiện, khoa học. Hệ thống nhật ký (Logs) và các công cụ giám sát (Monitor) cung cấp dữ liệu chi tiết, giúp quản trị viên dễ dàng theo dõi trạng thái xác thực và điều tra các sự cố an ninh định danh.

Nhược điểm:

Độ phức tạp trong cấu hình tích hợp nâng cao: Mặc dù giao diện cơ bản khá thân thiện, nhưng việc cấu hình các tính năng nâng cao như SAML IdP, tích hợp sâu với các hệ thống thư mục AD ngoại vi hoặc tùy chỉnh Captive Portal đòi hỏi kiến thức chuyên môn sâu và thời gian tìm hiểu, thử nghiệm kỹ lưỡng.

Chi phí bản quyền và thiết bị phụ trợ: Mặc dù thiết bị có giá thành cạnh tranh trong phân khúc, nhưng việc duy trì và mở rộng số lượng người dùng, cũng như chi phí trang bị các gói FortiToken (đặc biệt là Hard Tokens) là một yếu tố cần xem xét trong tổng chi phí sở hữu (TCO).

Rủi ro điểm yếu đơn nhất (Single Point of Failure): Khi toàn bộ quy trình xác thực của doanh nghiệp được tập trung vào một thiết bị duy nhất, bất kỳ sự cố phần cứng hoặc kết nối nào trên FortiAuthenticator cũng có thể gây gián đoạn truy cập cho toàn bộ hệ thống. Do đó, việc triển khai cụm dự phòng (High Availability) là cần thiết nhưng lại làm tăng chi phí đầu tư.

3.2. Tổng kết

Thông qua báo cáo, nhóm đã thực hiện một nghiên cứu chi tiết và thực nghiệm về hệ thống xác thực tập trung, tập trung vào việc triển khai và đánh giá hiệu quả của thiết bị FortiAuthenticator 200E. Xuất phát từ nhu cầu cấp thiết trong việc bảo vệ định danh người dùng trước các mối đe dọa an ninh mạng ngày càng tinh vi, báo cáo đã đặt mục tiêu tìm hiểu sâu về cơ chế hoạt động của AAA nói chung và khám phá các khả năng cụ thể của giải pháp Fortinet.

Thông qua việc kết hợp giữa tìm hiểu lý thuyết về các giao thức (RADIUS, LDAP, FSSO, SAML) và việc giới thiệu chi tiết thông số kỹ thuật của FortiAuthenticator 200E, báo cáo đã xây dựng một nền tảng kiến thức vững chắc. Phần trọng tâm của báo cáo là việc mô tả chi tiết quá trình triển khai cấu hình các chính sách bảo mật định danh trong môi trường Lab, bao gồm thiết lập các đối tượng người dùng, triển khai xác thực đa nhân tố và quản lý chứng thư số.

Quá trình kiểm nghiệm và đánh giá kết quả thực hiện qua các kịch bản thực tế đã xác nhận một cách thuyết phục rằng FortiAuthenticator 200E là một giải pháp IAM mạnh mẽ và hiệu quả. Thiết bị đã chứng minh khả năng nhận diện và kiểm soát truy cập thành công qua nhiều tầng bảo mật khác nhau, nhờ vào kiến thức bảo mật đa lớp và sự hỗ trợ từ hệ sinh thái Security Fabric. Các tính năng như MFA và quản lý định danh tập trung đã cho thấy giá trị gia tăng đáng kể, giúp nâng cao khả năng phòng thủ chủ động và thích ứng của hệ thống mạng.

Nhìn chung, nghiên cứu này không chỉ cung cấp kiến thức về một giải pháp xác thực cụ thể mà còn minh họa quy trình tiếp cận, triển khai và đánh giá một công nghệ bảo mật quan trọng. FortiAuthenticator 200E đã được chứng minh là một công cụ bảo mật giá trị, đặc biệt phù hợp với nhu cầu của các doanh nghiệp vừa và nhỏ, góp phần đảm bảo an toàn cho các tài sản số trong môi trường chuyển đổi số hiện nay.

TÀI LIỆU THAM KHẢO

[1]. FortiAuthenticator Data Sheet. (n.d.). Fortinet. Retrieved April 7, 2026, from https://www.fortinet.com/content/dam/fortinet/assets/data-sheets/FortiAuthenticator.pdf

[2]. Configuring FortiAuthenticator as a RADIUS server in FortiGate from https://docs.fortinet.com/document/fortiauthenticator/8.0.0/examples/592089/configuring-fortiauthenticator-as-a-radius-server-in-fortigate

[3]. Thietbifortinet.vn. (2024). FortiAuthenticator - Giải pháp quản lý xác thực tập trung và bảo mật. https://thietbifortinet.vn/bai-viet/fortiauthenticator-quan-ly-xac-thuc-111.html

[4]. Fortinet Community. (2024). Troubleshooting Tip: Basic FortiAuthenticator troubleshooting. https://community.fortinet.com/t5/FortiAuthenticator/Troubleshooting-Tip-Basic-FortiAuthenticator-troubleshooting/ta-p/337001

[5]. Fortinet. (2024). FortiAuthenticator 7.4.0 Administration Guide. https://docs.fortinet.com/product/fortiauthenticator/7.4